

ENSAE PARIS
NEXIALOG CONSULTING

Quantification du SCR lié à la non-conformité au règlement DORA

Un premier pont quantitatif entre résilience opérationnelle numérique et solvabilité
prudentielle

Mémoire d'actuariat

Auteur : Kélian Kaddouri
Établissement : ENSAE Paris — Master Actuariat
Structure d'accueil : Nexialog Consulting
Encadrant professionnel : Hugo Rapior
Référente académique : Caroline Hillairet

Sommaire

Introduction	1
État de l'art	1
0.1 Les limites de l'assurabilité et la rareté des données	2
0.2 Modélisation de la contagion et dynamique systémique	2
0.3 Risques extrêmes et agrégation (Copules)	2
0.4 La Théorie des Valeurs Extrêmes en actuariat : lignée et application au cyber . .	3
0.5 De Solvabilité II à DORA : Le pont quantitatif	3
1 Le cadre réglementaire : de Bâle III et Solvabilité II au règlement DORA	4
1.1 L'écosystème réglementaire : Bâle III, Solvabilité II, DORA	4
1.2 Ce que DORA exige concrètement : les cinq piliers ICT	6
1.3 1.3 — ORSA $\leftrightarrow$ DORA : recouvrement et divergences	7
1.4 1.4 — La probabilité de défaut de conformité comme variable latente	8
1.5 1.5 — Contagion interne et contagion externe via tiers ICT	10
Cadre mathématique de la modélisation des risques extrêmes	10
1.6 Justification de l'EVT et Théorème de Fisher-Tippett-Gnedenko (GEV)	11
1.7 Le passage au Peaks-Over-Threshold (POT) et la GPD	11
1.8 Estimation des paramètres : Maximum de Vraisemblance vs Estimateur de Hill . .	12
1.9 Modélisation de la dépendance de queue : le choix de la Copule de Gumbel . . .	14
1.10 Transformation d'un choc systémique en risque de conformité : le modèle de Vasicek	15
2 Données et limites	16
2.1 Exigences de Solvabilité II sur la qualité des données (Article 19)	17
2.2 Analyse critique des bases de sinistralité : les trois biais fondamentaux	17
2.3 Traitement de l'inflation cyber et actualisation des pertes	18
2.4 Perspectives : Le registre européen DORA comme solution pérenne	19
2.5 La PRC comme proxy de fréquence : périmètre, biais, justification	19
2.6 Hackmageddon : apports et limites	20
2.7 SAS OpRisk Global : proxy de sévérité ICT, lien avec l'approche AMA de Bâle 3	21
2.8 Cadre épistémique : ce qu'on sait faire et ce qu'on ne sait pas faire	22
2.9 Suffisance du dispositif de données pour l'exercice actuariel	23
2.10 Validation croisée externe : ENISA Threat Landscape	24
3 Modélisation	24
3.1 Architecture LDA : les quatre briques de perte	25
3.2 Fréquence : NegBin, calibration PRC, sur-dispersion	25
3.3 Sévérité : EVT/GPD, calibration OpRisk, validation croisée PRC	26

3.4	Dépendance : copule de Gumbel, contagion, modèle à facteur commun	28
3.5	Agrégation Monte Carlo et allocation d'Euler	29
4	Scénarios de conformité DORA	30
4.1	Les trois niveaux de non-conformité	30
4.2	Mapping vecteurs d'attaque $\rightarrow$ exigences DORA	31
4.3	Multiplicateurs de fréquence différenciés par exigence	31
4.4	Propagation et Δ_{DORA} : distribution, pas un point	32
4.5	Bootstrap et intervalles de confiance	33
	Comparaison méthodologique des approches	34
4.6	La Formule Standard (Solvabilité II) : une mesure aveugle à la résilience	34
4.7	L'approche par scénarios déterministes (ORSA) : l'illusion de la précision	35
5	Résultats et discussion	36
5.1	Distribution du SCR_DORA : ancrage sur une entité de 15 000 M€	36
5.2	Décomposition de l'incertitude (variance par source)	38
5.3	Allocation d'Euler : contribution de chaque brique	40
5.4	Analyse de sensibilité aux hypothèses porteuses	41
5.5	Robustesse du verdict aux hypothèses de mapping DORA	43
5.6	Ancrage empirique des multiplicateurs : une hypothèse conservatrice	44
5.7	Robustesse de la calibration de sévérité : validation temporelle et adéquation formelle	45
5.8	Sensibilité au choix du seuil POT	47
5.9	Robustesse du moteur de simulation : famille de copule et convergence Monte Carlo	48
5.10	Triangulation méthodologique : le SCR par quatre méthodes indépendantes	50
5.11	Comparaison avec les travaux antérieurs	52
5.12	Implications pour la réassurance cyber : l'assurabilité de dernier recours	54
5.13	Implications pour l'ORSA et le pilotage réglementaire	55
	Conclusion	56
	Perspectives de raffinement	56
A	Démonstrations complémentaires	58
A.1	Fisher–Tippett–Gnedenko (Théorème 1.1)	58
A.2	Pickands–Balkema–de Haan (Théorème 1.2)	58
A.3	Dérivation de l'approximation SLA (§5.10)	58
A.4	Récursion de Panjer : principe et exemple	58
A.5	Information de Fisher de la GPD (Proposition 1.3)	59
A.6	Estimateur de Hill (Proposition 1.4)	59
A.7	VaR et TVaR de la GPD (Proposition 1.5)	59

A.8	Queues de la copule de Gumbel (Proposition 1.6)	59
A.9	Sensibilité du modèle de Vasicek (Proposition 1.7)	60
A.10	Allocation d'Euler (Théorème 3.1)	60
B	Table des notations	61
C	Algorithmes	62
D	Paramètres calibrés	63
	Références	64

Introduction

Le risque cyber occupe aujourd'hui une place singulière dans le paysage prudentiel des institutions financières. Sa nature hybride — à la fois opérationnelle, technologique et parfois systémique — le place à la croisée de plusieurs cadres réglementaires qui, historiquement, ne dialoguaient pas directement entre eux. En assurance, le risque opérationnel demeure traité dans la formule standard de Solvabilité II par un chargement forfaitaire, peu sensible à la qualité réelle de l'infrastructure numérique d'un assureur. Parallèlement, le règlement DORA impose depuis 2025 un cadre détaillé de résilience opérationnelle numérique, sans pour autant fournir de traduction directe en exigence de capital.

Objet du mémoire. L'objet de ce mémoire est la **quantification actuarielle du risque cyber** d'une entité financière, envisagée non pas comme un exercice descriptif de conformité, mais comme un exercice de mesure des **pertes potentielles prospectives** susceptibles de résulter d'un non-respect, partiel ou total, des exigences du règlement DORA. Il ne s'agit donc pas de vérifier, poste par poste, la conformité réglementaire d'un assureur, mais de traduire un niveau de non-conformité — même hypothétique ou graduel — en une distribution de pertes financières futures, puis en un surcroît de capital de solvabilité mesurable. Cette démarche prospective est ce qui distingue le présent travail d'un audit de conformité classique : l'ambition est de répondre à la question « *que pourrait-il en coûter, en fonds propres, de ne pas se conformer à DORA ?* », et non à la question « *l'entité est-elle conforme aujourd'hui ?* ».

C'est dans cet interstice, entre un règlement de résilience opérationnelle et un cadre de solvabilité financière, que se situe la problématique de ce mémoire : *comment transformer la non-conformité à DORA en une variable quantitative susceptible d'alimenter une mesure interne de capital sous Solvabilité II ?* Il ne s'agit pas de proposer une nouvelle formule réglementaire de Pilier 1, mais de construire, dans l'esprit du Pilier 2 et de l'ORSA, un premier pont quantitatif entre les deux cadres. Cette articulation n'a, à notre connaissance, pas encore été formalisée de façon aussi directe dans la littérature actuarielle française : l'essentiel des travaux traite soit du risque cyber comme risque assurantiel classique, soit de DORA comme sujet de conformité, rarement des deux ensemble sous une même mécanique de capital.

Le mémoire se déploie en cinq parties. La première pose le cadre réglementaire et conceptuel dans lequel s'inscrit la démarche, de Bâle III à DORA, en passant par Solvabilité II. La deuxième présente les données mobilisées, leurs apports et leurs limites. La troisième détaille l'architecture de modélisation retenue, fondée sur une approche par distribution des pertes (LDA) enrichie de quatre briques. La quatrième formalise les scénarios de conformité DORA et la construction du Δ_{DORA} , mesure directe du surcoût prospectif de la non-conformité. La cinquième présente les résultats obtenus, leur interprétation actuarielle et leurs implications pour le pilotage prudentiel.

État de l'art : de l'assurabilité du risque cyber à la réglementation DORA

Avant de détailler la modélisation mathématique retenue pour quantifier le Capital de Solvabilité Requis (SCR) lié à DORA, il est indispensable de positionner ce travail dans la littérature actuarielle récente. Le risque cyber, de par sa nature évolutive et systémique, bouscule les paradigmes traditionnels de l'assurance non-vie et de la gestion des risques opérationnels.

0.1 Les limites de l'assurabilité et la rareté des données

La littérature s'est d'abord concentrée sur la question fondamentale de l'assurabilité du risque cyber. Biener, Eling et Wirfs (Biener et al., 2015) ont démontré que le risque cyber peine à satisfaire les critères classiques d'assurabilité, principalement en raison de l'asymétrie d'information et du risque d'accumulation extrême.

Face à ce constat, le principal obstacle à la quantification prudentielle reste le manque de bases de données de sinistralité exhaustives. Les travaux fondateurs de **Caroline Hillairet** et **Olivier Lopez** (Hillairet and Lopez, 2021) ont largement contribué à structurer l'exploitation des données publiques telles que la base *Privacy Rights Clearinghouse* (PRC). Maillart et Sornette (Maillart and Sornette, 2010) avaient déjà mis en évidence la nécessité d'utiliser la Théorie des Valeurs Extrêmes (EVT) pour traiter les montants de pertes, démontrant que le coût des méga-fuites de données suit des distributions à queues lourdes (notamment des lois de Pareto) dont l'espérance mathématique peut, dans certains régimes, diverger. Cette caractéristique justifie pleinement notre choix méthodologique d'appliquer une distribution de Pareto Généralisée (GPD) sur les bases PRC et OpRisk, tout en imposant des plafonds opérationnels pour stabiliser l'allocation de capital.

0.2 Modélisation de la contagion et dynamique systémique

Le deuxième grand axe de recherche actuarielle sur le cyber concerne la contagion. Contrairement aux risques climatiques (géographiquement circonscrits), le risque cyber s'affranchit des frontières physiques via les réseaux informatiques.

Les travaux de **Boumezoued**, **Hillairet** et leurs co-auteurs ont exploré l'utilisation de modèles épidémiologiques et de processus de branchement pour quantifier cette contagion au sein des portefeuilles d'assurance, notamment le processus de Hawkes multivarié (Bessy-Roland et al., 2021), qui capture l'auto-excitation des cyberattaques (une faille *zero-day* déclenchant une vague de sinistres rapprochés dans le temps), et le modèle de contagion à structure de réseau (Hillairet et al., 2022). Plus récemment, Hillairet, Lopez et Sopgoui (Hillairet et al., 2026) proposent un modèle SIR stochastique couplant contagion épidémique (processus de Cox) et croissance granulaire des firmes, appliqué aux attaques LockBit de 2024 sur un portefeuille de près de 3 000 entreprises franciliennes ; ce cadre distingue explicitement contagion idiosyncratique et systémique, une distinction que nous retrouvons en 1.5.

Bien que les processus de Hawkes et les modèles SIR soient extrêmement performants pour la tarification dynamique et la modélisation fine de la propagation, ils s'avèrent très lourds à implémenter pour un calcul de SCR réglementaire (qui nécessite une vision statique à un an, la VaR 99,5 %). C'est pourquoi, dans ce mémoire, nous avons fait le pont entre ces constats de contagion cyber et les modèles de risque de crédit. En nous inspirant de la dynamique de dépendance systémique de type Vasicek (Merton), nous modélisons la probabilité conditionnelle de défaut de conformité d'une entité face à un choc macro-cyber. Le remplacement de ce facteur unique par un processus de contagion de type SIR/Cox, plus fidèle à la dynamique réelle mais nécessitant une réévaluation dynamique du capital, constitue une perspective naturelle de raffinement (cf. Conclusion).

0.3 Risques extrêmes et agrégation (Copules)

La question de l'agrégation des risques extrêmes est centrale dans le calcul du SCR. Les travaux de **Farkas**, Lopez et Thomas (Farkas et al., 2021) sur le risque opérationnel soulignent la difficulté d'allouer du capital lorsque les différentes lignes de métier (ou briques de risque) sont soumises à des chocs lourds simultanés ; leur méthode d'arbres de régression Pareto généralisés, qui segmente automatiquement la sévérité par sous-population homogène plutôt que d'imposer

un seuil global unique, rejoint l'esprit de la segmentation manuelle Systems Security / Business Disruption que nous opérons en 2.4.4 sur OpRisk Global — sans toutefois en reproduire l'automatisation par arbre.

La formule standard de Solvabilité II utilise des matrices de corrélation linéaire qui échouent mathématiquement à capturer la dépendance dans les extrêmes (la queue de distribution). La littérature préconise l'usage de copules. Dans le sillage de ces recommandations, notre modèle rejette la copule Gaussienne au profit de la **copule de Gumbel**, garantissant une dépendance de queue supérieure stricte, essentielle pour simuler un scénario où une amende DORA majeure coïnciderait avec la défaillance systémique d'un prestataire cloud de rang 1.

0.4 La Théorie des Valeurs Extrêmes en actuariat : lignée et application au cyber

Le socle mathématique mobilisé dans ce mémoire s'inscrit dans une lignée actuarielle bien établie. La théorie asymptotique des extrêmes remonte aux résultats fondateurs de [Fisher and Tippett \(1928\)](#) et [Gnedenko \(1943\)](#) sur les lois limites de maxima, prolongés par [Pickands III \(1975\)](#) et [Balkema and de Haan \(1974\)](#) qui fondent l'approche *Peaks-Over-Threshold* en établissant la convergence des excès vers la GPD (Théorèmes 1.1 et 1.2). La synthèse de référence pour l'assurance et la finance demeure l'ouvrage de [Embrechts et al. \(1997\)](#), *Modelling Extremal Events*, qui systématise l'usage de la GPD, de l'estimateur de [Hill \(1975\)](#) et du *mean excess plot* pour la tarification des risques à queue lourde; [McNeil et al. \(2015\)](#) en donnent la formulation moderne intégrée aux mesures de risque cohérentes (VaR, Expected Shortfall) et à l'allocation de capital, cadre que nous adoptons.

L'application spécifique de l'EVT au risque cyber est plus récente mais convergente. [Maillard and Sornette \(2010\)](#) montrent, sur les fuites de données américaines, que la taille des brèches suit une loi de Pareto d'indice proche de l'unité — résultat que notre calibration PRC ($\hat{\xi} = 1,03$) reproduit et que le §5.8 confirme comme robuste au choix du seuil. [Wheatley et al. \(2016\)](#) étendent ce constat par une analyse en valeurs extrêmes des méga-brèches, tandis que [Eling and Wirfs \(2019\)](#) appliquent explicitement une décomposition POT/GPD aux pertes opérationnelles cyber, documentant des indices de queue élevés et une frontière ténue avec le régime d'espérance infinie. [Eling and Loperfido \(2017\)](#) recourent aux copules et à l'analyse multivariée pour modéliser la dépendance entre types de brèches. Notre travail se situe au confluent de ces deux lignées : il applique l'appareil POT/GPD classique (Embrechts, McNeil) aux bases cyber (Maillard, Eling), mais en le connectant — via la variable latente de Vasicek et l'allocation d'Euler — à un objectif prudentiel inédit, la quantification du surcoût de capital lié à la non-conformité DORA.

0.5 De Solvabilité II à DORA : Le pont quantitatif

Historiquement, le risque cyber était relégué au sein du « risque opérationnel », quantifié de manière rudimentaire par la formule standard de Solvabilité II via un pourcentage des primes (BSCR). Cette approche « forfaitaire » ne récompense pas les investissements en cybersécurité.

Le règlement européen DORA (Digital Operational Resilience Act) change ce paradigme en imposant des standards stricts de résilience IT, de gestion des tiers prestataires et de report d'incidents. Cependant, DORA est un texte de conformité qualitative. Le défi actuel de la place financière est de traduire ces exigences en impacts bilanciaux.

C'est très exactement dans cette dynamique d'innovation méthodologique que s'inscrivent les travaux internes menés chez Nexialog Consulting sous la supervision de **Hugo Rapior**. L'approche développée dans ce mémoire formalise cette traduction : il s'agit de passer d'un constat binaire (conforme / non-conforme) à une modélisation continue du risque (le Delta DORA). En isolant la brique « Prestataires » (Chapitre V de DORA) et la brique « Sanctions » administratives, ce modèle interne partiel de type LDA propose un premier pont quantitatif rigoureux entre la résilience opérationnelle numérique (DORA) et la solvabilité prudentielle

(Pilier 1 et ORSA de Solvabilité II).

1 Le cadre réglementaire : de Bâle III et Solvabilité II au règlement DORA

La quantification du capital requis au titre de la non-conformité au règlement DORA s'inscrit dans un écosystème prudentiel dont il importe de retracer l'architecture. Le risque que nous cherchons à modéliser — le risque opérationnel d'origine technologique, et le risque de manquement aux exigences de résilience numérique — se situe à l'intersection de trois cadres réglementaires construits successivement, selon des philosophies distinctes mais convergentes : le dispositif bancaire de Bâle, la directive Solvabilité II propre à l'assurance, et le règlement transsectoriel DORA. Cette section retrace cette construction, identifie le *pont quantitatif* que DORA permet d'établir entre exigence de capital et résilience opérationnelle, et formalise la non-conformité comme une variable latente exploitable dans l'évaluation interne des risques.

1.1 L'écosystème réglementaire : Bâle III, Solvabilité II, DORA

Le risque opérationnel : une définition partagée, des traitements divergents. Le risque opérationnel a connu, au cours des deux dernières décennies, une mutation profonde marquée par une recherche de convergence entre les secteurs bancaire et assurantiel. Défini par le Comité de Bâle puis repris par la directive Solvabilité II, il désigne le risque de perte résultant de l'inadaptation ou de la défaillance de procédures internes, de personnels et de systèmes, ou d'événements extérieurs. Cette définition inclut le risque juridique mais exclut les risques stratégiques et de réputation.

Si la définition est partagée, les modes de quantification ont divergé. Le secteur bancaire a progressivement abandonné les modèles internes au profit d'une approche standardisée, tandis que l'assurance a conservé une liberté méthodologique. Cette asymétrie, que nous détaillons ci-après, éclaire le choix méthodologique du présent mémoire : c'est précisément parce que Solvabilité II laisse subsister un espace de modélisation interne que la quantification du risque cyber sous forme d'une distribution de pertes y conserve toute sa pertinence.

Bâle III/IV : du modèle interne AMA à la standardisation SMA. Sous le régime de Bâle II, les établissements bancaires d'envergure internationale étaient encouragés à développer des modèles internes complexes, regroupés sous l'appellation d'approche de mesure avancée (*Advanced Measurement Approaches*, AMA). Ces modèles reposaient principalement sur l'approche par distribution des pertes (*Loss Distribution Approach*, LDA) — celle-là même que nous mobilisons dans ce mémoire — ou sur des approches par scénarios. S'ils offraient une grande flexibilité théorique, ils ont engendré une variabilité excessive et difficilement justifiable des actifs pondérés par le risque d'un établissement à l'autre, érodant la confiance des superviseurs dans les ratios de solvabilité déclarés.

La finalisation des réformes de Bâle III, communément désignée sous le nom de Bâle IV, a acté le retrait des modèles internes AMA pour le calcul du capital de Pilier 1, à compter du 1^{er} janvier 2022, au profit d'une méthode unique et comparable : l'approche d'évaluation standardisée (*Standardised Measurement Approach*, SMA). L'exigence de capital pour risque opérationnel (*ORC*) s'exprime alors comme le produit d'une composante de volume d'activité, le *Business Indicator Component* (*BIC*), et d'un facteur d'échelle fondé sur l'historique des pertes internes, l'*Internal Loss Multiplier* (*ILM*) :

$$ORC = BIC \times ILM, \quad RWA_{Op} = 12,5 \times ORC. \quad (1)$$

Le *Business Indicator* synthétise la taille de l'établissement à partir de trois composantes comptables (intérêts et dividendes, services, activité financière), auxquelles sont appliqués des

coefficients marginaux croissants par tranches. Le profil de risque propre est réintroduit par l'*ILM*, qui compare le *BIC* à la composante de pertes historiques *LC*, égale à quinze fois la moyenne des pertes opérationnelles annuelles significatives des dix dernières années. Lorsque la sinistralité historique est faible relativement à l'activité ($LC < BIC$), l'*ILM* est inférieur à l'unité et réduit l'exigence ; lorsqu'elle est élevée, il agit comme une pénalité en fonds propres.

Enseignement pour notre démarche. Le retrait de l'AMA n'invalide nullement l'approche LDA en tant qu'outil de modélisation : il en restreint l'usage *pour le calcul réglementaire de Pilier 1 dans le secteur bancaire*. La logique de la composante *LC* — faire dépendre le capital de l'historique réel des pertes — demeure parfaitement pertinente, et c'est cette logique, transposée à l'assurance et enrichie de la théorie des valeurs extrêmes, que nous mettons en oeuvre.

Solvabilité II : l'asymétrie réglementaire et le maintien du choix méthodologique.

Contrairement au secteur bancaire, le secteur de l'assurance conserve sous Solvabilité II une liberté de choix pour la quantification du risque opérationnel : formule standard, paramètres propres à l'entreprise (USP), ou modèle interne, partiel ou global, approuvé par l'autorité de contrôle. Dans la formule standard, l'exigence pour risque opérationnel (SCR_{Op}) s'ajoute de manière additive au capital de solvabilité requis de base (*BSCR*), ajusté de la capacité d'absorption des pertes :

$$SCR = BSCR + Adj + SCR_{Op}, \quad SCR_{Op} = \min(0,3 \times BSCR, Op) + 0,25 \times Exp_{ul}, \quad (2)$$

où $Op = \max(Op_{premiums}, Op_{provisions})$ est calculé à partir de coefficients forfaitaires appliqués aux primes et provisions, vie et non-vie. Nous en donnons ici la forme simplifiée ; la formule complète de l'Article 204 du règlement délégué 2015/35 comporte en outre des termes de croissance, sous la forme $\max(0; 0,04 \times \Delta)$, pénalisant les hausses de primes supérieures à 20 % d'un exercice à l'autre.

Cette approche présente une faiblesse conceptuelle majeure pour l'actuaire. En se fondant exclusivement sur des indicateurs de volume, elle pose l'hypothèse implicite que deux assureurs gérant le même volume de primes présentent une exposition identique au risque opérationnel — indépendamment de la qualité de leur infrastructure informatique, du degré d'automatisation de leurs processus, ou de leur dépendance à des prestataires d'externalisation critiques. Or c'est précisément cette dépendance technologique que DORA vient encadrer, et dont nous cherchons à mesurer l'effet sur le capital.

Pilier 1 et Pilier 2. Le SCR_{Op} relève du Pilier 1, quantitatif et forfaitaire. Mais Solvabilité II comporte un second pilier, l'évaluation interne des risques et de la solvabilité (*Own Risk and Solvency Assessment*, ORSA), qui impose à l'assureur une évaluation prospective de l'adéquation entre son profil de risque réel et ses besoins de solvabilité. C'est dans le cadre de l'ORSA — et non du forfait de Pilier 1, plafonné à 30 % du *BSCR* — que notre modélisation trouve sa place naturelle : l'ORSA autorise, et même encourage, le recours à des scénarios de stress stochastiques que la formule standard ne sait pas produire.

DORA : un cadre transversal de résilience opérationnelle numérique. Face à l'insuffisance des exigences de capital de Pilier 1 pour garantir la continuité des opérations en cas de crise informatique d'envergure, l'Union européenne a introduit le règlement sur la résilience opérationnelle numérique du secteur financier (*Digital Operational Resilience Act*, règlement UE 2022/2554). Entré en application le 17 janvier 2025, DORA agit comme une *lex specialis* par rapport à la directive NIS 2 et harmonise les obligations de gestion des risques liés aux technologies de l'information et de la communication (TIC) à travers vingt-et-une catégories

d'entités financières : banques, entreprises d'assurance et de réassurance, intermédiaires, ainsi que les prestataires tiers critiques de services TIC.

Le postulat de DORA est que la résilience opérationnelle ne saurait se réduire à l'allocation de tampons de fonds propres. Le règlement impose un cadre proactif, articulé autour de la capacité à *résister, absorber, récupérer et s'adapter* face aux perturbations informatiques majeures.

Position dans l'écosystème. La progression Bâle → Solvabilité II → DORA traduit un déplacement du centre de gravité prudentiel : de la *couverture financière* du risque (détenir assez de capital) vers la *continuité opérationnelle* (rester capable d'opérer). DORA ne remplace pas les exigences de capital ; il en révèle l'angle mort, à savoir la dynamique propre des défaillances technologiques, que ni le *SCR_{Op}* forfaitaire ni l'ORSA qualitatif ne savaient capturer.

1.2 Ce que DORA exige concrètement : les cinq piliers ICT

Le règlement DORA structure ses exigences autour de cinq piliers, qui couvrent l'ensemble du cycle de vie du risque informatique, de sa prévention à sa résolution. Chacun d'entre eux introduit une granularité que ni la formule standard, ni l'ORSA qualitatif traditionnel ne parvenaient à atteindre.

Pilier 1 — Gouvernance et gestion du risque TIC. DORA impose l'existence d'un cadre de gouvernance formalisé, porté au plus haut niveau de l'organe de direction, incluant une cartographie des actifs informationnels et des dépendances critiques, une politique de sécurité documentée, et un dispositif de contrôle interne capable d'identifier et de corriger les faiblesses technologiques de façon continue — non plus seulement lors d'audits ponctuels.

Pilier 2 — Gestion, classification et notification des incidents. Les entités doivent disposer d'un processus structuré de détection, de qualification et de suivi des incidents liés aux TIC. Les incidents jugés majeurs doivent être notifiés selon un calendrier resserré : une alerte sous quatre heures après classification (et au plus tard vingt-quatre heures après détection), un rapport intermédiaire sous soixante-douze heures, puis un rapport final sous un mois.

Pilier 3 — Tests de résilience opérationnelle numérique. Il ne suffit plus de documenter des procédures : elles doivent être éprouvées. Les entités identifiées comme significatives sont soumises à des tests de pénétration guidés par la menace (*Threat-Led Penetration Testing*, TLPT), à mener au moins tous les trois ans, en conditions proches du réel.

Pilier 4 — Gestion du risque lié aux prestataires tiers ICT. Ce pilier est central dans un environnement marqué par l'externalisation et le recours au cloud. Il impose une cartographie exhaustive des contrats critiques via un Registre d'Informations harmonisé, une gouvernance contractuelle renforcée (clauses impératives de l'article 30), et une surveillance directe des prestataires tiers critiques par les autorités européennes, jusqu'au rang 3 de la chaîne de sous-traitance.

Pilier 5 — Partage d'informations sur les cybermenaces. DORA encourage les entités à partager, de façon volontaire et encadrée, des informations sur les menaces observées, dans une logique de résilience collective. Ce pilier reste moins directement mobilisable dans le calibrage actuariel du présent mémoire, mais il rappelle que DORA porte aussi une dimension systémique de la résilience numérique, au-delà de la seule entité individuelle.

Dimension	Solvabilité II (ORSA)	DORA
Taxonomie du risque	Traitement agrégé dans le module SCR_{Op}	Taxonomie granulaire des actifs TIC et indicateurs de risque distincts
Reporting des incidents	Notification interne, dialogue prudentiel non standardisé	Notification obligatoire à l'ACPR : alerte sous 4 h après classification comme majeur (et au plus tard 24 h après détection), rapport intermédiaire 72 h, rapport final 1 mois
Tests de résilience	Stress tests orientés adéquation du capital	Tests de continuité et TLPT (pénétration guidée par la menace) au moins tous les 3 ans pour les entités identifiées comme significatives
Cartographie des dépendances	Analyse générale des accords d'externalisation	Registre d'Informations harmonisé, chaînes de sous-traitance jusqu'au rang 3
Encadrement des tiers	Lignes directrices EIOPA non contraignantes	Clauses contractuelles impératives (Art. 30), surveillance directe des prestataires critiques

Le *Registre d'Informations* (ROI) mérite une attention particulière. En imposant le recensement exhaustif et structuré des contrats TIC critiques et de leurs chaînes de sous-traitance, DORA produit, pour la première fois, une donnée exploitable pour modéliser quantitativement le risque de concentration technologique — donnée qui faisait précisément défaut à l'ORSA traditionnel.

1.3 1.3 — ORSA ↔ DORA : recouvrement et divergences

Les limites structurelles de l'ORSA traditionnel. L'ORSA traditionnel s'appuyait principalement sur des cartographies de risques fondées sur l'avis d'experts. Trois limites en découlaient.

Un cloisonnement méthodologique. Les risques TIC étaient traités séparément des risques financiers et assurantiels, sans intégration des corrélations réelles. L'interaction entre une défaillance de l'outil de tarification (risque opérationnel) et la sous-évaluation systématique des primes qui en résulte (risque de souscription) était rarement modélisée de manière dynamique.

L'absence de données de sinistralité qualifiées. Les assureurs ne disposaient pas de base standardisée permettant d'alimenter les modèles de sévérité pour les événements cyber de faible fréquence et de forte gravité. L'étalonnage des distributions à queue lourde restait hautement incertain et sujet à une forte volatilité de modèle — difficulté que notre travail aborde frontalement en mobilisant plusieurs sources indépendantes (PRC, SAS OpRisk Global, Hackmageddon) et en assumant explicitement l'incertitude résiduelle.

La non-prise en compte des interdépendances de la chaîne de valeur. Les politiques d'externalisation sous Solvabilité II se limitaient à des audits documentaires ponctuels. L'effet de cascade d'une panne systémique chez un fournisseur d'infrastructure cloud partagé par plusieurs

acteurs du marché n'était pas intégré aux tests de résistance.

Zone de recouvrement. ORSA et DORA partagent un même objet — le risque opérationnel d'origine technologique — et une même exigence d'évaluation prospective. Trois domaines se recouvrent explicitement : le risque opérationnel informatique, traité de façon agrégée par l'ORSA et granulaire par DORA ; les scénarios de stress cyber, que l'ORSA peut désormais alimenter des données et tests imposés par DORA ; et la continuité d'activité, exigence commune mais de portée différente. C'est dans ce recouvrement que se loge la contribution du présent mémoire : utiliser les artefacts produits par DORA (taxonomie, registre, tests) pour *quantifier* dans l'ORSA ce que celui-ci ne savait jusqu'alors que décrire.

Zones de divergence fondamentale. La finalité de l'évaluation. Solvabilité II s'inscrit dans une logique de continuité *financière* : prouver que l'assureur détient assez de fonds propres pour absorber les pertes d'une défaillance majeure. DORA s'inscrit dans une logique de continuité *opérationnelle* : garantir que, même sans capital excédentaire, l'infrastructure maintient les services critiques et se restaure rapidement. Les deux cadres sont complémentaires, non substituables.

Le principe de proportionnalité. Solvabilité II applique une proportionnalité fondée sur la taille globale (primes, provisions). DORA décline la sienne selon la complexité des systèmes d'information, la dépendance au cloud tiers, et la criticité dans l'écosystème de distribution. Une captive de réassurance ou une petite mutuelle peut ainsi bénéficier d'un régime DORA simplifié sans pour autant échapper aux exigences de capital.

La temporalité de la supervision. Solvabilité II fonctionne sur des cycles trimestriels et annuels (QRT, SFCR, RSR). DORA impose une réactivité quasi temps réel, notamment par la notification des incidents majeurs sous quatre heures, contraignant l'assureur à des processus permanents de veille connectés aux canaux du régulateur.

1.4 1.4 — La probabilité de défaut de conformité comme variable latente

Les sections précédentes ont établi que DORA fournit des artefacts nouveaux — registre des tiers, notifications d'incidents, résultats de tests TLPT — mais aucun de ces artefacts ne constitue, pris isolément, une mesure directe du niveau de conformité d'une entité. Une entité peut être en avance sur la gouvernance TIC mais en retard sur les tests de résilience ; une autre peut être conforme sur le papier mais fortement exposée via un prestataire tiers critique mal maîtrisé. La conformité DORA n'est donc pas une variable observable au sens strict : c'est une caractéristique multidimensionnelle, partiellement cachée, qu'il convient de formaliser par une **variable latente à structure factorielle**, sur le modèle du cadre de Merton-Vasicek utilisé pour la modélisation des défauts corrélés en risque de crédit — et qui constitue également le fondement de l'approche IRB de Bâle pour la corrélation des probabilités de défaut.

Structure à facteur unique. Soit Z_i la variable latente continue de fragilité réglementaire et opérationnelle de l'entité i , agréant de façon non observable ses faiblesses sur les cinq piliers DORA. Suivant la structure de Vasicek, Z_i se décompose en un facteur systémique θ , commun à l'ensemble du marché, et un facteur idiosyncratique ε_i , propre à l'entité :

$$Z_i = \sqrt{\rho_i} \theta + \sqrt{1 - \rho_i} \varepsilon_i, \quad \theta \sim \mathcal{N}(0, 1), \quad \varepsilon_i \sim \mathcal{N}(0, 1), \quad (3)$$

avec θ et ε_i indépendants, et $\rho_i \in [0, 1]$ le coefficient de corrélation de l'entité i à l'environnement cyber systémique. Un ρ_i élevé caractérise une entité dont la posture de conformité se dégrade

fortement lorsque l'environnement sectoriel se détériore (forte dépendance aux tiers, mutualisation d'infrastructures critiques), tandis qu'un ρ_i faible caractérise une entité dont la gouvernance reste robuste indépendamment du contexte général.

Seuil de défaut de conformité. Comme dans le modèle de Merton, le défaut de conformité de l'entité i est déclenché lorsque sa variable latente franchit un seuil K_i , calibré de sorte à retrouver le taux de non-conformité moyen observé sur le marché. La probabilité de défaut de conformité conditionnelle à l'état de l'environnement systémique θ s'écrit alors :

$$PCD_i(\theta) = \mathbb{P}(Z_i \leq K_i | \theta) = \Phi\left(\frac{K_i - \sqrt{\rho_i} \theta}{\sqrt{1 - \rho_i}}\right), \quad (4)$$

où Φ désigne la fonction de répartition de la loi normale centrée réduite. Le seuil K_i est obtenu par inversion de la probabilité de défaut inconditionnelle $P\bar{C}D_i$ (calibrée sur les taux de non-conformité observés en 2025) : $K_i = \Phi^{-1}(P\bar{C}D_i)$.

Cette écriture retrouve les propriétés attendues : lorsque l'environnement systémique se dégrade ($\theta \rightarrow -\infty$, interprété comme un choc cyber sectoriel négatif), $PCD_i(\theta) \rightarrow 1$ pour toute entité présentant $\rho_i > 0$; à l'inverse, une entité affichant $\rho_i \rightarrow 0$ conserve un $PCD_i(\theta)$ proche de son niveau inconditionnel $P\bar{C}D_i$, quasiment insensible au contexte de marché. Le paramètre ρ_i joue ainsi le rôle d'un coefficient de dépendance à la contagion systémique, au sens strict du modèle à facteur unique de Vasicek.

Interpolation entre scénarios-types. Cette formalisation permet de dépasser le choix discret d'un scénario de marché $S_x \in \{S_0, S_1, S_2\}$ (conforme, partiellement conforme, non conforme) au profit d'une lecture continue : S_0 correspond au cas limite $PCD_i(\theta) \rightarrow 0$, S_2 au cas limite $PCD_i(\theta) \rightarrow 1$, et S_1 à une valeur intermédiaire calibrée sur les profils de conformité partielle observés en 2025. Le multiplicateur de fréquence appliqué à un vecteur d'attaque v pour l'entité i s'écrit alors comme une interpolation linéaire entre le régime conforme et le régime de non-conformité totale sourcé empiriquement :

$$m_v(PCD_i(\theta)) = 1 + PCD_i(\theta) \times (\bar{m}_v^{S_2} - 1), \quad (5)$$

où $\bar{m}_v^{S_2}$ est le centre de l'intervalle de multiplicateur sourcé en scénario de non-conformité totale pour le vecteur v (cf. Partie 4). Cette écriture ne requiert aucune calibration supplémentaire au-delà de ρ_i et $P\bar{C}D_i$: elle réutilise directement les multiplicateurs déjà sourcés par vecteur d'attaque, en substituant au choix manuel d'un scénario de marché la probabilité propre à chaque profil d'entité, conditionnellement à l'état de l'environnement cyber systémique θ .

Trois avantages méthodologiques découlent de ce choix de structure. Premièrement, le cadre de Vasicek est un standard éprouvé de la modélisation actuarielle et prudentielle des risques corrélés, ce qui confère au $PCD_i(\theta)$ une assise théorique plus solide qu'une fonction de lien ad hoc. Deuxièmement, le paramètre ρ_i offre une lecture économique directe et interprétable de la sensibilité de chaque entité à la contagion systémique — une lecture qui prépare naturellement la discussion de la contagion interne et externe menée en 1.5. Troisièmement, la structure à facteur unique est immédiatement compatible avec l'architecture de dépendance retenue en Partie 3 (copule de Gumbel et modèle à facteur commun), puisqu'elle repose sur le même principe de décomposition entre un choc commun θ et des chocs idiosyncratiques ε_i .

Cette variable latente n'est pas un simple artifice de modélisation : elle constitue le point de jonction technique entre le cadre réglementaire décrit ci-dessus et le moteur actuariel développé dans la suite du mémoire. C'est elle qui, dans le chapitre consacré à la fréquence, vient moduler l'intensité des sinistres simulés et piloter la probabilité d'occurrence d'une sanction réglementaire.

1.5 1.5 — Contagion interne et contagion externe via tiers ICT

L'introduction d'une variable latente de conformité invite à distinguer deux canaux de propagation du risque, que le cadre DORA rend précisément observables : une contagion **interne** et une contagion **externe**.

Contagion interne. Une faiblesse de gouvernance TIC, un retard dans le déploiement des correctifs de sécurité, ou une insuffisance de sensibilisation du personnel ne restent pas cantonnés à un seul type d'incident. Ils dégradent simultanément plusieurs vecteurs d'attaque : un défaut de formation accroît la vulnérabilité au phishing, mais fragilise également la détection précoce d'autres intrusions. Cette dimension justifie que la fréquence des incidents ne soit pas traitée comme la simple somme de processus indépendants, mais comme le produit d'un facteur commun de maîtrise opérationnelle interne.

Contagion externe. Le pilier consacré à la gestion du risque lié aux prestataires tiers ICT rend cette seconde dimension explicite. Une entité peut afficher une gouvernance interne robuste tout en restant exposée à la défaillance d'un prestataire critique — hébergeur cloud, éditeur logiciel, sous-traitant de paiement — partagé par plusieurs acteurs du marché. Le Registre d'Informations et la traçabilité des chaînes de sous-traitance jusqu'au rang 3, imposés par DORA, rendent pour la première fois cette dépendance cartographiable, alors qu'elle échappait largement aux audits documentaires ponctuels de Solvabilité II.

Cette distinction entre contagion interne et externe n'est pas seulement conceptuelle : elle structure directement l'architecture de modélisation retenue dans ce mémoire. La contagion interne motive le recours à une structure de dépendance de type facteur commun entre les briques de perte liées à la maîtrise opérationnelle de l'entité elle-même. La contagion externe justifie l'introduction d'une brique de risque dédiée au prestataire, distincte de la brique de remédiation, et calibrée sur un scénario d'occurrence propre — car le risque tiers ne se comporte pas comme un sinistre interne ordinaire, mais comme un choc importé, potentiellement corrélé entre plusieurs entités du marché exposées au même fournisseur.

Positionnement du mémoire

Au terme de ce panorama, la contribution visée se précise. Le forfait de Pilier 1 (SCR_{Op} , plafonné à 30 % du $BSCR$) est, par construction, incapable de refléter le risque de cyber-catastrophe systémique : il ignore la qualité de l'infrastructure, la dépendance aux tiers, et la dynamique propre des défaillances. Nous proposons donc, dans la logique du Pilier 2, un modèle de stress stochastique fondé sur la théorie des valeurs extrêmes, étalonné sur des données de sinistralité sectorielles et structuré par la variable latente de conformité introduite ci-dessus. L'objectif n'est pas de produire un chiffre unique de capital, mais une *distribution* de l'exigence, assortie de ses intervalles d'incertitude — car le SCR cyber n'est pas un nombre, mais une distribution large.

Cadre mathématique de la modélisation des risques extrêmes

La quantification du risque cyber, caractérisée par une asymétrie prononcée et la présence de sinistres d'une sévérité exceptionnelle, nécessite un cadre probabiliste robuste. Les lois de probabilité traditionnelles (Lognormale, Gamma, Weibull), souvent utilisées en assurance non-vie pour modéliser le corps de la distribution (la fréquence des sinistres d'attrition), échouent à capturer l'épaisseur des queues de distribution typiques des méga-fuites de données ou des paralysies systémiques. Cette section détaille les fondements théoriques de la Théorie des Valeurs Extrêmes (EVT) sous-jacents au modèle de distribution de pertes agrégées (LDA) implémenté, ainsi que la modélisation de la dépendance.

1.6 Justification de l'EVT et Théorème de Fisher-Tippett-Gnedenko (GEV)

Là où le Théorème Central Limite s'intéresse au comportement asymptotique des sommes de variables aléatoires, la Théorie des Valeurs Extrêmes (EVT) étudie le comportement asymptotique de leurs maxima.

Soit une séquence $(X_1, X_2, \dots, X_n)$ de variables aléatoires indépendantes et identiquement distribuées (i.i.d.) de fonction de répartition F , représentant la sévérité des cyberattaques. L'approche initiale de l'EVT, dite des *Block Maxima*, s'intéresse au maximum sur des blocs de taille n (par exemple, le sinistre cyber maximal annuel) :

$$M_n = \max(X_1, X_2, \dots, X_n) \quad (6)$$

Théorème de Fisher-Tippett-Gnedenko (1928, 1943). S'il existe des suites de constantes de normalisation $a_n > 0$ et $b_n \in \mathbb{R}$, et une distribution non dégénérée H telles que :

$$\lim_{n \rightarrow \infty} \mathbb{P} \left(\frac{M_n - b_n}{a_n} \leq x \right) = \lim_{n \rightarrow \infty} F^n(a_n x + b_n) = H(x) \quad (7)$$

Alors, H appartient nécessairement à la famille des distributions des extrêmes généralisées (GEV - *Generalized Extreme Value*), dont la fonction de répartition s'écrit :

$$H_\xi(x) = \begin{cases} \exp \left(- (1 + \xi x)^{-1/\xi} \right) & \text{si } \xi \neq 0 \\ \exp(-\exp(-x)) & \text{si } \xi = 0 \end{cases} \quad (8)$$

définie sur l'ensemble $\{x : 1 + \xi x > 0\}$. Le paramètre ξ (indice de queue) définit trois grands domaines d'attraction :

- $\xi > 0$ (**Loi de Fréchet**) : La distribution présente une queue lourde à décroissance polynomiale. C'est le régime critique qui nous intéresse pour les sinistres cyber majeurs.
- $\xi = 0$ (**Loi de Gumbel**) : La distribution présente une queue légère à décroissance exponentielle (domaine d'attraction des lois Normale, Lognormale, Gamma).
- $\xi < 0$ (**Loi de Weibull**) : La distribution a un support fini supérieur (queue courte).

On peut énoncer formellement ce résultat fondateur, qui joue pour les maxima le rôle du théorème central limite pour les sommes.

Théorème 1.1 (Fisher-Tippett-Gnedenko). Soit $(X_i)_{i \geq 1}$ i.i.d. de fonction de répartition F et $M_n = \max(X_1, \dots, X_n)$. S'il existe des suites $a_n > 0$, $b_n \in \mathbb{R}$ et une loi non dégénérée H telles que $(M_n - b_n)/a_n \xrightarrow{d} H$, alors H est, à un changement d'échelle et de position près, une loi GEV H_ξ . Le signe de ξ détermine le domaine d'attraction : Fréchet ($\xi > 0$, queue lourde), Gumbel ($\xi = 0$) ou Weibull ($\xi < 0$, support borné).

Éléments. La loi limite H est nécessairement *max-stable* : pour tout n , $H^n(a_n x + b_n) = H(x)$, car M_{nk} est le maximum de k blocs de taille n . L'équation fonctionnelle de max-stabilité, résolue via la théorie des fonctions à variation régulière, n'admet (à normalisation près) que la famille à un paramètre H_ξ . La correspondance queue de $F \leftrightarrow$ signe de ξ s'obtient en caractérisant les F dont la fonction de survie est à variation régulière d'indice $-1/\xi$ (cas Fréchet). Le détail figure en Annexe A.1. ■

1.7 Le passage au Peaks-Over-Threshold (POT) et la GPD

Bien que rigoureuse, l'approche *Block Maxima* (GEV) présente une limite majeure en actuariat pratique : elle induit un immense gaspillage d'information. En ne retenant que le maximum

de chaque bloc, elle occulte potentiellement le deuxième plus grand sinistre d'une année extrême, qui pourrait pourtant être supérieur au maximum d'une année calme. Dans le contexte du risque cyber, où les données historiques fiables et quantifiées sont particulièrement rares, un tel gaspillage statistique fragiliserait la modélisation.

Pour contourner ce problème, ce mémoire privilégie l'approche *Peaks-Over-Threshold* (POT). Au lieu de ne garder que les maxima, cette méthode exploite **toutes** les observations excédant un seuil élevé u . On s'intéresse alors à la distribution des excès $Y = X - u$.

La fonction de répartition conditionnelle des excès est donnée par :

$$F_u(y) = \mathbb{P}(X - u \leq y \mid X > u) = \frac{F(u + y) - F(u)}{1 - F(u)} \quad (9)$$

Théorème de Balkema-de Haan-Pickands (1974). Ce théorème établit le pont mathématique entre la GEV et l'approche POT. Pour une large classe de distributions sous-jacentes F (celles appartenant au domaine d'attraction d'une loi GEV H_ξ), il existe une fonction mesurable positive $\sigma(u)$ telle que, lorsque le seuil u tend vers la limite supérieure du support de F (x_F), la distribution des excès converge asymptotiquement vers une distribution de Pareto Généralisée (GPD) :

$$\lim_{u \rightarrow x_F} \sup_{0 \leq y < x_F - u} |F_u(y) - G_{\xi, \sigma(u)}(y)| = 0 \quad (10)$$

Où la fonction de répartition de la GPD s'écrit :

$$G_{\xi, \sigma}(y) = \begin{cases} 1 - \left(1 + \frac{\xi y}{\sigma}\right)^{-1/\xi} & \text{si } \xi \neq 0 \\ 1 - \exp\left(-\frac{y}{\sigma}\right) & \text{si } \xi = 0 \end{cases} \quad (11)$$

avec $y \geq 0$ si $\xi \geq 0$, et $0 \leq y \leq -\sigma/\xi$ si $\xi < 0$. Le paramètre de forme ξ de la GPD est strictement le même que celui de la loi GEV correspondante. Dans le contexte du risque cyber, un indice de queue $\xi > 0$ traduit une distribution à queue lourde de type Fréchet, impliquant des moments potentiellement infinis (l'espérance est infinie si $\xi \geq 1$, la variance si $\xi \geq 0.5$). Le résultat s'énonce formellement ainsi.

Théorème 1.2 (Pickands–Balkema–de Haan). Soit F dans le domaine d'attraction d'une GEV H_ξ (Théorème 1.1). Alors il existe une fonction $\sigma(u) > 0$ telle que la loi des excès converge uniformément vers une GPD lorsque le seuil approche la borne supérieure x_F du support :

$$\lim_{u \rightarrow x_F} \sup_{0 \leq y < x_F - u} |F_u(y) - G_{\xi, \sigma(u)}(y)| = 0, \quad (12)$$

où $F_u(y) = \mathbb{P}(X - u \leq y \mid X > u)$ et $G_{\xi, \sigma}$ est la fonction de répartition de la GPD. L'indice de queue ξ est identique à celui de la GEV limite.

Esquisse. L'appartenance de F au domaine d'attraction de H_ξ équivaut à une condition de variation régulière sur la fonction de survie $\bar{F}$. On montre que $\bar{F}(u + y a(u)) / \bar{F}(u) \rightarrow (1 + \xi y)^{-1/\xi}$ quand $u \rightarrow x_F$, pour une fonction d'échelle $a(u)$ adéquate ; ce membre de droite est exactement la fonction de survie GPD. La convergence uniforme découle de la monotonie des fonctions de répartition (théorème de Pólya). Détail et lien avec le Théorème 1.1 en Annexe A.2. ■

1.8 Estimation des paramètres : Maximum de Vraisemblance vs Estimateur de Hill

L'estimation de l'indice de queue ξ est un enjeu critique, car une infime variation de ce paramètre modifie massivement le Capital de Solvabilité Requis (SCR). Deux approches principales s'affrontent dans la littérature.

L'estimateur de Hill. Pour $\xi > 0$, l'estimateur non paramétrique de Hill (1975) repose sur les statistiques d'ordre. Soit $X_{(1)} \geq X_{(2)} \geq \dots \geq X_{(n)}$ l'échantillon ordonné de manière décroissante. L'estimateur de Hill fondé sur les k plus grandes observations est défini par :

$$\hat{\xi}_{Hill}(k) = \frac{1}{k} \sum_{i=1}^k \ln X_{(i)} - \ln X_{(k+1)} \quad (13)$$

Bien que cet estimateur soit asymptotiquement convergent et sans biais sous la stricte condition que la distribution sous-jacente appartienne exactement au domaine d'attraction de Fréchet, il présente en pratique un biais d'échantillon fini majeur. En effet, si la composante à variation lente de la queue de distribution ne converge pas assez vite, $\hat{\xi}_{Hill}$ devient instable.

Le Maximum de Vraisemblance (MLE). Pour pallier le biais de l'estimateur de Hill hors du régime asymptotique strict, ce mémoire privilégie l'estimation par Maximum de Vraisemblance (MLE) sur les excès de la GPD. La log-vraisemblance pour un échantillon de N_u excès y_i au-delà du seuil u s'écrit (pour $\xi \neq 0$) :

$$\ell(\xi, \sigma) = -N_u \ln(\sigma) - \left(1 + \frac{1}{\xi}\right) \sum_{i=1}^{N_u} \ln \left(1 + \frac{\xi y_i}{\sigma}\right) \quad (14)$$

La maximisation numérique de cette fonction fournit des estimateurs $(\hat{\xi}_{MLE}, \hat{\sigma}_{MLE})$ qui, bien que nécessitant des méthodes d'optimisation (telles que l'algorithme de Nelder-Mead utilisé dans nos scripts Python), offrent une robustesse supérieure face à la variance d'échantillonnage des bases de sinistres cyber comme OpRisk ou PRC.

Loi asymptotique et information de Fisher. La qualité d'un intervalle de confiance sur ξ conditionne toute l'interprétation du SCR. Nous en donnons ici le fondement théorique, qui servira de contrôle indépendant du bootstrap employé en partie 5.

Proposition 1.3 (Normalité asymptotique de l'EMV de la GPD). *Pour $\xi > -\frac{1}{2}$, l'estimateur du maximum de vraisemblance $(\hat{\xi}, \hat{\sigma})$ de la GPD est consistant et asymptotiquement normal :*

$$\sqrt{N_u} \begin{pmatrix} \hat{\xi} - \xi \\ \hat{\sigma} - \sigma \end{pmatrix} \xrightarrow{d} \mathcal{N} \left(\mathbf{0}, (1 + \xi) \begin{pmatrix} 1 + \xi & -\sigma \\ -\sigma & 2\sigma^2 \end{pmatrix} \right). \quad (15)$$

En particulier, la variance asymptotique de l'indice de queue est $\text{Var}(\hat{\xi}) \simeq (1 + \xi)^2 / N_u$.

Esquisse. La matrice de covariance limite est l'inverse de l'information de Fisher $\mathcal{I}(\xi, \sigma)$, obtenue en prenant l'espérance de l'opposé de la hessienne de ℓ . Le détail du calcul de $\mathcal{I}$ (dérivées secondes de (14) et intégration contre la densité GPD, valide pour $\xi > -\frac{1}{2}$ où l'information est finie) est reporté en Annexe A.5. Le résultat classique remonte à Smith (1987). ■

Appliquée à la calibration OpRisk ($\hat{\xi} = 0,595$, $N_u = 91$ excès), la Proposition 1.3 donne un écart-type asymptotique $\widehat{\text{sd}}(\hat{\xi}) = (1 + \hat{\xi}) / \sqrt{N_u} = 0,167$, soit un intervalle de confiance à 90 % par la delta-méthode de $[0,320; 0,870]$. Cet intervalle recoupe presque exactement l'intervalle bootstrap $[0,304; 0,831]$ obtenu indépendamment (§5.5) : la concordance des deux approches — l'une paramétrique et asymptotique, l'autre par rééchantillonnage — renforce la fiabilité de l'incertitude reportée sur ξ .

Proposition 1.4 (Loi asymptotique de l'estimateur de Hill). *Si F est à variation régulière d'indice $-1/\xi$ (domaine de Fréchet), alors pour une suite $k = k(n) \rightarrow \infty$ avec $k/n \rightarrow 0$,*

$$\sqrt{k} (\hat{\xi}_{Hill}(k) - \xi) \xrightarrow{d} \mathcal{N}(0, \xi^2). \quad (16)$$

L'écart-type $\xi/\sqrt{k}$ décroît en $\sqrt{k}$: d'où l'arbitrage biais-variance qui gouverne le choix de k dans le *Hill plot*, et qui explique l'instabilité signalée plus haut lorsque k est pris trop grand (contamination par le corps de la loi) ou trop petit (variance explosive). La preuve, fondée sur la représentation de Rényi des espacements exponentiels, est esquissée en Annexe A.6.

Quantile extrême et capital : formules fermées. Le passage des paramètres (ξ, σ) au capital réglementaire est explicite. Notons $\zeta_u = \mathbb{P}(X > u)$ la probabilité de dépassement du seuil.

Proposition 1.5 (VaR et Expected Shortfall d'une queue GPD). *Sous le modèle POT, pour α tel que $\text{VaR}_\alpha > u$ et $\xi \in (0, 1)$:*

$$\text{VaR}_\alpha(X) = u + \frac{\sigma}{\xi} \left[\left(\frac{1-\alpha}{\zeta_u} \right)^{-\xi} - 1 \right], \quad (17)$$

$$\text{TVaR}_\alpha(X) = \mathbb{E}[X \mid X > \text{VaR}_\alpha] = \frac{\text{VaR}_\alpha(X)}{1-\xi} + \frac{\sigma - \xi u}{1-\xi}. \quad (18)$$

Lorsque $\xi \geq 1$, l'espérance $\mathbb{E}[X]$ est infinie et TVaR_α n'est pas définie.

Démonstration. Pour $x > u$, la propriété POT donne $\mathbb{P}(X > x) = \zeta_u (1 + \xi(x-u)/\sigma)^{-1/\xi}$. En posant ce membre égal à $1 - \alpha$ et en inversant, on obtient (17). Pour (18), la stabilité de la GPD par franchissement de seuil implique que l'excès au-delà de VaR_α suit encore une GPD de paramètre ξ et d'échelle $\sigma + \xi(\text{VaR}_\alpha - u)$, d'espérance $(\sigma + \xi(\text{VaR}_\alpha - u))/(1 - \xi)$ pour $\xi < 1$; en ajoutant VaR_α et en réarrangeant, on retrouve (18). La divergence pour $\xi \geq 1$ découle de $\mathbb{E}[X] = \int_u^\infty \mathbb{P}(X > x) dx = +\infty$ dès que $1/\xi \leq 1$. Détail en Annexe A.7. ■

Numériquement, la calibration OpRisk ($u = 20,03$, $\sigma = 57,97$, $\xi = 0,595$, $\zeta_u = 0,151$) donne par (17) une VaR mono-perte $\text{VaR}_{99,5\%} = 663,0$ M€ et par (18) $\text{TVaR}_{99,5\%} = 1\,752,4$ M€. La Proposition 1.5 éclaire surtout le contraste entre sources : la calibration PRC affiche $\hat{\xi} = 1,033 > 1$, ce qui place la sévérité en **régime d'espérance infinie** — l'Expected Shortfall y est mathématiquement indéfini, ce qui justifie *a posteriori* le recours à un plafond de sévérité (capacité de réassurance) pour rendre le capital PRC calculable.

1.9 Modélisation de la dépendance de queue : le choix de la Copule de Gumbel

L'agrégation des différentes briques de risque (remédiation, tiers prestataires, amendes) nécessite de capturer la structure de dépendance. Le théorème de Sklar (1959) permet de dissocier les lois marginales de la structure de dépendance.

Théorème de Sklar. Soit H une fonction de répartition jointe de marges $F_1, \dots, F_d$. Il existe une copule $C : [0, 1]^d \rightarrow [0, 1]$ telle que pour tout $x_1, \dots, x_d \in \mathbb{R} \cup \{-\infty, +\infty\}$:

$$H(x_1, \dots, x_d) = C(F_1(x_1), \dots, F_d(x_d)) \quad (19)$$

Dans le cas du risque cyber, la préoccupation majeure du régulateur (notamment sous DORA) est la contagion systémique : la probabilité que les pires sinistres (ex : paralysie d'un prestataire cloud critique) surviennent simultanément avec des attaques majeures sur l'assureur. Cette caractéristique impose l'utilisation d'une copule présentant une **dépendance de queue supérieure** (upper tail dependence) strictement positive.

Le coefficient de dépendance de queue supérieure λ_U entre deux variables X_1, X_2 de fonctions de répartition F_1, F_2 est défini par :

$$\lambda_U = \lim_{q \rightarrow 1^-} \mathbb{P}(X_1 > F_1^{-1}(q) \mid X_2 > F_2^{-1}(q)) \quad (20)$$

La copule Gaussienne possède une dépendance de queue asymptotiquement nulle ($\lambda_U = 0$), ce qui la disqualifie pour modéliser le risque de crise systémique. C'est pourquoi nous avons opté pour la famille archimédienne, et spécifiquement la *copule de Gumbel*, définie pour $\eta \in [1, +\infty)$ par :

$$C_\eta(u, v) = \exp\left(-[(-\ln u)^\eta + (-\ln v)^\eta]^{1/\eta}\right) \quad (21)$$

Pour la copule de Gumbel, $\lambda_U = 2 - 2^{1/\eta}$. Le paramètre η permet ainsi de piloter finement la propension des briques de risque à générer des pertes extrêmes conjointes. Cette formule, souvent admise, se démontre en trois lignes et fournit la justification *quantitative* du choix de Gumbel.

Proposition 1.6 (Dépendance de queue de la copule de Gumbel). *La copule de Gumbel de paramètre $\eta \geq 1$ possède une dépendance de queue supérieure $\lambda_U = 2 - 2^{1/\eta}$ et une dépendance de queue inférieure nulle $\lambda_L = 0$. Son τ de Kendall vaut $\tau = 1 - 1/\eta$.*

Démonstration. Le long de la diagonale, $C_\eta(q, q) = \exp(-[2(-\ln q)^\eta]^{1/\eta}) = \exp(-2^{1/\eta}(-\ln q)) = q^{2^{1/\eta}}$. Le coefficient de queue supérieure s'écrit $\lambda_U = \lim_{q \rightarrow 1^-} \frac{1 - 2q + C_\eta(q, q)}{1 - q} = 2 - \lim_{q \rightarrow 1^-} \frac{1 - q^{2^{1/\eta}}}{1 - q}$. Or $\lim_{q \rightarrow 1} \frac{1 - q^a}{1 - q} = a$ (règle de L'Hôpital), d'où $\lambda_U = 2 - 2^{1/\eta}$. Pour λ_L , un développement de $C_\eta(q, q)/q$ en $q \rightarrow 0^+$ montre que le rapport tend vers 0. Enfin $\tau = 1 - 1/\eta$ résulte de l'intégration du générateur archimédien $\phi(t) = (-\ln t)^\eta$ (Annexe A.8). ■

Le calibrage retenu $\eta = 1,8$ (apparié au τ de Kendall empirique 0,444 entre briques) correspond ainsi à $\lambda_U = 2 - 2^{1/1,8} = 0,530$: en régime de crise, deux briques de risque ont une probabilité limite de 53 % de franchir *conjointement* un quantile extrême. Le régime conforme ($\eta = 1,2$) abaisse cette probabilité à $\lambda_U = 0,218$. C'est cette dépendance de queue *strictement positive* — impossible à reproduire avec une copule gaussienne — qui matérialise la contagion systémique visée par DORA, et dont le test de robustesse du §5.6 mesure l'impact sur le capital.

1.10 Transformation d'un choc systémique en risque de conformité : le modèle de Vasicek

Pour modéliser l'occurrence de l'amende administrative et la défaillance d'un prestataire sous DORA en fonction d'un environnement macro-cyber (crise systémique), nous adaptons le modèle à un facteur de Vasicek (initialement conçu pour le risque de crédit asymétrique de type Merton).

Soit une variable latente Z_i représentant la robustesse globale (ou solvabilité numérique) d'une entité i . Nous postulons que cette robustesse dépend d'un facteur de risque systémique commun à tout le marché Y (par exemple, la découverte d'une faille *zero-day* mondiale) et d'un facteur idiosyncratique propre à l'entité X_i (la qualité de sa gouvernance IT) :

$$Z_i = \sqrt{\rho}Y + \sqrt{1 - \rho}X_i \quad (22)$$

où Y et X_i sont des variables normales centrées réduites indépendantes, et $\rho \in [0, 1]$ mesure la sensibilité de l'entité au choc systémique (le coefficient de corrélation des actifs).

Une entité subit une défaillance de conformité (déclenchant potentiellement une amende ou une rupture de service critique) si sa robustesse Z_i tombe sous un certain seuil de tolérance $c_i = \Phi^{-1}(PCD_{marginal})$. Conditionnellement à un état donné de l'environnement macro-cyber $Y = y$

(où $y < 0$ représente un choc dégradé), la probabilité conditionnelle de défaut de conformité, notée $PCD_i(y)$, s'écrit :

$$PCD_i(y) = \mathbb{P}(Z_i < c_i \mid Y = y) = \mathbb{P}(\sqrt{\rho}y + \sqrt{1-\rho}X_i < c_i) \quad (23)$$

Puisque $X_i \sim \mathcal{N}(0, 1)$, on isole X_i pour obtenir la formule fermée :

$$PCD_i(y) = \Phi\left(\frac{\Phi^{-1}(PCD_{\text{marginal}}) - \sqrt{\rho}y}{\sqrt{1-\rho}}\right) \quad (24)$$

Cette formulation mathématique rigoureuse justifie la dynamique asymétrique observée dans nos résultats : une entité « Leader » (dont le seuil c_i est très bas) restera résiliente même si Y se dégrade, tandis qu'une entité « Médiane » verra sa probabilité de défaut converger asymptotiquement vers 1, ce qui active mécaniquement la contagion entre la brique prestataire et la brique sanction dans l'allocation d'Euler. On peut résumer ces propriétés dans l'énoncé suivant.

Proposition 1.7 (Probabilité de défaut de conformité conditionnelle). *Sous le modèle à facteur unique $Z_i = \sqrt{\rho}Y + \sqrt{1-\rho}X_i$ avec $Y, X_i \sim \mathcal{N}(0, 1)$ indépendantes et seuil $c_i = \Phi^{-1}(p)$ où $p = PCD_{\text{marginal}}$, la probabilité de défaut conditionnelle au facteur systémique $Y = y$ vaut*

$$PCD_i(y) = \left[\Phi\left(\frac{\Phi^{-1}(p) - \sqrt{\rho}y}{\sqrt{1-\rho}}\right) \right]. \quad (25)$$

La fonction $y \mapsto PCD_i(y)$ est décroissante ; sa sensibilité au choc augmente avec ρ , et pour $\rho \rightarrow 1$ elle tend vers un échelon (défaut certain dès $y < \Phi^{-1}(p)$).

Démonstration. Le défaut survient si $Z_i < c_i$. Conditionnellement à $Y = y$, $Z_i = \sqrt{\rho}y + \sqrt{1-\rho}X_i$ avec $X_i \sim \mathcal{N}(0, 1)$, donc $PCD_i(y) = \mathbb{P}(\sqrt{1-\rho}X_i < c_i - \sqrt{\rho}y) = \mathbb{P}(X_i < (c_i - \sqrt{\rho}y)/\sqrt{1-\rho})$, d'où (25) en appliquant Φ et $c_i = \Phi^{-1}(p)$. La monotonie provient du signe négatif de y dans l'argument ; la dérivée $\partial PCD_i/\partial \rho$ et la limite en échelon sont détaillées en Annexe A.9. ■

2 Données et limites

La modélisation développée dans ce mémoire ne repose sur aucune base de données unique. Chaque source mobilisée présente un périmètre, un biais et un niveau de granularité distincts, et c'est précisément leur articulation — plutôt que le choix d'une source « privilégiée » — qui constitue la démarche méthodologique retenue. Cette partie présente successivement les trois sources utilisées, avant de formaliser un cadre épistémique explicite sur les limites de l'exercice.

Bloc synthèse — Cartographie des sources et de leurs rôles

Un point de clarification méthodologique central structure l'ensemble de cette partie : **aucune base n'est utilisée seule**. Chaque source alimente une composante précise du modèle, selon ses propriétés propres.

Source	Rôle dans le modèle	Justification / limite
PRC 2025	Fréquence (λ) ; sévérité indirecte via conversion Jacobs	Périmètre défini, mais sévérité dérivée d'un modèle log-log
SAS OpRisk Global	Sévérité (montants réels)	Montants observés, mais biais vers les grandes entités financières
Hackmageddon	Multiplicateurs de scénario DORA (structure du risque)	Ne calibre pas le modèle : ajuste λ selon le niveau de conformité

Cette répartition des rôles évite un écueil fréquent dans la modélisation du risque cyber : traiter une base généraliste comme si elle pouvait, à elle seule, calibrer l'ensemble d'un modèle fréquence-sévérité. Chaque source est au contraire mobilisée là où elle est la plus fiable, et ses limites propres sont explicitement documentées dans les sous-sections suivantes.

2.1 Exigences de Solvabilité II sur la qualité des données (Article 19)

L'utilisation d'un modèle interne, même partiel, est strictement encadrée par la directive Solvabilité II. L'Article 19 du Règlement Délégué (UE) 2015/35 impose que les données utilisées pour le calcul de la distribution de probabilité prévisionnelle respectent trois critères cumulatifs : l'exactitude, l'exhaustivité et la pertinence.

Dans le domaine du risque cyber, aucune base de données publique ou commerciale ne satisfait pleinement ces trois critères. L'actuaire est donc contraint de documenter rigoureusement les biais inhérents aux données historiques et de justifier les retraitements appliqués. La validité du SCR calculé ne repose pas sur la perfection de la donnée (qui n'existe pas), mais sur la transparence des limites épistémiques et la robustesse du modèle mathématique face à ces biais.

2.2 Analyse critique des bases de sinistralité : les trois biais fondamentaux

L'utilisation conjointe des bases *Privacy Rights Clearinghouse* (PRC) et SAS OpRisk Global permet de croiser les perspectives, mais nécessite d'identifier trois biais statistiques majeurs qui altèrent l'estimation de l'indice de queue ξ .

1. Le biais de sélection (Selection Bias). Ce biais affecte particulièrement la base OpRisk Global, qui se nourrit principalement d'événements rendus publics dans la presse financière ou les rapports annuels. Par construction, un incident cyber n'atteint ce seuil de visibilité que s'il frappe une entité d'une certaine taille (généralement des institutions systémiques ou de grandes banques internationales) ou si son montant est exceptionnellement élevé. Ce biais de taille (size bias) conduit à une sur-représentation des événements extrêmes et une sous-représentation de la sinistralité d'attrition. Si l'on calibre directement un modèle sur cette base pour une entité de taille moyenne (ex : une mutuelle régionale), la probabilité de subir une perte extrême sera mécaniquement surestimée. C'est pour cette raison que notre approche conditionne la fréquence d'occurrence au profil de l'entité via le modèle de Vasicek (Partie 3).

2. Le biais de déclaration (Reporting Bias). La base PRC est soumise à un biais de déclaration lié aux asymétries réglementaires. Aux États-Unis, la notification des fuites de données personnelles (Data Breaches) est obligatoire dans la plupart des États, ce qui rend la base PRC très riche sur ce vecteur d'attaque. En revanche, un rançongiciel (Ransomware) qui paralyse les serveurs de l'entreprise mais n'exfiltre aucune donnée personnelle peut ne déclencher aucune

obligation de notification légale (avant l'entrée en vigueur d'actes récents comme le CIRCIA). Par conséquent, calibrer une fréquence globale sur la PRC tend à sous-estimer le risque d'interruption d'activité (Business Interruption) au profit du seul risque de compromission de données. C'est précisément pour corriger ce biais que nous avons superposé la structure des vecteurs d'attaque de la base Hackmageddon (qui capte l'ensemble du spectre, y compris les ransomwares) sur la fréquence de base issue de la PRC.

3. Le biais de survie (Survivorship Bias). Dans les bases de pertes opérationnelles, la sévérité maximale observée est paradoxalement bornée par la capacité de survie de l'entité. Une cyberattaque ayant entraîné la faillite pure et simple de l'entreprise (ruine) disparaît souvent des bases de pertes opérationnelles classiques, car il n'y a plus d'entité survivante pour reporter la perte financière finale et les coûts de remédiation à long terme. Ce biais tronque artificiellement l'extrême queue de distribution. La Théorie des Valeurs Extrêmes (EVT), en ajustant une loi de Pareto Généralisée (GPD) qui permet d'extrapoler au-delà du maximum historique observé, est la réponse mathématique adéquate à ce biais de survie.

2.3 Traitement de l'inflation cyber et actualisation des pertes

L'hétérogénéité temporelle des bases de données constitue une autre infraction potentielle au critère d'exactitude de Solvabilité II. La base OpRisk Global agrège des pertes allant de l'année 2000 à 2026. Utiliser un montant de perte de 2018 tel quel dans un modèle de capital en 2026 constitue une erreur actuarielle sévère, l'inflation cyber ne se comportant pas comme l'inflation macroéconomique classique (IPC).

Le coût d'un sinistre cyber est principalement tiré par trois facteurs :

- **L'inflation salariale IT** : Le coût des experts en remédiation (forensic, restauration de systèmes) connaît une inflation nettement supérieure à l'indice des prix à la consommation, en raison de la pénurie de talents en cybersécurité.
- **L'inflation juridique et réglementaire** : L'entrée en vigueur du RGPD en 2018 a drastiquement modifié l'échelle des sanctions. Une fuite de données en 2015 coûtait infiniment moins cher en amendes administratives que la même fuite en 2025.
- **L'escalade des rançons** : La professionnalisation du cybercrime (Ransomware-as-a-Service) a transformé les demandes de rançons de quelques milliers de dollars en 2016 à plusieurs dizaines de millions d'euros en 2026.

Pour respecter les exigences de l'Article 19, les sinistres historiques doivent être actualisés en euros de l'année de modélisation (2026). Soit L_t la perte observée l'année t , la perte actualisée $\tilde{L}_{2026}$ s'écrit :

$$\tilde{L}_{2026} = L_t \times \prod_{k=t}^{2025} (1 + i_k^{cyber}) \quad (26)$$

où i_k^{cyber} est un taux d'inflation spécifique aux sinistres technologiques (souvent estimé par des indices sectoriels entre 5 % et 10 % annuels). Dans le cadre de ce mémoire, nous assumons que les bases commerciales traitées intègrent une homogénéisation monétaire, mais soulignons que la construction d'un indice d'inflation cyber robuste demeure un défi majeur pour la place financière.

Par ailleurs, le traitement des données manquantes dans la PRC (qui recense parfois le nombre d'enregistrements compromis sans le montant financier) est géré par la conversion de Jacobs. Bien qu'utile comme *proxy*, ce modèle de régression log-log présente la limite de « lisser » la variance et de minorer les extrêmes, justifiant notre décision de ne pas plafonner la calibration issue directement d'OpRisk (où les montants sont observés de bout en bout).

2.4 Perspectives : Le registre européen DORA comme solution pérenne

Les limites épistémiques et statistiques exposées ci-dessus contraignent aujourd'hui le calcul du SCR cyber à de larges intervalles d'incertitude. Cependant, cette situation est transitoire. L'apport fondamental du règlement DORA ne réside pas uniquement dans l'imposition de normes de sécurité (Chapitre II), mais dans la création d'un cadre de **notification harmonisée des incidents majeurs liés aux TIC** (Chapitre III, Article 19 de DORA).

DORA impose aux entités financières de reporter à leur autorité compétente (l'ACPR en France) les incidents majeurs selon une taxonomie standardisée (causes, vecteurs, temps de résolution, pertes financières directes et indirectes). À terme, le règlement prévoit la centralisation de ces rapports au sein d'un pôle de l'Union européenne (EU Hub).

La constitution de ce registre européen résoudra structurellement les trois failles actuelles des bases de données :

- **Suppression du biais de déclaration** : Le *reporting* étant réglementairement obligatoire, la base sera exhaustive.
- **Suppression du biais de sélection** : Le registre couvrira toutes les strates du marché financier (grandes banques, mais aussi courtiers, mutuelles et sociétés de gestion), offrant enfin une granularité suffisante pour conditionner la sévérité par taille d'entité.
- **Visibilité sur les tiers** : Le registre DORA cartographiera l'implication des prestataires tiers ICT, validant empiriquement les modèles de contagion externe via la copule de Gumbel présentés en Partie 3.

Dès lors, l'architecture du Modèle Interne Partiel développée dans ce mémoire (LDA, théorie des valeurs extrêmes, facteurs de Vasicek, allocation d'Euler) prend toute sa valeur. Le modèle mathématique et les scripts de simulation construits sont intégralement agnostiques à la source de données. Lorsqu'une base d'incidents DORA harmonisée sera rendue disponible à la profession actuarielle, il suffira de substituer ces nouvelles données aux actuelles bases PRC et OpRisk. Le moteur de calcul absorbera ces entrées qualifiées pour produire un SCR cyber d'une précision inédite, répondant simultanément aux exigences qualitatives de DORA et aux contraintes quantitatives de Solvabilité II.

Automatisation du reclassement par NLP. En attendant ce registre harmonisé, une partie du travail de fiabilisation des données peut d'ores et déjà être outillée. Le reclassement manuel par grille de mots-clés opéré en 2.5 sur la taxonomie Hackmageddon (nécessaire pour isoler le ransomware, absent en tant que catégorie en 2023) illustre une limite récurrente des bases de sinistralité cyber : une taxonomie déclarative instable, dont la correction repose aujourd'hui sur un travail manuel documenté mais non reproductible à grande échelle. Les travaux R&D menés chez Nexialog Consulting sur l'exploitation du NLP et des modèles de langage pour l'enrichissement de bases de sinistralité cyber (rapports d'incidents, bases de vulnérabilités, publications techniques) ouvrent une voie directe pour systématiser ce type de reclassement — en le rendant à la fois plus rigoureux (classification supervisée validée statistiquement plutôt que grille de mots-clés ad hoc) et transposable à d'autres bases (OpRisk, futur registre DORA). Cette piste n'a pas été mise en oeuvre dans le présent mémoire, faute de corpus annoté disponible dans le périmètre de ce travail, mais constitue une perspective directe de prolongement.

2.5 La PRC comme proxy de fréquence : périmètre, biais, justification

La base *Privacy Rights Clearinghouse* (PRC) constitue le socle de calibration de la fréquence annuelle de référence λ_{ref} utilisée dans le modèle. Son intérêt principal tient à son périmètre défini et à sa couverture longitudinale, qui permettent d'obtenir un niveau de fréquence directement exploitable pour une simulation actuarielle.

La PRC joue toutefois un second rôle, plus fragile : celui de source de sévérité indirecte, via une conversion dite de Jacobs, qui traduit un nombre d'enregistrements compromis en un montant de perte financière à partir d'un modèle log-log. Ce mécanisme permet d'élargir le spectre de tailles d'incidents disponibles, mais introduit un biais de modèle supplémentaire : la sévérité qui en résulte n'est pas observée directement, elle est *dérivée*. La calibration en queue de distribution obtenue sur la PRC — réalisée en propre sur les 15 053 incidents 2019–2025 de la base brute, via la conversion Jacobs $\ln(L) = 7,68 + 0,76 \ln(X)$ — donne un paramètre de forme $\hat{\xi}_{\text{PRC}} = 1,03$ (IC90% [0,97 ; 1,09]), caractéristique d'une queue extrêmement lourde, à espérance infinie — un résultat qui, pris seul, rendrait toute simulation numériquement instable et qui doit donc être discuté conjointement avec les corrections méthodologiques présentées en 2.4.

La justification du recours à la PRC malgré ces limites tient à l'absence d'alternative comparable pour la fréquence : aucune des deux autres sources mobilisées (Hackmageddon, OpRisk Global) ne permet, seule, d'ancrer un niveau annuel de sinistralité directement transposable à un portefeuille assurantiel.

2.6 Hackmageddon : apports et limites

Périmètre consolidé. La base Hackmageddon a été consolidée sur le semestre complet et contigu janvier–juin 2026, soit **1 041 incidents**. La couverture pluriannuelle initialement envisagée a été abandonnée : l'année 2024 est absente du jeu transmis, et 2025 n'est disponible que partiellement. La base est donc exploitée pour la *structure* du risque, non pour son *niveau* ou sa dynamique temporelle — ce qui explique pourquoi elle n'intervient pas dans la calibration de λ_{ref} , réservée à la PRC.

Apport 1 : structure du risque et mapping DORA. Sur les 1 041 incidents, 840 disposent d'un vecteur d'accès initial identifié (81 %), regroupés en familles et reliés directement aux articles DORA :

Vecteur d'attaque	Part	Exigence DORA
Phishing / Ingénierie sociale	38,8 %	Art. 13 — Sensibilisation & formation
Exploitation vuln. exposée	33,8 %	Art. 26 — Tests TLPT ; Art. 8–10
Supply chain / Tiers ICT	15,8 %	Art. 28–44 — Gestion risque tiers
Identifiants compromis	6,3 %	Art. 9 — Contrôle d'accès & MFA

Deux chiffres sont structurants pour la construction des scénarios de la Partie 4 : **15,8 %** des attaques empruntent le vecteur tiers/supply chain, coeur des articles 28–44 ; et **49,6 %** relèvent de vecteurs qu'un test TLPT (art. 26) est censé détecter en amont (exploitation et tiers cumulés).

Limite 1 : biais de visibilité. Hackmageddon recense des incidents rendus publics, majoritairement médiatiques ou déclarés, ce qui sur-représente structurellement les événements les plus visibles au détriment des incidents ordinaires, moins commentés. La base ne peut donc servir à estimer un niveau absolu de fréquence, seulement une répartition relative entre vecteurs d'attaque.

Limite 2 : taxonomie instable. Une comparaison de structure entre 2023 (3 019 incidents, Q3 manquant) et 2026 a mis en évidence un artefact de taxonomie. La catégorie « Ransomware »

n’existait pas en 2023, les incidents correspondants étant alors classés sous « Malware ». Une lecture naïve suggérerait une hausse du ransomware de +11 points ; après reclassement par grille de mots-clés commune, le ransomware *recule* en réalité de 23 points.

Dimension	2023	2026	Δ
Cybercriminalité (motivation)	81,1 %	73,9 %	−7,1
Cyberespionnage (motivation)	9,6 %	20,6 %	+11,0
Ransomware (reclassé)	35,8 %	12,7 %	−23,1

Seules les **motivations** (taxonomie stable de haut niveau) sont donc comparables directement dans le temps ; les **types d’attaque** ne le sont qu’après un travail de reclassement documenté. Le signal robuste qui demeure est la bascule du cybercrime de masse vers l’espionnage ciblé, une information pertinente pour la discussion du risque systémique en Partie 5, mais qui illustre aussi la fragilité méthodologique de toute lecture brute d’une base de ce type.

2.7 SAS OpRisk Global : proxy de sévérité ICT, lien avec l’approche AMA de Bâle 3

Nature et périmètre. OpRisk Global est la base de référence historique du risque opérationnel au sens de Bâle 2/3, comptant **41 975 incidents** après nettoyage d’une aberration de saisie. Le risque cyber n’y constitue pas une catégorie native : il est reconstruit à partir des catégories « Systems Security » et « Business Disruption and System Failures ». Le périmètre cyber × finance retenu compte **582 incidents** sur la période 2000–2026.

Lien avec l’approche AMA. Cette base est historiquement celle qui alimentait les modèles internes de type *Advanced Measurement Approach* évoqués en Partie 1, avant leur retrait au profit de la SMA sous Bâle III/IV. Son usage ici renoue donc, à des fins de modélisation interne et non de calcul réglementaire de Pilier 1, avec la logique originelle de la LDA bancaire : calibrer une sévérité extrême à partir de pertes réellement observées plutôt qu’à partir d’un indicateur de volume forfaitaire.

Statistiques de sévérité.

Indicateur	Valeur	Indicateur	Valeur
Médiane	1,50 M\$	P99	402 M\$
Moyenne	26,4 M\$	Maximum	1 500 M\$
P90	51,5 M\$	Total cumulé	15,4 Md\$

La concentration extrême de la sévérité — les 10 % d’incidents les plus graves représentent 82,7 % de la perte totale, et le seul top 1 % en représente 31 % — constitue une signature de queue lourde qui justifie directement le recours à la théorie des valeurs extrêmes développée en Partie 3.

Choix du seuil POT. Le choix du seuil u au-dessus duquel la loi de Pareto généralisée est calibrée résulte d'un compromis classique biais-variance, arbitré graphiquement. Le *mean excess plot* (figure 1) présente une pente positive et globalement linéaire au-delà de $u = 20$ M€, signature attendue d'un régime GPD à queue lourde ($\xi > 0$) ; c'est ce seuil, correspondant au percentile 85 de la distribution des montants, qui est retenu pour la suite.

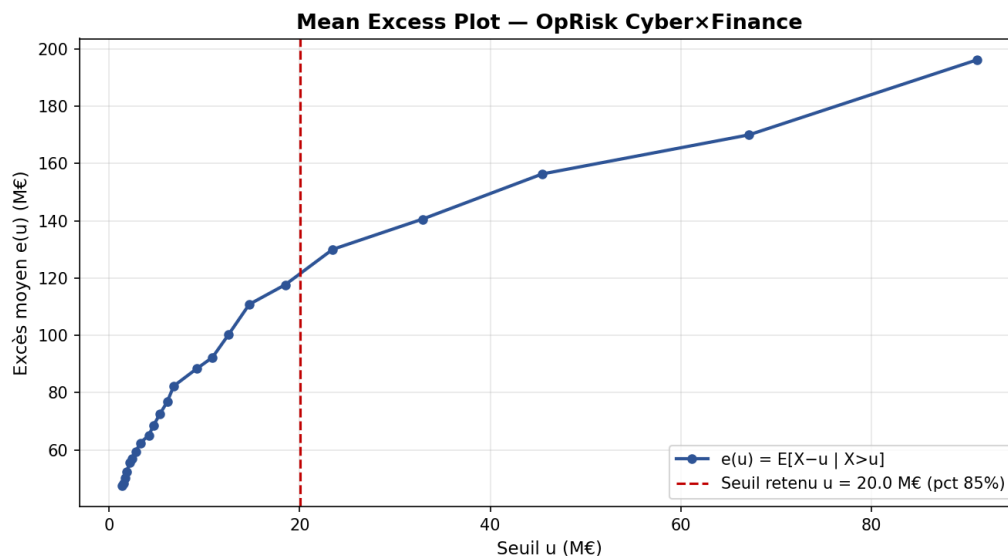


Figure 1. Mean excess plot sur le périmètre cyber×finance d’OpRisk Global. La linéarité de $e(u)$ au-delà du seuil retenu $u = 20$ M€(pointillés) confirme le régime de queue lourde justifiant l’ajustement GPD.

Calibration GPD et validation croisée. Au seuil du percentile 85 ($u = 20,0$ M€, 91 excès), la calibration GPD donne :

$$\hat{\xi} = 0,595 \quad (\text{IC}_{90\%} = [0,31 ; 0,83]), \quad \hat{\sigma} = 58,0 \text{ M€}, \quad \text{VaR}_{99,5\%} = 663 \text{ M€}.$$

L’intervalle de confiance bootstrap sur cette VaR est $[411 ; 1037]$ M€, soit un facteur 2,5 entre les bornes — une ampleur qui, à elle seule, illustre que le SCR ne peut être présenté comme un point.

La comparaison avec la PRC ($\hat{\xi}_{\text{PRC}} = 1,03$ contre $\hat{\xi}_{\text{OpRisk}} = 0,595$) révèle un écart de régime de queue, expliqué par le biais de taille d’OpRisk : les grandes entités financières y sont sur-représentées et absorbent mieux les chocs, d’où une queue apparemment plus légère. Les deux sources confirment néanmoins le même régime qualitatif de queue lourde ($\xi > 0$). Il n’existe donc pas de hiérarchie « source primaire » en sévérité : OpRisk fournit des montants réels, la PRC un spectre de tailles plus large via la conversion Jacobs — deux estimations indépendantes et complémentaires, dont l’écart constitue lui-même une information sur l’incertitude du modèle.

La décomposition par sous-catégorie révèle en outre deux profils de risque distincts : les pannes (« Business Disruption ») sont moins fréquentes (19 % des incidents) mais nettement plus coûteuses, avec une médiane cinq fois supérieure à celle des intrusions (« Systems Security »), suggérant que les multiplicateurs DORA pourraient à terme être différenciés non seulement en fréquence mais aussi en sévérité — sous réserve de la taille réduite de l’échantillon « pannes » (28 excès), qui rend cette calibration indicative.

2.8 Cadre épistémique : ce qu’on sait faire et ce qu’on ne sait pas faire

La discipline méthodologique retenue dans ce mémoire consiste à ne jamais prétendre inférer davantage que ce que les données permettent réellement, ce qui impose d’explicitier aussi bien les capacités que les limites du dispositif.

Ce que l'on sait faire. On sait calibrer une fréquence de référence annuelle à partir d'un proxy sectoriel documenté (PRC), et la moduler selon une structure d'attaque observée empiriquement (Hackmageddon). On sait calibrer une sévérité de queue lourde par la théorie des valeurs extrêmes à partir de pertes réellement observées (OpRisk Global), et confronter cette calibration à une source indépendante pour objectiver l'incertitude. On sait enfin traiter l'écart entre sources non comme un bruit à éliminer, mais comme une dimension d'incertitude à part entière, qui s'ajoute à l'incertitude de paramètre estimée par bootstrap.

Ce que l'on ne sait pas faire. On ne sait pas mesurer directement le niveau de conformité DORA d'une entité donnée ; c'est précisément la raison d'être de la variable latente introduite en 1.4. On ne sait pas disposer d'une base d'incidents harmonisée à l'échelle européenne, exhaustive et non biaisée par la visibilité médiatique. On ne sait pas non plus estimer avec précision la corrélation entre les différentes briques de perte, faute d'historique suffisant sur les événements joints ; cette incertitude est traitée en Partie 3 par une structure de dépendance explicite plutôt que par une hypothèse d'indépendance non fondée.

Deux corrections méthodologiques transparentes. Ce cadre épistémique a conduit à identifier et corriger deux défauts du moteur de simulation en cours de travail. D'une part, avec $\hat{\xi}_{\text{PRC}} = 1,03 \geq 1$, l'espérance de la sévérité PRC est infinie et la VaR simulée diverge numériquement ; un plafond de sévérité de 40 M€, ancré sur la capacité de réassurance cyber observable sur le marché, est appliqué à la *seule source PRC*. La calibration OpRisk, dont l'indice de queue $\hat{\xi}_{\text{OpRisk}} = 0,595 < 1$ garantit une espérance finie, n'est en revanche pas plafonnée : ses montants étant observés de bout en bout, y appliquer un plafond tronquerait des pertes réelles et contredirait sa propre calibration. D'autre part, le moteur attribuait initialement une sévérité de queue (GPD) à l'intégralité des événements simulés, au lieu de la seule fraction p_u dépassant le seuil de queue ; cette correction ramène les SCR simulés dans des ordres de grandeur cohérents avec les données observées.

La conséquence directe de ce cadre épistémique est méthodologique autant que présentationnelle : le résultat final ne peut être livré comme un montant unique, mais doit être présenté comme une distribution large, conditionnelle à des hypothèses documentées et à des sources dont les écarts sont eux-mêmes informatifs — ce principe structure l'ensemble de la Partie 5.

2.9 Suffisance du dispositif de données pour l'exercice actuariel

Le dispositif retenu — PRC pour la fréquence, OpRisk Global pour la sévérité observée, Hackmageddon pour la structure du risque — appelle une question préalable à toute discussion de robustesse : ce triptyque est-il suffisant pour l'exercice mené dans ce mémoire ? La réponse tient à la nature même de l'exercice. L'objectif n'est pas de produire une formule réglementaire de Pilier 1, qui exigerait une base exhaustive et représentative du marché au sens de l'Article 19 — base qui, comme l'a établi la section 2.1, n'existe aujourd'hui pour aucun acteur, public ou privé, sur le risque cyber. L'objectif est de construire, dans l'esprit du Pilier 2 et de l'ORSA, une mesure prospective dont la valeur ajoutée actuarielle réside dans la transparence de ses limites autant que dans la précision de son résultat. Sous cet angle, les trois sources mobilisées couvrent exactement les trois rôles qu'exige une architecture fréquence-sévérité-structure, et leurs biais respectifs — sélection, déclaration, survie, visibilité, instabilité taxonomique — sont documentés plutôt que dissimulés (section 2.2).

Pourquoi ne pas simplement en ajouter d'autres. Des bases supplémentaires existent (bases commerciales de sinistres cyber assurantiels, enquêtes sectorielles européennes) et pourraient, en principe, enrichir le dispositif. Mais chacune porterait ses propres biais de sélection et

de représentativité, sans lever la limite structurelle identifiée dès la section 2.1 : l'absence, à ce jour, d'un registre harmonisé et exhaustif à l'échelle du marché. Multiplier les sources déplacerait la difficulté sans la résoudre, et complexifierait un narratif dont la clarté — trois sources, trois rôles distincts, aucune hiérarchie de « source primaire » — constitue en elle-même un gage de rigueur méthodologique. L'analyse de sensibilité menée en 5.4 confirme d'ailleurs, *a posteriori*, la pertinence de ce choix : c'est l'incertitude sur l'indice de queue ξ de la sévérité — estimé sur les sources déjà mobilisées — qui domine très largement toute autre source de variation du modèle, multipliers de fréquence et paramètres de dépendance compris. Approfondir l'exploitation des trois sources retenues (bootstrap, validation croisée, diagnostics de stabilité) réduit donc l'incertitude du capital de façon bien plus significative que l'ajout d'une quatrième base de sinistralité.

2.10 Validation croisée externe : ENISA Threat Landscape

La structure du risque tirée de Hackmageddon (section 2.6), bien que documentée quant à ses limites de visibilité et de taxonomie, gagne à être confrontée à une source indépendante, de nature différente et couvrant un périmètre réglementaire proche de celui du présent mémoire. Le rapport *ENISA Threat Landscape 2025*, déjà mobilisé en 4.3 pour ancrer les bornes du multiplicateur associé à l'exploitation de vulnérabilités, remplit ce rôle : constitué par l'agence européenne de cybersécurité elle-même à partir de 4 875 incidents de périmètre européen, il repose sur une méthodologie de collecte distincte de celle, essentiellement médiatique, de Hackmageddon.

La confrontation porte sur un point précis, déjà exploité en 4.3 : ENISA mesure un taux de conversion tentative-vers-intrusion de 70 % pour l'exploitation de vulnérabilités, contre seulement 27 % pour le phishing. Cette asymétrie, mesurée par un organisme réglementaire sur un périmètre indépendant, confirme un résultat qu'Hackmageddon, par construction, ne peut révéler à partir du seul volume d'incidents observés : le phishing domine la structure en volume (38,8 % contre 33,8 % pour l'exploitation de vulnérabilités, section 2.6), mais convertit nettement moins efficacement en intrusion réussie. Les deux sources s'accordent ainsi, chacune sur son propre plan — structure des incidents rapportés pour Hackmageddon, taux de conversion pour ENISA — sur une même hiérarchie qualitative des vecteurs d'attaque, ce qui renforce la crédibilité du mapping vecteurs $\rightarrow$ exigences DORA retenu en 4.2 sans nécessiter de recalibration.

Piste non mobilisée : Verizon DBIR. Le *Data Breach Investigations Report* de Verizon, fondé sur des méthodologies de collecte distinctes à la fois de Hackmageddon et d'ENISA, constituerait une troisième confrontation naturelle. Il n'est pas mobilisé dans le présent mémoire, faute de statistiques suffisamment vérifiées dans le périmètre de ce travail pour en garantir l'exactitude des chiffres cités — une prudence identique à celle déjà retenue pour les références bibliographiques marquées comme à vérifier (cf. **references.bib**). Cette confrontation constitue une perspective directe de prolongement, dans le même esprit que l'automatisation du reclassement par NLP déjà évoquée en 2.4.

3 Modélisation

Les deux parties précédentes ont posé le cadre réglementaire et les données disponibles. Cette troisième partie formalise le moteur actuariel qui transforme ces éléments en une distribution de pertes, puis en une mesure de capital. L'architecture retenue reste fondée sur une approche par distribution des pertes (LDA), enrichie pour tenir compte de la multiplicité des sources de risque et de leur dépendance mutuelle.

3.1 Architecture LDA : les quatre briques de perte

L'approche LDA classique calibre une fréquence de sinistres stationnaire, indépendante du niveau de maîtrise opérationnelle de l'assureur. Cette hypothèse est précisément ce que le règlement DORA invite à remettre en cause : un défaut de conformité aux exigences de résilience numérique n'affecte pas la sévérité des sinistres de façon uniforme, mais leur *fréquence*, par l'intermédiaire des vecteurs d'attaque que chaque article de DORA est censé atténuer.

Le modèle retenu décompose la perte physique simulée L_{DORA} en trois briques, chacune dotée de sa propre logique :

$$L_{DORA} = L_{\text{remédiation}} + L_{\text{sanction}} + L_{\text{prestataire}} \quad (27)$$

La brique d'**aggravation** ne constitue pas une perte simulée supplémentaire s'ajoutant à cette somme, mais une mesure dérivée. Elle quantifie le surcroît de capital entre un état conforme et un état non conforme, au travers du différentiel qui constitue la grandeur centrale du mémoire :

$$\Delta_{DORA} = \text{VaR}_\alpha(L_{DORA}^{\text{non conforme}}) - \text{VaR}_\alpha(L_{DORA}^{\text{conforme}}) \quad (28)$$

développé en Partie 4.

La brique de **remédiation** constitue le coeur fréquence-sévérité du modèle : elle représente le coût direct de gestion des incidents cyber, simulé par composition d'une fréquence (section 3.2) et d'une sévérité extrême (section 3.3). La brique de **sanction** traduit le risque réglementaire explicite prévu par les articles 50-52 de DORA, pilotée par la probabilité de défaut de conformité $PCD_i(\theta)$ introduite en 1.4. La brique de **prestataire** modélise un événement indépendant impliquant un tiers ICT critique, dont la probabilité d'occurrence diminue lorsque l'entité maîtrise mieux la gestion de ses tiers (chapitre V de DORA). Enfin, la brique d'**aggravation** ne constitue pas une perte simulée supplémentaire au même titre que les trois précédentes : elle mesure le surcroît de capital entre un état conforme et un état non conforme, au travers de la différence $\Delta_{DORA} = \text{VaR}_\alpha(L_{DORA}^{\text{non conforme}}) - \text{VaR}_\alpha(L_{DORA}^{\text{conforme}})$, développée en Partie 4.

Cette architecture rompt avec une logique de chargements multiplicatifs appliqués uniformément sur une sévérité globale : chaque brique possède sa propre distribution, sa propre logique métier, et son propre lien — ou absence de lien — à la variable latente de conformité. Elle impose en contrepartie de traiter explicitement la question de la dépendance entre briques (section 3.4), qu'une architecture additive naïve négligerait.

3.2 Fréquence : NegBin, calibration PRC, sur-dispersion

Décomposition par vecteur d'attaque. La fréquence de référence λ_{ref} , calibrée sur la base PRC ($\lambda_{ref} = 341$ incidents/an), est décomposée en sous-fréquences par vecteur d'attaque, pondérées par la structure observée dans la base Hackmageddon :

$$\lambda_{ref} = \sum_v \lambda_v, \quad \lambda_v = \lambda_{ref} \times \pi_v, \quad (29)$$

où π_v est la part du vecteur v dans la structure Hackmageddon (38,8 % phishing, 33,8 % exploitation de vulnérabilités, 15,8 % supply chain, 6,3 % identifiants compromis, 5,3 % autres). Cette décomposition transforme un constat structurel en levier de modélisation : un défaut de conformité sur une exigence donnée n'agit que sur la sous-fréquence du vecteur qu'elle est censée mitiger, pas sur l'ensemble de λ_{ref} .

Choix de la loi binomiale négative. La fréquence agrégée $\lambda_{S_x} = \sum_v \lambda_{ref} \pi_v m_{v,S_x}$ obtenue sous un scénario S_x n'est pas simulée par une loi de Poisson, mais par une loi binomiale négative,

pour tenir compte de la sur-dispersion observée dans les données ($\sigma^2/\mu > 1$). Le facteur de sur-dispersion $\phi = \sigma^2/\mu = 9,2$ est traité comme une propriété structurelle de la sinistralité, supposée indépendante du niveau de fréquence : c'est donc ϕ qui est maintenu constant d'un scénario à l'autre, et non le paramètre r de la binomiale négative, qui est au contraire recalculé sous chaque scénario :

$$r_{S_x} = \frac{\lambda_{S_x}}{\phi - 1}, \quad p_{S_x} = \frac{r_{S_x}}{r_{S_x} + \lambda_{S_x}}. \quad (30)$$

Augmenter λ via les multiplicateurs DORA déplace ainsi la fréquence moyenne tout en préservant la *forme* de sur-dispersion de la sinistralité — une hypothèse de modélisation explicite, dont la limite est que le comportement de la sur-dispersion en régime de forte dégradation n'est pas lui-même observé, faute d'historique de crise DORA.

De la fréquence par scénario à la fréquence par entité. Le choix d'un scénario $S_x \in \{S_0, S_1, S_2\}$ reste, par construction, discret et appliqué uniformément à l'ensemble du marché. La variable latente de conformité $PCD_i(\theta)$ introduite en 1.4 permet de dépasser cette limite, en substituant à ce choix discret une interpolation continue :

$$m_v(PCD_i(\theta)) = 1 + PCD_i(\theta) \times (\bar{m}_v^{S_2} - 1), \quad (31)$$

où $\bar{m}_v^{S_2}$ est le centre de l'intervalle de multiplicateur sourcé en scénario S_2 . Une entité au profil de conformité mature conserve ainsi une fréquence proche de S_0 même en cas de choc systémique θ défavorable, tandis qu'une entité en retard de conformité peut, sous un ρ_i élevé, dépasser le multiplicateur S_2 dès l'environnement normal.

3.3 Sévérité : EVT/GPD, calibration OpRisk, validation croisée PRC

Choix de la loi de Pareto généralisée. La sévérité des sinistres cyber présente une signature de queue lourde documentée en Partie 2 : sur OpRisk Global, les 10 % d'incidents les plus graves concentrent 82,7 % de la perte totale. Cette concentration extrême justifie le recours à la théorie des valeurs extrêmes, et plus précisément à une modélisation de la queue de distribution par une loi de Pareto généralisée (GPD) au-delà d'un seuil u , selon l'approche *peaks-over-threshold*.

Calibration OpRisk. Au seuil du percentile 85 ($u = 20,0$ M€, 91 excès), la calibration donne :

$$\hat{\xi}_{\text{OpRisk}} = 0,595 \quad (\text{IC}_{90\%} = [0,31 ; 0,83]), \quad \hat{\sigma}_{\text{OpRisk}} = 58,0 \text{ M€}, \quad \text{VaR}_{99,5\%} = 663 \text{ M€}. \quad (32)$$

L'intervalle de confiance bootstrap sur cette VaR, $[411 ; 1037]$ M€, matérialise à lui seul un facteur 2,5 entre les bornes, uniquement imputable à l'incertitude de paramètre.

Stabilité du paramètre de forme. Le choix du seuil est corroboré par deux diagnostics complémentaires. Le *diagnostic GPD* (figure 2) montre que $\hat{\xi}$ se stabilise autour de 0,6 dès que le seuil atteint $u = 20$ M€, tout en conservant un nombre d'excès suffisant ($n = 91 > 30$) pour une estimation fiable : le seuil retenu se situe précisément à la frontière où le paramètre de forme quitte la zone instable ($\xi \geq 1$) pour se fixer dans un régime de moments finis. Le *Hill plot* (figure 3) confirme qualitativement ce niveau, l'estimateur de Hill restant compatible avec la référence MLE $\hat{\xi} \approx 0,60$ dans la plage des extrêmes retenus.

L'estimateur de Hill : définition et rôle diagnostique. Introduit par Hill (1975), l'estimateur de Hill fournit une estimation de l'indice de queue ξ à partir des k statistiques d'ordre

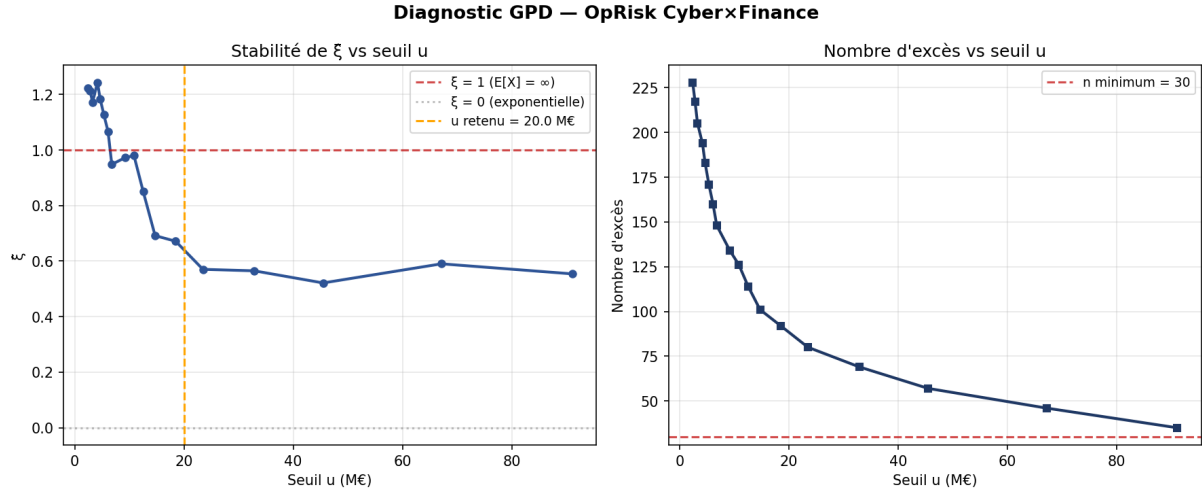


Figure 2. Diagnostic GPD sur le périmètre cyber×finance d'OpRisk. *Gauche* : stabilité de $\hat{\xi}$ en fonction du seuil u ; le paramètre passe sous $\xi = 1$ (espérance finie) et se stabilise autour de 0,6 au seuil retenu $u = 20$ M€. *Droite* : le nombre d'excès correspondant ($n = 91$) demeure au-dessus du minimum de 30 requis pour une estimation robuste.

les plus élevées d'un échantillon $X_{(1)} \leq \dots \leq X_{(n)}$, sans passer par l'ajustement paramétrique d'une loi de Pareto généralisée :

$$\hat{\xi}_{\text{Hill}}(k) = \frac{1}{k} \sum_{i=1}^k \ln X_{(n-i+1)} - \ln X_{(n-k)}. \quad (33)$$

Contrairement au maximum de vraisemblance sur la GPD, qui exploite le cadre théorique de Pickands–Balkema–de Haan et estime conjointement ξ et σ , l'estimateur de Hill repose sur une hypothèse de Pareto *pure* dans la queue et ne fournit qu'un indice de forme, sans paramètre d'échelle explicite (Beirlant et al., 2004). Sa propriété la plus documentée dans la littérature EVT est un compromis biais-variance piloté par le choix de k : pour k trop petit, l'estimateur est instable (variance élevée, intervalle de confiance large) ; pour k trop grand, il intègre des observations situées hors du régime purement asymptotique de la queue, ce qui induit un biais positif croissant avec k (Embrechts et al., 1997 ; Beirlant et al., 2004).

Application et confrontation au MLE-GPD. Le Hill plot obtenu sur le périmètre cyber×finance d'OpRisk (figure 3) illustre ce compromis de façon nette : l'estimateur croît de façon quasi monotone avec k , passant de $\hat{\xi} \approx 0,5$ pour k faible à $\hat{\xi} \approx 1,8$ pour $k = 200$, tandis que la bande de confiance asymptotique à 90 % s'élargit continûment. La référence par maximum de vraisemblance ($\hat{\xi}_{\text{MLE}} = 0,595$, pointillés rouges) n'est statistiquement compatible avec l'estimateur de Hill que sur une plage restreinte, $k \in [3, 25]$ environ, où la bande de confiance recouvre encore la valeur MLE. Au-delà de $k \approx 30$, l'estimateur de Hill diverge continûment de cette référence, ce qui traduit le biais positif attendu lorsque des observations hors du régime purement asymptotique de la queue sont intégrées au calcul. Sur le seuil effectivement retenu pour la calibration ($k = 86$), cet écart atteint 138,7 % ($\hat{\xi}_{\text{Hill}} = 1,42$ contre $\hat{\xi}_{\text{MLE}} = 0,595$), ce qui confirme que l'estimateur de Hill n'est pas adapté à ce niveau de k et que le MLE-GPD, qui exploite un cadre théorique plus général (loi GPD complète plutôt que Pareto pure), demeure l'estimateur de référence pour la calibration finale.

Validation croisée PRC. La calibration sur la PRC, via la conversion Jacobs, donne $\hat{\xi}_{\text{PRC}} = 1,03$ (seuil $u = 4,18$ M€, 2 258 excès), supérieur à $\hat{\xi}_{\text{OpRisk}} = 0,595$, les IC90% des deux estimateurs ne se chevauchant pas. Ce paramètre correspond formellement à une espérance de sévérité

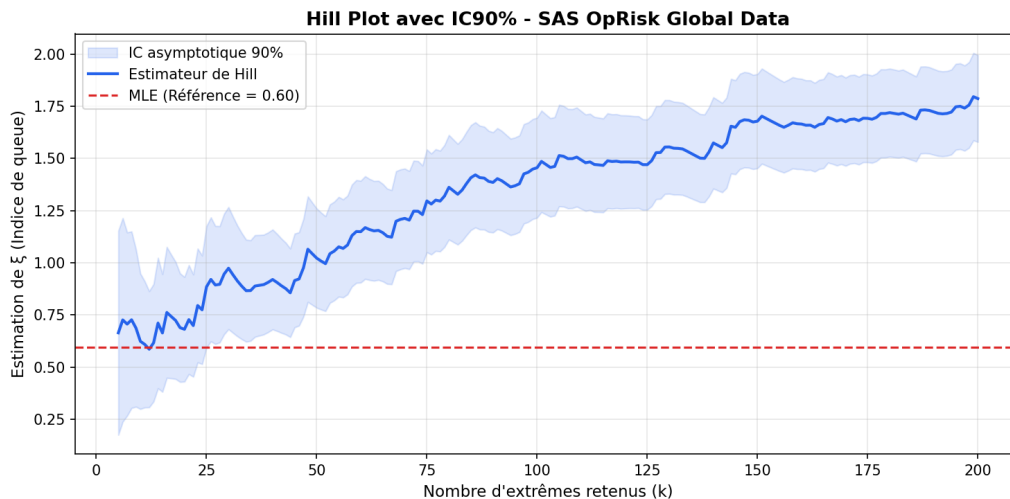


Figure 3. Hill plot avec intervalle de confiance asymptotique à 90 % sur OpRisk Global. La référence MLE ($\hat{\xi} \approx 0,595$, pointillés rouges) n'est statistiquement compatible avec l'estimateur de Hill que pour $k \lesssim 25$; au-delà, la dérive de $\hat{\xi}_{\text{Hill}}$ traduit le biais croissant lié à l'intégration d'observations hors du régime asymptotique pur de la queue.

infinie ($\xi \geq 1$), ce qui impose un plafond de sévérité opérationnel — fixé à 40 M€, ancré sur la capacité de réassurance cyber observable sur le marché — pour que la simulation reste numériquement stable; ce plafond ne s'applique qu'à la source PRC, la calibration OpRisk ($\xi < 1$, espérance finie) demeurant non plafonnée. L'écart entre les deux calibrations s'explique par le biais de taille d'OpRisk : les grandes entités financières y sont sur-représentées et absorbent mieux les chocs, d'où une queue apparemment plus légère. Les deux sources confirment néanmoins le même régime qualitatif de queue lourde ($\xi > 0$), et aucune hiérarchie de type « source primaire » n'est retenue entre elles — leur écart est traité comme une composante de l'incertitude totale du modèle, non comme un désaccord à trancher.

3.4 Dépendance : copule de Gumbel, contagion, modèle à facteur commun

Pourquoi l'indépendance est intenable. Une architecture purement additive des quatre briques, simulées indépendamment, ignorerait la discussion de contagion menée en 1.5 : une même dégradation de l'environnement cyber systémique θ tend à accroître simultanément la fréquence de remédiation, la probabilité de sanction (via le $PCD_i(\theta)$) et l'occurrence d'un événement prestataire. Traiter ces briques comme indépendantes sous-estimerait mécaniquement les quantiles extrêmes de la perte agrégée, précisément là où le capital réglementaire est évalué.

Modèle à facteur commun. La contagion *interne*, décrite en 1.5, est capturée par la structure factorielle de Vasicek déjà introduite pour le $PCD_i(\theta)$: le facteur θ agit comme un choc commun affectant simultanément la brique de remédiation (via la fréquence) et la brique de sanction (via le PCD_i). Ce choix évite d'introduire une seconde structure de dépendance ad hoc : le même θ qui module la conformité individuelle module également l'intensité de la sinistralité observée.

Copule de Gumbel pour la dépendance de queue. La contagion *externe*, portée par les tiers ICT, est en revanche mal représentée par une simple corrélation gaussienne : le risque prestataire se matérialise typiquement de façon conjointe avec les événements les plus extrêmes de remédiation, lors de chocs systémiques affectant un fournisseur mutualisé. Cette dépendance de queue positive est représentée par une copule de Gumbel, dont le paramètre $\eta \geq 1$ contrôle

l'intensité de la dépendance dans les scénarios extrêmes :

$$C_\eta(u, v) = \exp\left[-((- \ln u)^\eta + (- \ln v)^\eta)^{1/\eta}\right], \quad (34)$$

appliquée entre les rangs simulés de $L_{\text{remédiation}}$ et $L_{\text{prestataire}}$. Le cas $\eta = 1$ correspond à l'indépendance; des valeurs de η croissantes renforcent la probabilité que les deux briques réalisent simultanément une valeur extrême, conformément à l'intuition selon laquelle une crise cyber sectorielle majeure implique souvent à la fois une remédiation interne lourde et une défaillance de tiers.

Cette double structure — facteur commun de Vasicek pour la contagion interne, copule de Gumbel pour la contagion externe — permet de conserver une lecture économique distincte des deux canaux identifiés en 1.5, plutôt que de les fondre artificiellement dans une unique matrice de corrélation.

3.5 Agrégation Monte Carlo et allocation d'Euler

Simulation Monte Carlo. L'agrégation finale des quatre briques est réalisée par simulation Monte Carlo. À chaque itération : (i) un facteur systémique θ est tiré, déterminant le $PCD_i(\theta)$ de l'entité et la fréquence effective λ_{S_x} ou $\lambda(PCD_i)$; (ii) la fréquence de chaque vecteur est simulée par la binomiale négative calibrée en 3.2; (iii) la sévérité de chaque événement est tirée dans la GPD calibrée en 3.3, sous la source retenue (OpRisk ou PRC); (iv) la dépendance entre briques est imposée via la structure factorielle et la copule de Gumbel décrites en 3.4. Le recours à Monte Carlo n'est pas ici un simple choix technique : la grandeur recherchée n'est pas une perte moyenne, mais un quantile extrême de la distribution agrégée, dont la forme analytique n'existe pas sous une architecture à dépendance non gaussienne.

Allocation d'Euler. Une fois la perte agrégée simulée, il est nécessaire de répartir le capital total entre les quatre briques, pour identifier lesquelles contribuent le plus au risque extrême. L'allocation d'Euler, cohérente avec la propriété d'homogénéité de la VaR, répartit le capital total proportionnellement à la contribution marginale de chaque brique conditionnellement au scénario où la perte agrégée dépasse son quantile α :

$$AC_k = \mathbb{E}[L_k \mid L_{DORA} = VaR_\alpha(L_{DORA})], \quad \sum_k AC_k = VaR_\alpha(L_{DORA}), \quad (35)$$

pour $k \in \{\text{remédiation, sanction, prestataire, aggravation}\}$. En pratique, cette espérance conditionnelle est estimée numériquement par une fenêtre de tirages Monte Carlo au voisinage du quantile α recherché, faute de forme fermée pour l'architecture de dépendance retenue.

Le fondement de cette règle de partage n'est pas conventionnel : c'est la *seule* allocation compatible avec une mesure de performance ajustée du risque (RORAC), ce que formalise le résultat suivant.

Théorème 3.1 (Allocation d'Euler). *Soit ρ une mesure de risque positivement homogène de degré 1, différentiable, appliquée à une perte agrégée $L = \sum_{k=1}^d L_k$. Alors*

$$\rho(L) = \sum_{k=1}^d \underbrace{\frac{d}{dh} \rho(L + h L_k) \Big|_{h=0}}_{\text{contribution } AC_k}. \quad (36)$$

Pour $\rho = VaR_\alpha$, cette contribution vaut $AC_k = \mathbb{E}[L_k \mid L = VaR_\alpha(L)]$; pour $\rho = TVaR_\alpha$, $AC_k = \mathbb{E}[L_k \mid L \geq VaR_\alpha(L)]$. Dans les deux cas $\sum_k AC_k = \rho(L)$, et cette allocation est l'unique à satisfaire la compatibilité RORAC (Tasche, 1999).

Esquisse. L'homogénéité de degré 1, $\rho(tL) = t\rho(L)$, permet d'appliquer le théorème d'Euler sur les fonctions homogènes à ρ vue comme fonction des expositions $(h_1, \dots, h_d)$ via $\rho(\sum_k h_k L_k)$: la somme des dérivées partielles pondérées reconstitue ρ . Le calcul de la dérivée directionnelle pour VaR_α et TVaR_α (dérivation sous le signe espérance, régularité de la densité de L au voisinage du quantile) est reporté en Annexe A.10 ; l'unicité RORAC est due à Tasche (1999). ■

Ce théorème garantit que la décomposition présentée en Partie 5 (remédiation $\approx 86\%$, prestataire $\approx 14\%$, sanction $\approx 0\%$ sous OpRisk) est *additive et cohérente* : les contributions se somment exactement au capital total, sans résidu d'agrégation.

Formulaire synthétique du modèle SCR_DORA

Sévérité (POT/GPD)	$\mathbb{P}(X > x) = \zeta_u \left(1 + \frac{\xi(x-u)}{\sigma}\right)^{-1/\xi}, \quad x > u$
Capital mono-perte	$\text{VaR}_\alpha(X) = u + \frac{\sigma}{\xi} \left[((1-\alpha)/\zeta_u)^{-\xi} - 1 \right]$
Queue moyenne	$\text{TVaR}_\alpha(X) = \frac{\text{VaR}_\alpha}{1-\xi} + \frac{\sigma-\xi u}{1-\xi} \quad (\xi < 1)$
Fréquence	$N \sim \text{NegBin}(r, p), \quad \frac{\text{Var}(N)}{\mathbb{E}[N]} = 9,2$
Dépendance (Gumbel)	$C_\eta(u, v) = \exp(-[(-\ln u)^\eta + (-\ln v)^\eta]^{1/\eta}), \quad \lambda_U = 2 - 2^{1/\eta}$
Conformité (Vasicek)	$\text{PCD}_i(y) = \Phi((\Phi^{-1}(p) - \sqrt{\rho}y)/\sqrt{1-\rho})$
Agrégation	$L_{DORA} = L_{\text{rem}} + L_{\text{sanct}} + L_{\text{prest}}$
Allocation d'Euler	$AC_k = \mathbb{E}[L_k \mid L_{DORA} = \text{VaR}_\alpha], \quad \sum_k AC_k = \text{VaR}_\alpha$
Surcoût de conformité	$\Delta_{DORA} = \text{VaR}_\alpha(L_{DORA}^{nc}) - \text{VaR}_\alpha(L_{DORA}^c)$
Repère analytique (SLA)	$\text{VaR}_\alpha(S) \approx u + \frac{\sigma}{\xi} \left[((1-\alpha)/\lambda_{\text{eff}})^{-\xi} - 1 \right]$

Cette allocation permet de répondre à une question distincte de celle du niveau global de capital : non pas « combien faut-il provisionner ? », mais « quelle brique — remédiation, sanction, prestataire ou aggravation — consomme le plus de capital dans les scénarios extrêmes ? ». Cette décomposition est présentée et discutée en Partie 5, où elle est mise en regard des travaux antérieurs sur la structure du risque cyber.

4 Scénarios de conformité DORA

La Partie 3 a posé l'architecture de modélisation ; cette quatrième partie formalise la manière dont le niveau de conformité DORA se traduit concrètement dans les paramètres du modèle, puis se propage jusqu'à une mesure de surcoût de capital, le Δ_{DORA} .

4.1 Les trois niveaux de non-conformité

Le modèle retient trois scénarios-types de conformité, $S_x \in \{S_0, S_1, S_2\}$, qui bornent l'espace des situations observables sur le marché. S_0 correspond à une entité pleinement conforme aux cinq piliers DORA détaillés en 1.2 ; S_2 correspond à une situation de non-conformité totale ; S_1 représente une conformité partielle, intermédiaire entre les deux régimes précédents.

Ces trois scénarios ne sont pas de simples repères qualitatifs : ils ancrent les bornes numériques des multiplicateurs de fréquence calibrés en 4.3, et servent également de cas limites à l'interpolation continue portée par la variable latente $\text{PCD}_i(\theta)$ introduite en 1.4. Le scénario S_0 correspond ainsi à la limite $\text{PCD}_i(\theta) \rightarrow 0$, et S_2 à la limite $\text{PCD}_i(\theta) \rightarrow 1$, ce qui permet de faire cohabiter une lecture par scénarios de marché, utile pour la communication des résultats, et une

lecture par profil d'entité, plus fine, mobilisée dans les applications individuelles du modèle.

4.2 Mapping vecteurs d'attaque → exigences DORA

La fréquence de référence $\lambda_{ref} = 341$ incidents/an, calibrée sur la PRC, est décomposée en sous-fréquences par vecteur d'attaque, pondérées par la structure observée dans Hackmageddon (1 041 incidents, S1 2026) et reliées explicitement à l'article DORA censé les atténuer :

Vecteur	π_v	Exigence DORA atténuante
Phishing / ingénierie sociale	38,8 %	Art. 13 — Sensibilisation & formation
Exploitation de vulnérabilités	33,8 %	Art. 26 — Tests TLPT
Supply chain / tiers ICT	15,8 %	Art. 28-44 — Gestion du risque tiers
Identifiants compromis	6,3 %	Art. 9 — Contrôle d'accès et MFA
Autres / transverse	5,3 %	—

Cette décomposition transforme un constat structurel — la part de chaque vecteur dans la sinistralité observée — en un levier de modélisation directement actionnable : un défaut de conformité sur une exigence donnée n'agit que sur la sous-fréquence du vecteur qu'elle est censée mitiger, et non sur l'ensemble de λ_{ref} . Cette granularité est ce qui distingue l'approche retenue d'un simple chargement multiplicatif global appliqué à la sinistralité totale.

4.3 Multiplicateurs de fréquence différenciés par exigence

Sous un scénario S_x , chaque vecteur v se voit appliquer un multiplicateur m_{v,S_x} , non pas une valeur ponctuelle mais un **intervalle** $[m_{min}, m_{max}]$, dont les bornes sont ancrées sur la littérature empirique relative à l'efficacité des contrôles de sécurité correspondants.

Phishing (Art. 13). Ponemon/IBM *Cost of a Data Breach 2025* établit que la formation des employés peut réduire le risque jusqu'à 86 %, avec un retour sur investissement médian de 5 fois. Cette mesure étant agrégée sur l'ensemble des incidents et non spécifique au phishing, nous n'en retenons pas l'inverse littéral, mais une fraction prudente de cet effet : $[1,8 ; 3,0]$ en scénario S_2 .

Exploitation de vulnérabilités (Art. 26). ENISA *Threat Landscape 2025* (4 875 incidents, périmètre européen) mesure un taux de conversion tentative-vers-intrusion de 70 % pour l'exploitation de vulnérabilités contre 27 % pour le phishing, soit un ratio directement observé de $\times 2,6$ — la seule borne de la grille fondée sur une probabilité de succès conditionnelle mesurée par un organisme réglementaire. Elle ancre l'intervalle $[2,0 ; 2,6]$ en S_2 .

Supply chain et tiers ICT (Art. 28-44). IBM/Ponemon mesurent un surcoût de 11,8 % pour les brèches impliquant un partenaire commercial et de 8,3 % pour celles impliquant une compromission logicielle ; SecurityScorecard documente une part des brèches d'origine tierce passée de 15 % à 36 % en une année. La combinaison de ce surcoût mesuré et de cette tendance de marché donne l'intervalle $[1,9 ; 2,6]$ en S_2 .

Identifiants compromis (Art. 9). Microsoft Research (arXiv :2305.00945, étude *peer-reviewed* sur comptes Azure Active Directory réels) établit que l'authentification multifacteur réduit le risque de compromission de 99,22 % en population générale, et de 98,56 % même en cas de fuite préalable des identifiants. Il s'agit de la mesure la plus rigoureuse de la grille, mais aussi la plus susceptible d'être mal transposée à l'échelle d'une entité financière hétérogène : nous en retenons des bornes tempérées, $[3,0 ; 8,0]$ en S_2 — les plus élevées de la grille, sans reproduire l'inversion littérale que le 99,22 % suggérerait naïvement.

Vecteur	π_v	S_1 partiel	S_2 non conforme
Phishing	38,8 %	$[1,2 ; 1,6]$	$[1,8 ; 3,0]$
Exploit. vuln.	33,8 %	$[1,3 ; 1,8]$	$[2,0 ; 2,6]$
Supply chain	15,8 %	$[1,3 ; 1,9]$	$[1,9 ; 2,6]$
Identifiants	6,3 %	$[1,5 ; 3,0]$	$[3,0 ; 8,0]$

Le principe central : l'intervalle, pas le point. Pour chaque itération de simulation, un multiplicateur m_{v,S_x} est **tiré uniformément** dans son intervalle — jamais fixé à une valeur unique. Cette discipline, appliquée dès la calibration des hypothèses et non seulement en sortie de modèle, permet de propager une incertitude de *calibration*, et non la seule incertitude d'échantillonnage, jusqu'au résultat final.

Sous ce cadre, la fréquence effective sous un scénario S_x s'écrit :

$$\lambda_{S_x} = \sum_v \lambda_{ref} \times \pi_v \times m_{v,S_x}, \quad (37)$$

puis se propage dans la binomiale négative selon le mécanisme de sur-dispersion constante ($\phi = 9,2$) détaillé en 3.2.

4.4 Propagation et Δ_{DORA} : distribution, pas un point

Les résultats obtenus, pour $\alpha = 99,5$ %, sous les deux sources de sévérité, sont les suivants :

Source	Scénario	Δ_{DORA} médiane	IC90 %
PRC	S_1 partiel	720,9 M€	$[555,7 ; 895,5]$ M€
PRC	S_2 non conforme	2 014,7 M€	$[1 606,9 ; 2 366,1]$ M€
OpRisk	S_1 partiel	1 514,4 M€	$[522,5 ; 7 863,2]$ M€
OpRisk	S_2 non conforme	3 879,3 M€	$[1 496,9 ; 22 249,3]$ M€

Sous PRC, un défaut de conformité DORA se traduit par une charge de capital quantifiée et non simplement qualitative : le passage de S_1 à S_2 accroît le Δ_{DORA} médian d'un facteur 2,8 (720,9 à 2 014,7 M€), cohérent avec le rapport des multiplicateurs globaux de fréquence entre les deux scénarios. Ce Δ_{DORA} mesure le surcoût strict de capital imputable au défaut de conformité, à profil de risque constant (contrefactuel à graine figée).

Sous OpRisk, le même défaut de conformité produit un Δ_{DORA} du même ordre de grandeur : 1 514,4 M€ en S_1 et 3 879,3 M€ en S_2 , soit un facteur proche de 1,9 par rapport à la PRC sur S_2 .

Ce résultat est notable : une fois la PRC calibrée de bout en bout sur les données brutes (et non plus sur des paramètres externes non reproduits), les deux sources indépendantes *convergent* bien davantage qu’anticipé — l’écart de niveau entre sources (facteur 1,9) devient comparable à l’écart entre scénarios de conformité sous une même source (facteur 2,6 de S_1 à S_2 sous OpRisk). Ce qui distingue encore nettement les deux sources n’est plus le *niveau* du capital mais son *incertitude* : l’IC90% OpRisk s’étend sur un facteur 15 entre bornes (bootstrap de seulement 91 excès), là où l’IC PRC, appuyé sur 2 258 excès et une sévérité lissée par la conversion Jacobs, reste beaucoup plus resserré (cf. section suivante).

4.5 Bootstrap et intervalles de confiance

La distribution du Δ_{DORA} est obtenue par un bootstrap à deux niveaux, combiné à une architecture Monte Carlo.

1. **Niveau 1 — incertitude des multiplicateurs.** À chaque itération, un jeu de multiplicateurs $\{m_{v,S_x}\}$ est tiré dans les intervalles sourcés en 4.3, produisant un λ_{S_x} lui-même aléatoire plutôt que fixé.
2. **Niveau 2 — incertitude de sévérité.** Un couple $(\hat{\xi}, \hat{\sigma})$ est obtenu par rééchantillonnage bootstrap des excès réels, *pour les deux sources* : pour OpRisk, sur les 91 excès observés au-dessus du seuil $u = 20$ M€(périmètre cyber×finance de 582 incidents) ; pour la PRC, sur les 2 258 excès de la sévérité dérivée de la conversion Jacobs au-dessus du seuil $u = 4,18$ M€(15 053 incidents 2019–2025). L’incertitude de sévérité PRC est ainsi elle aussi *data-driven*, quoique plus resserrée : la conversion Jacobs, en traduisant de façon déterministe le nombre d’enregistrements en montant, lisse mécaniquement la variance de sévérité.
3. **Simulation Monte Carlo.** Pour chaque tirage des niveaux 1 et 2, le modèle LDA est simulé pour obtenir SCR_{S_0} et SCR_{S_x} , avec la **même graine** de simulation pour les deux régimes, condition méthodologique centrale garantissant que l’écart observé provient uniquement du changement de conformité et non de la variance d’échantillonnage Monte Carlo (principe des *common random numbers*).
4. **Résultat.** $\Delta_{DORA} = SCR_{S_x} - SCR_{S_0}$ est accumulé sur l’ensemble des tirages, produisant un intervalle de confiance plutôt qu’un point.

Asymétrie des intervalles. L’intervalle de confiance associé à la source OpRisk est nettement plus large que celui de la source PRC (facteur proche de 15 contre facteur proche de 1,5 sur S_2). Cette asymétrie n’est pas un artefact et — depuis la recalibration de la PRC sur ses données brutes — ne provient plus d’un bootstrap PRC *incomplet* : les deux sources intègrent désormais l’incertitude de sévérité mesurée par rééchantillonnage réel (2 258 excès pour la PRC, 91 pour OpRisk). L’écart d’amplitude tient à deux causes structurelles. D’une part, le nombre d’excès : OpRisk ne dispose que de 91 observations de queue, contre 2 258 pour la PRC, si bien que le rééchantillonnage OpRisk fait varier $(\hat{\xi}, \hat{\sigma})$ bien davantage. D’autre part, la nature de la sévérité PRC : la conversion Jacobs, transformation *déterministe* du nombre d’enregistrements en montant, lisse mécaniquement la variance de sévérité. L’intervalle PRC est donc plus resserré, non parce qu’il ignore l’incertitude de sévérité, mais parce que cette incertitude y est intrinsèquement plus faible — une nuance reprise dans la décomposition de l’incertitude en Partie 5.

Comparaison méthodologique : limites des approches standards face au risque cyber

L'introduction d'un Modèle Interne Partiel (LDA) stochastique, tel que développé dans ce mémoire, représente un investissement méthodologique lourd pour un assureur. Pour en justifier la pertinence, il convient de le confronter aux deux méthodes traditionnellement utilisées sur la place pour évaluer le risque opérationnel : l'approche forfaitaire de la Formule Standard (Pilier 1) et l'approche déterministe par scénarios (historiquement privilégiée dans l'ORSA, Pilier 2). L'application de nos propres données de calibration à ces méthodes permet d'en démontrer les limites structurelles face à la nature du risque cyber.

4.6 La Formule Standard (Solvabilité II) : une mesure aveugle à la résilience

Dans le cadre de la Formule Standard de Solvabilité II (Article 204 du Règlement Délégué 2015/35), le risque cyber n'est pas isolé : il est noyé dans le module global du risque opérationnel (SCR_{Op}).

Rappel mathématique. L'exigence de capital pour le risque opérationnel est calculée selon une approche modulaire, plafonnée à 30 % de l'exigence de capital de base ($BSCR$). En omettant la composante liée aux risques en unités de compte (Exp_{ul}), la formule se résume principalement à une fonction linéaire des primes acquises ($Earned_{premiums}$) et des provisions techniques (TP) :

$$SCR_{Op} \approx \min \left(0,3 \times BSCR ; \max(0,04 \times Earned_{premiums} ; 0,045 \times TP) \right) \quad (38)$$

(Note : la formule complète intègre également une pénalité marginale pour les croissances de primes annuelles supérieures à 20 %, que nous omettons ici par souci de clarté).

Démonstration numérique. Appliquons cette formule à l'entité-type systémique utilisée pour le calibrage de nos résultats finaux (Partie 5), générant un volume de primes (Chiffre d'Affaires) de 15 000 M€. En appliquant le coefficient simplifié de 4 %, la charge de capital pour l'intégralité de ses risques opérationnels s'élève à :

$$SCR_{Op} = 0,04 \times 15\,000 = 600 \text{ M€} \quad (39)$$

La confrontation avec notre modèle LDA-EVT est révélatrice. Sous la calibration PRC (plafonnée à 40 M€ par sinistre, sévérité dérivée de la conversion Jacobs), la VaR 99,5 % pour une entité médiane est de **2 772,7 M€**, soit déjà plus de quatre fois le forfait de Pilier 1 (600 M€). Face à la calibration OpRisk (capturant le risque extrême sans plafond, sur des montants réellement observés), la VaR atteint **9 259,5 M€**. La Formule Standard sous-estime ainsi le risque de queue réel d'un facteur compris entre 4,6 (PRC) et 15 (OpRisk) pour cette entité systémique — et c'est cette convergence des deux sources indépendantes vers un même verdict (un capital cyber en milliers de M€, très au-delà du Pilier 1), bien plus qu'un chiffre unique, qui constitue le message actuariel central du mémoire (cf. Partie 5).

Synthèse comparative. Le tableau ci-dessous résume cette confrontation pour notre entité de 15 000 M€ de CA, en observant le gain de capital obtenu en passant d'un profil non-conforme S_2 à un profil conforme S_0 .

Méthode d'évaluation	SCR Estimé (Médian)	Sensibilité DORA (Δ_{DORA})	Limites structurelles
Formule Standard (Pilier 1)	600,0 M€	0,0 M€	Aveugle à la résilience (aléa moral), sous-estimation extrême de la queue
Déterministe (ORSA classique)	200,0 M€	Difficile à quantifier	Biais d'ancrage expert, ignore l'agrégation et la contagion
Modèle Interne Partiel (LDA – PRC)	2 772,7 M€	2 014,7 M€	Nécessite un plafonnement opérationnel (espérance infinie)
Modèle Interne Partiel (LDA – OpRisk)	9 259,5 M€	3 879,3 M€	Biais de taille lié aux grandes entités financières historiques

4.7 L'approche par scénarios déterministes (ORSA) : l'illusion de la précision

Pour pallier les lacunes de la Formule Standard, les assureurs s'appuient traditionnellement sur le Pilier 2 (ORSA) pour évaluer leurs risques extrêmes, souvent via une approche déterministe dite « à dire d'expert ».

Mécanique de l'approche déterministe. Le Directeur des Risques et le Responsable de la Sécurité des Systèmes d'Information (RSSI) définissent de concert un « scénario catastrophe ». Par exemple : « *Une attaque par rançongiciel paralyse nos serveurs centraux pendant 5 jours, entraînant une perte d'exploitation, des coûts d'investigation et de notification.* » Les experts chiffrent ce scénario poste par poste, aboutissant à une perte ponctuelle, par exemple de 80 M€, qui est alors provisionnée comme exigence de capital.

Le biais de cognition face à la queue lourde. Si cette méthode présente l'avantage d'être hautement « lisible » pour la Direction Générale, nos données empiriques en démontrent la dangerosité statistique. L'expertise humaine a tendance à s'ancrer sur des moyennes ou des événements récents mémorisables. Dans la base SAS OpRisk Global, la moyenne des sinistres cyber est de 26,4 M€. Un expert fixant un scénario de crise à 80 M€ (soit 3 fois la moyenne) pensera légitimement faire preuve d'un grand conservatisme.

Pourtant, l'analyse par la Théorie des Valeurs Extrêmes (EVT) menée en Partie 3 prouve le contraire. L'ajustement de la distribution de Pareto Généralisée (GPD) sur les données OpRisk a révélé un indice de queue $\hat{\xi} = 0,595$, caractéristique d'un régime à queue lourde extrême. Empiriquement, la base documente un sinistre maximum à **1 500 M€**. En se contentant d'un scénario expert à 80 M€, l'assureur ignore la forme asymptotique de la distribution et ne provisionne absolument pas le quantile à 99,5 % exigé par la directive.

La supériorité de la simulation Monte-Carlo. L'approche déterministe présente deux autres limites majeures que notre modèle LDA résout :

- **La dépendance temporelle et l'agrégation :** Le scénario d'expert calcule le coût d'un incident isolé. Or, la VaR 99,5 % est une mesure annuelle. L'approche Monte-Carlo, en combinant des tirages de fréquence (loi binomiale négative) et de sévérité (GPD), permet d'explorer des années simulées où un sinistre majeur coïncide avec une myriade d'incidents

d'attrition de taille moyenne, engendrant une perte agrégée supérieure à la simple addition déterministe.

- **La contagion externe (Tiers ICT) :** Un scénario construit en silo ignore la probabilité d'occurrence conjointe. L'introduction de la **copule de Gumbel** dans notre architecture permet de modéliser mathématiquement ce qu'un expert peine à quantifier : la survenance d'une crise systémique de marché (θ fortement négatif) qui déclenche à la fois la défaillance d'un fournisseur cloud critique et des failles internes.

Conclusion sur les méthodes. L'approche déterministe donne l'illusion de la précision en produisant un chiffre unique (ex : 80 M€), mais échoue à capturer le véritable risque de ruine. À l'inverse, l'approche stochastique développée dans ce mémoire assume l'incertitude (en produisant des intervalles de confiance par *bootstrap*) et capture mathématiquement la réalité du risque cyber : une fréquence corrélée à l'environnement, une sévérité à queue lourde, et des pertes agrégées hautement non linéaires face à la qualité de la conformité DORA.

5 Résultats et discussion

Les quatre parties précédentes ont posé le cadre, les données, le moteur de simulation et les scénarios de conformité. Cette cinquième partie présente les résultats numériques obtenus, leur décomposition par source d'incertitude et par brique de perte, et leur mise en perspective avec la littérature existante et le pilotage prudentiel.

Paramètre	Valeur	Source / Justification
Fréquence (Loi Binomiale Négative)		
Fréquence de base (λ_{ref})	341 inc./an	PRC (Proxy sectoriel US)
Sur-dispersion (ϕ)	9,2	Fixée pour maintenir la forme de variance
Sévérité (GPD POT)		
Seuil OpRisk (u)	20 M€	Analyse MEP et stabilité ξ
Seuil PRC (u)	4,18 M€	Percentile 85 (sévérité dérivée Jacobs)
Indice de queue ($\hat{\xi}_{OpRisk}$)	0,595	MLE sur OpRisk (Moments finis)
Indice de queue ($\hat{\xi}_{PRC}$)	1,03	Conversion Jacobs (Espérance infinie)
Plafond opérationnel PRC	40 M€	Capacité maximale réassurance
Dépendance & Variables latentes		
Paramètre Gumbel (θ_{Gumbel})	1,5	Dépendance de queue supérieure modérée
Sensibilité systémique ($\rho_{Vasicek}$)	0,2 à 0,8	Calibré selon la criticité de l'entité

Table 1. Récapitulatif des paramètres centraux du modèle de simulation.

5.1 Distribution du SCR_DORA : ancrage sur une entité de 15 000 M€

Pour ancrer les quantiles simulés dans une réalité bilancielle et évaluer le risque de ruine, l'ensemble des modélisations a été exécuté sous l'hypothèse d'une entité de référence générant

un Chiffre d’Affaires (CA) annuel de **15 000 M€** (assureur ou bancassureur de dimension européenne).

Le capital total à l’horizon 99,5 % ($VaR_{99,5\%}$) et l’Expected Shortfall ($ES_{99,5\%}$) varient très fortement selon la source de sévérité retenue et le profil de conformité de l’entité.

Source	Profil	VaR 99,5 %	ES 99,5 %	Ratio VaR/CA	Ratio ES/CA
PRC	Leader	1 778,7 M€	1 883,8 M€	11,86 %	12,56 %
PRC	Médian	2 772,7 M€	2 910,3 M€	18,48 %	19,40 %
PRC	Retardataire	3 724,3 M€	3 886,9 M€	24,83 %	25,91 %
OpRisk	Leader	6 420,7 M€	14 255,0 M€	42,80 %	95,03 %
OpRisk	Médian	9 259,5 M€	20 023,2 M€	61,73 %	133,49 %
OpRisk	Retardataire	10 992,4 M€	21 720,1 M€	73,28 %	144,80 %

Le SCR_DORA se situe ainsi dans une fourchette globale de **1 779 M€ à près de 21 720 M€** selon la source, le profil de conformité et la mesure de risque retenue.

Plausibilité économique et risque de ruine. La lecture des ratios relatifs au Chiffre d’Affaires est particulièrement éloquent. Sous la calibration OpRisk, l’Expected Shortfall d’une entité non-conforme atteint **144,80 %** de son CA annuel ; même sous la calibration PRC, plus modérée, l’entité retardataire mobilise près de **26 %** de son CA en capital. En assurance classique, un sinistre dépassant le chiffre d’affaires est rare ; en risque cyber, une telle valeur traduit mathématiquement un risque de ruine certain de l’entité. Plutôt que d’invalider le modèle, ces montants confirment que la distribution sous-jacente (GPD à queue lourde, $\hat{\xi} \geq 0,6$ sous les deux sources) modélise un régime de pertes qui outrepassse la capacité d’absorption financière stricte d’une institution individuelle. C’est précisément ce constat actuariel qui justifie la philosophie du règlement DORA : imposer la résilience technique *ex-ante* face à un risque dont l’impact *ex-post* est financièrement intenable.

Cet écart, d’un facteur proche de **12** entre la borne basse (PRC, profil leader, VaR) et la borne haute (OpRisk, profil retardataire, ES), demeure important, mais il s’est *fortement resserré* par rapport à la calibration PRC externe utilisée dans une version antérieure de ce travail (où il atteignait un facteur 65). Ce resserrement est un résultat en soi : une fois la PRC recalibrée de bout en bout sur ses données brutes (conversion Jacobs sur 15 053 incidents, cf. Partie 2), les deux sources *indépendantes* convergent sur le même diagnostic — un capital cyber se comptant en milliers de M€, très au-delà du forfait de Pilier 1. La divergence résiduelle relève de l’incertitude légitime entre deux périmètres distincts, non d’un désaccord de fond. Le SCR cyber ne peut donc toujours pas être communiqué comme un point, mais la fourchette inter-sources est désormais mieux maîtrisée.

Ce facteur 12 s’explique par le traitement de la queue de distribution OpRisk : le paramètre de forme $\hat{\xi}_{OpRisk} = 0,595 < 1$ garantissant une espérance finie (cf. Partie 2), aucun plafonnement de la sévérité par sinistre n’y est appliqué, à la différence de la PRC ($\hat{\xi}_{PRC} = 1,03 \geq 1$, espérance infinie, où le plafond de 40 M€ reste nécessaire à la stabilité numérique de la simulation, cf. Partie 2.4). Le capital simulé sous OpRisk reflète ainsi directement les événements extrêmes réellement observés dans cette base (jusqu’à 1 500 M\$ par sinistre), dont la calibration GPD elle-même annonçait un $VaR_{99,5\%}$ *par sinistre* de 662,8 M€ — déjà bien au-delà de tout plafond de 40 M€.

La figure 4 illustre la forme de la distribution agrégée des pertes sous le régime OpRisk le plus sévère : une masse concentrée aux faibles montants, prolongée d’une queue extrêmement lourde qui repousse la VaR 99,5 % très loin dans la distribution, matérialisant graphiquement le poids désormais dominant des scénarios extrêmes dans la constitution du capital.

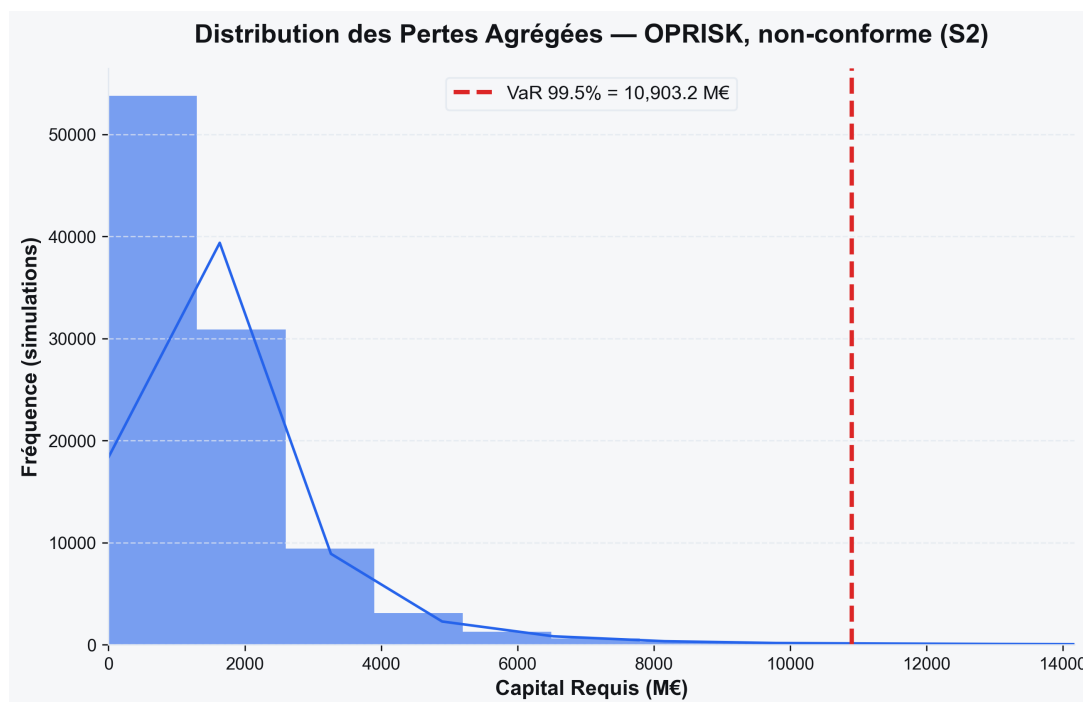


Figure 4. Distribution simulée des pertes agrégées (SCR cyber), source de sévérité OpRisk, scénario de non-conformité totale S_2 . La VaR 99,5 % (pointillés rouges) est repoussée très à droite de la masse principale, signature de la queue lourde non plafonnée. La valeur exacte de la VaR dépend du profil de conformité et du scénario retenus (cf. tableau ci-dessus).

5.2 Décomposition de l’incertitude (variance par source)

Trois sources distinctes d’incertitude se superposent dans les résultats présentés, et leur hiérarchie — resserrée après la recalibration en propre de la PRC — est elle-même un résultat central du mémoire.

Le choix de source de sévérité reste le premier facteur, mais d’un poids désormais comparable à celui de la conformité. Entre PRC et OpRisk, pour un même profil et une même mesure de risque, le capital total varie d’un facteur proche de **3,3** (par exemple 2 772,7 M€ contre 9 259,5 M€ pour le profil médian en VaR). Cet écart demeure supérieur au facteur associé au profil de conformité de l’entité (cf. paragraphe suivant), mais il n’en est plus séparé d’un ordre de grandeur : c’est un changement notable par rapport à une version antérieure de ce travail, où une calibration PRC issue de paramètres externes non reproduits sur les données brutes conduisait à un facteur inter-sources de 19. Une fois la PRC recalibrée de bout en bout (conversion Jacobs $\ln(L) = 7,68 + 0,76 \ln(X)$ sur les 15 053 incidents 2019–2025, $\hat{\xi}_{\text{PRC}} = 1,03$), l’écart de niveau entre sources se réduit à un facteur 3, l’essentiel de l’ancien écart provenant d’une sous-estimation de l’échelle de sévérité PRC plutôt que d’une divergence de fond entre les deux bases. La différence résiduelle s’explique par l’écart de régime de queue ($\hat{\xi}_{\text{PRC}} = 1,03$ avec plafond à 40 M€ contre $\hat{\xi}_{\text{OpRisk}} = 0,595$ sans plafond) et par le biais de taille d’OpRisk, qui documente des sinistres extrêmes (jusqu’à 1 500 M\$) que la sévérité PRC, plafonnée, ne peut restituer.

Le profil de conformité de l'entité conserve un effet net, d'un ordre désormais voisin de celui du choix de source. Sous la source OpRisk, le passage du profil leader au profil retardataire fait passer le capital de 6 420,7 à 10 992,4 M€ en VaR, soit un facteur 1,71 ; sous PRC, le même passage fait passer le capital de 1 778,7 à 3 724,3 M€, soit un facteur 2,09. Ces facteurs, proches entre les deux sources, confirment la robustesse *qualitative* de l'effet de conformité, indépendamment du niveau absolu de sévérité retenu : quelle que soit la source de calibration, un profil de conformité dégradé multiplie le capital requis par un facteur de l'ordre de 1,7 à 2,1. Cette stabilité du facteur de conformité illustre que le modèle capture deux informations de nature différente — une sensibilité relative au profil, robuste au choix de calibration, et un niveau absolu, qui l'est moins mais dont l'écart inter-sources s'est lui aussi resserré.

L'environnement systémique amplifie la sensibilité au profil. La comparaison des scénarios $\theta = 0$ et $\theta = -2,5$ (choc cyber sectoriel négatif) montre que la dégradation de l'environnement systémique accroît le capital de toutes les entités, mais de façon différenciée : le profil leader, sous OpRisk, voit son capital de base (6 420,7 M€) s'accroître sous l'effet du choc, alors que son PCD passe de 0,0045 à 0,385 — une sensibilité au facteur commun directement héritée de la structure de Vasicek introduite en 1.4. Sous PRC, l'effet est de même ampleur. Le profil retardataire, déjà proche de $PCD = 1$ en régime normal, ne peut en revanche plus se dégrader significativement sous le choc (augmentation marginale sous OpRisk comme sous PRC), ce qui traduit un effet de saturation cohérent avec la forme de la fonction de lien Φ .

La figure 5 rend visible ce mécanisme sur la fréquence de sinistralité elle-même : à mesure que l'environnement se dégrade (θ décroissant), la fréquence de l'entité médiane croît fortement pour rejoindre celle de l'entité en retard, tandis que le profil leader reste quasi insensible au choc. C'est cette différenciation de sensibilité, et non un simple décalage de niveau, qui constitue l'apport de la structure de Vasicek.

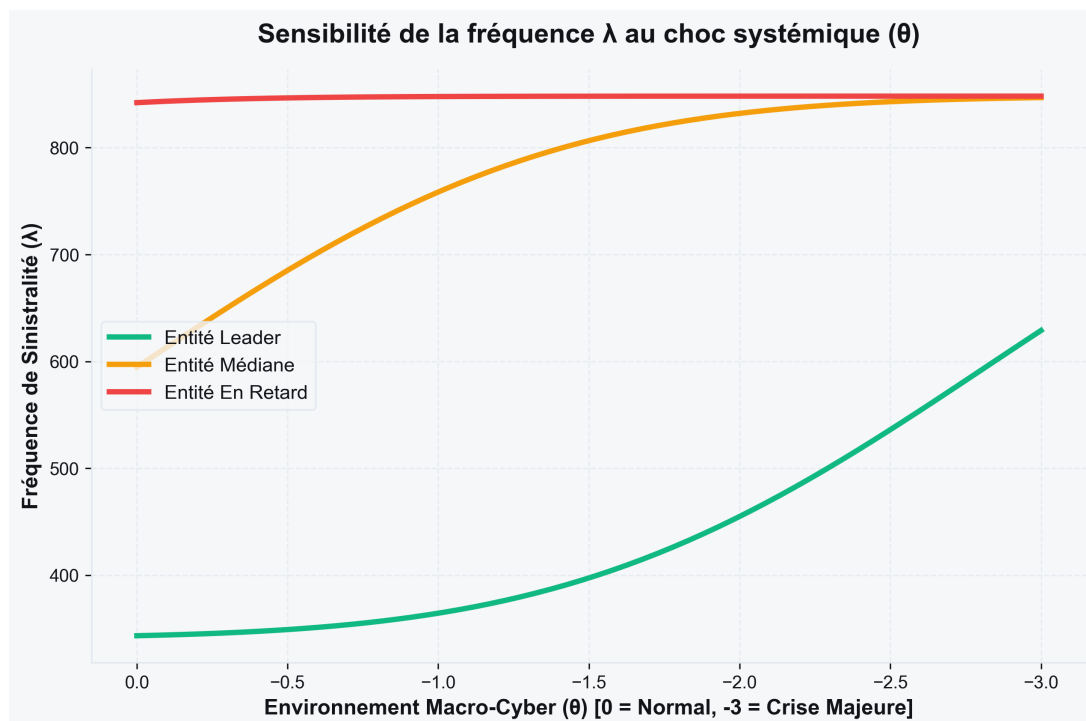


Figure 5. Sensibilité de la fréquence de sinistralité λ au choc systémique θ , par profil d'entité. Le profil leader (vert) reste quasi plat ; le profil médian (orange) rattrape le profil en retard (rouge) sous un choc sévère, illustrant l'effet de contagion différenciée hérité du modèle à facteur unique. L'axe des abscisses va de $\theta = 0$ (environnement normal) à $\theta = -3$ (crise majeure).

5.3 Allocation d'Euler : contribution de chaque brique

Cette décomposition révèle un enseignement qui n'apparaissait pas dans une version antérieure du moteur, où la brique prestataire était calibrée sur une échelle absolue (Lognormale, médiane ≈ 5 M€) indépendante de la source de sévérité active. Cette échelle absolue fixe entrait en conflit avec la remédiation dès que la source active portait sa sévérité sur une échelle différente, écrasant artificiellement la remédiation — y compris après plafonnement symétrique des deux briques à 40 M€, le problème n'étant pas la queue mais le corps de la distribution. La brique prestataire est donc désormais calibrée comme un **surcoût relatif** sur la sévérité de remédiation active plutôt qu'une échelle absolue fixe : IBM/Ponemon *Cost of a Data Breach 2025* mesure un surcoût de 8,3 % à 11,8 % lorsqu'un tiers est impliqué dans l'incident, fourchette tirée uniformément comme les multiplicateurs DORA (Partie 4.3). Cette reformulation restaure la commensurabilité entre briques *et* entre sources : la brique prestataire suit désormais l'échelle de la source active, au lieu d'importer une échelle étrangère au régime simulé.

Sous les deux sources, la brique de **remédiation** domine nettement (83,1 à 86,1 % du capital selon le profil et la source), suivie par le **prestataire** (13,9 à 16,9 %). L'écart entre PRC et OpRisk sur cette décomposition est désormais faible (moins de 3 points sur chaque brique) : les deux sources, bien que très différentes en niveau absolu (cf. 5.1–5.2), s'accordent maintenant sur la *structure* du risque une fois les briques rendues commensurables. C'est un résultat plus robuste, et plus conforme à l'intuition actuarielle, que l'inversion PRC/OpRisk observée avant cette correction.

La contribution de la **sanction** reste, sous les deux sources, très en retrait (inférieure à 1 % sous PRC, inférieure à 0,1 % sous OpRisk), en cohérence avec le poids structurellement borné du montant réglementaire face aux deux autres briques.

La figure 6 synthétise visuellement cette hiérarchie. On observe que le risque physique (remédiation) concentre l'essentiel du capital sous les deux sources (83 à 86 %), le risque tiers (prestataire) en représentant une part minoritaire mais non négligeable (14 à 17 %) ; la sanction reste marginale sous les deux sources.

Effet du plafond de sanction. Une analyse de sensibilité complémentaire confirme le caractère marginal de la brique de sanction dans le capital total, y compris après correction du moteur. Le doublement du plafond réglementaire de l'amende, de 20 M€ à 40 M€, ne déplace que très faiblement la VaR 99,5 % : l'effet maximal observé reste inférieur à 7 M€ (6,9 M€ sous OpRisk et 4,4 M€ sous PRC), y compris pour le profil retardataire subissant un taux de non-conformité extrême — un effet d'autant plus négligeable en proportion que le capital total sous OpRisk se compte désormais en milliers de millions d'euros.

Source	Profil	VaR base (plafond 20 M€)	VaR stress (plafond 40 M€)	Δ VaR
OpRisk	Leader	6 420,7 M€	6 420,7 M€	0,0 M€
OpRisk	Médian	9 259,5 M€	9 260,3 M€	0,9 M€
OpRisk	Retardataire	10 992,4 M€	10 999,3 M€	6,9 M€
PRC	Leader	1 778,7 M€	1 778,7 M€	0,0 M€
PRC	Médian	2 772,7 M€	2 775,5 M€	2,9 M€
PRC	Retardataire	3 724,3 M€	3 728,7 M€	4,4 M€

Cette insensibilité confirme un message central du mémoire pour le pilotage : le capital cyber

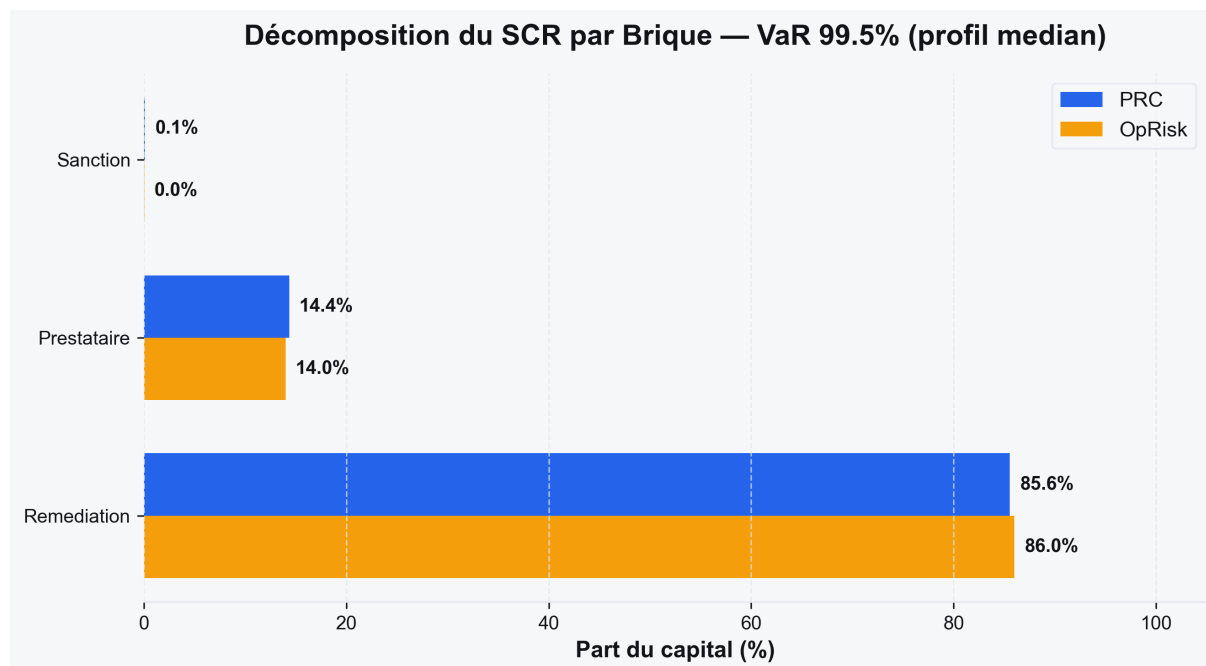


Figure 6. Décomposition du SCR (VaR 99,5 %) par brique, sous les deux sources de sévérité (profil médian, $\theta = 0$). La brique de remédiation domine sous les deux sources (85 à 86 %) ; le prestataire, désormais calibré en surcoût relatif sur la sévérité de remédiation active, représente une part minoritaire et cohérente entre sources (14 %).

répond à un risque *opérationnel* (fréquence et sévérité des incidents), et non à un risque de *sanction* administrative, dont l'impact financier demeure borné par sa structure réglementaire et négligeable face à la queue lourde des pertes techniques, sous les deux sources.

5.4 Analyse de sensibilité aux hypothèses porteuses

Le modèle mobilise des paramètres de statut épistémique hétérogène : certains sont *calibrés sur données* et assortis d'un intervalle de confiance (l'indice de queue $\hat{\xi}$ et l'échelle $\hat{\sigma}$ de la GPD, dont l'IC90% est obtenu par bootstrap, cf. Partie 2) ; d'autres sont des *hypothèses libres*, ancrées sur proxies ou avis d'expert et non estimées faute de données conditionnelles à la conformité (la corrélation systémique γ du modèle de Vasicek, la non-conformité de référence p_{ref} , les bornes des multiplicateurs de fréquence, la surcharge tiers, la sur-dispersion φ , le paramètre de la copule). La légitimité du modèle exige de mesurer *combien* chacun de ces leviers pèse réellement sur le capital, plutôt que de se contenter de les déclarer incertains.

Nous perturbons donc chaque paramètre sur une plage plausible et documentée, toutes choses égales par ailleurs, et mesurons la réponse de la VaR 99,5 % autour du cas de référence (OpRisk, profil médian, $\theta = 0$, soit un SCR de base de 9 259 M€). La figure 7 classe les paramètres par amplitude d'effet (*tornado*).

Un résultat qui conforte la thèse du mémoire. La hiérarchie est sans appel et va dans le sens de tout le reste du travail :

- l'indice de queue $\hat{\xi}$ domine *massivement* : sur son seul IC90% bootstrap [0,30 ; 0,83], la VaR passe de 3 073 à 32 312 M€, soit une amplitude de plus de 300 % du SCR de base — à lui seul, le paramètre de queue peut multiplier le capital par dix ;
- l'échelle $\hat{\sigma}$ vient ensuite ($\pm 69\%$) ; les deux paramètres calibrés sur données concentrent ainsi l'essentiel de l'incertitude ;

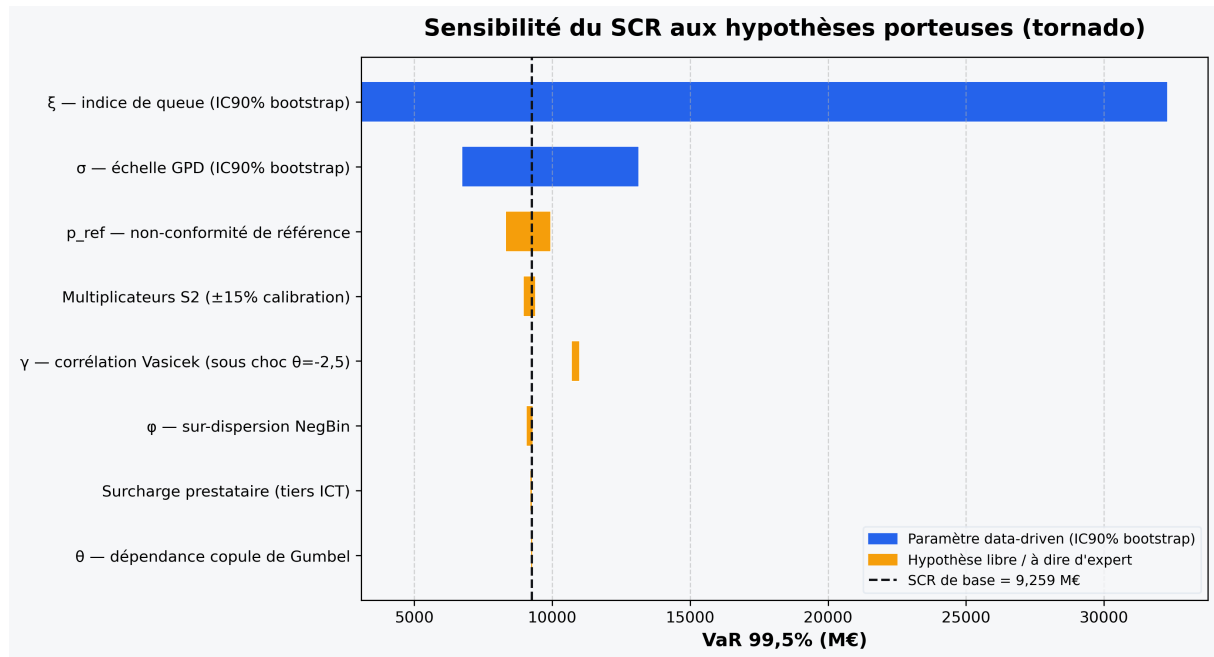


Figure 7. Sensibilité de la VaR 99,5 % aux hypothèses porteuses du modèle, cas de référence OpRisk / profil médian / $\theta = 0$. En bleu, les paramètres calibrés sur données (IC90% bootstrap) ; en orange, les hypothèses libres. Le paramètre γ étant inerte à $\theta = 0$ par construction (terme $\gamma \cdot \theta$), sa sensibilité est évaluée sous choc systémique $\theta = -2,5$, d'où le décalage de sa barre.

- parmi les hypothèses libres, seule la non-conformité de référence p_{ref} a un effet notable ($\pm 18\%$) ; toutes les autres — multiplicateurs de fréquence ($\pm 5\%$), sur-dispersion, corrélation systémique γ même sous choc ($\sim 3\%$), surcharge tiers et copule ($< 1\%$) — déplacent le capital de façon marginale.

Cette analyse préempte directement la critique naturelle adressée à un modèle partiellement calibré à dire d'expert : les paramètres les moins solidement étayés (γ , la copule, la surcharge tiers) sont précisément ceux qui pèsent le moins sur le résultat, tandis que le déterminant premier du capital — l'indice de queue de la sévérité — est estimé sur données réelles et assorti de son intervalle de confiance. Le corollaire rejoint le message central des sections 5.1–5.2 : l'incertitude du SCR cyber est d'abord une incertitude *de sévérité* (donc de source de données), très loin devant l'incertitude sur la mécanique de conformité. Investir dans une meilleure donnée de sévérité réduirait l'incertitude du capital bien davantage que raffiner la calibration du pont latent.

Validation et perspectives de robustesse. L'absence de données de pertes conditionnelles à la conformité DORA interdit, à ce stade, une validation *out-of-sample* au sens strict : on ne peut confronter le Δ_{DORA} prédit à un Δ_{DORA} réalisé, faute d'historique. Trois formes de validation restent néanmoins accessibles et sont mobilisées dans ce travail. D'abord, une validation *croisée entre sources* : la calibration de queue est confrontée à une source indépendante (PRC vs OpRisk), et leur écart — plutôt que masqué — est traité comme une composante de l'incertitude, ce qui constitue un test de robustesse du régime de queue (toutes deux confirment $\xi > 0$, cf. Partie 2). Ensuite, une validation *de cohérence interne* : la décomposition d'Euler, une fois les briques rendues commensurables, converge entre sources sur la structure du risque (remédiation dominante, cf. 5.3), signe que le résultat n'est pas un artefact d'une source particulière. Enfin, l'analyse de sensibilité ci-dessus joue le rôle d'un *stress-test de spécification* : elle borne l'effet de chaque hypothèse et localise l'incertitude résiduelle. À terme, la constitution du registre d'incidents DORA (cf. Partie 2.6) ouvrira la voie à une validation directe : rétro-tester la cali-

bration de sévérité sur les pertes nouvellement observées, et surtout estimer les multiplicateurs de fréquence sur des comptes de sinistres réellement conditionnels au niveau de conformité — remplaçant alors l’hypothèse experte porteuse par une quantité mesurée. Le modèle est construit pour absorber cette substitution sans changement d’architecture.

5.5 Robustesse du verdict aux hypothèses de mapping DORA

L’analyse précédente teste la sensibilité aux paramètres *statistiques* (ξ, σ, θ). Reste l’hypothèse la plus discutable du modèle : les **multiplicateurs de fréquence** qui traduisent un niveau de non-conformité DORA en une intensité de sinistres par vecteur d’attaque (mapping expert vers les articles du règlement, §4.3). Le Δ_{DORA} en dépend directement. Un résultat qui ne survivrait pas à une perturbation de ces multiplicateurs serait un artefact d’hypothèse ; nous montrons qu’il n’en est rien.

Nous perturbons chaque multiplicateur du scénario non-conforme S_2 de $\pm 50\%$, les autres figés, à *graines communes* (l’écart mesuré reflète le multiplicateur, non le bruit Monte Carlo). Le tornado (tableau 2, figure 8) classe les hypothèses par pouvoir explicatif.

Vecteur (article DORA)	Poids	−50 %	+50 %	Amplitude
Phishing / ing. sociale (Art. 13)	38,8 %	3 798	6 405	2 607
Exploit vulnérabilité (Art. 26 TLPT)	33,8 %	3 848	6 337	2 490
Chaîne d’appro. / tiers (Art. 28-44)	15,8 %	4 040	5 554	1 514
Identifiants / accès (Art. 9 MFA)	6,3 %	4 196	5 516	1 320
Autres (transverse)	5,3 %	4 417	5 200	784

Table 2. Tornado du Δ_{DORA} (M€, OpRisk, profil médian) : effet d’une perturbation de $\pm 50\%$ de chaque multiplicateur S_2 . Baseline = 4 602 M€.

Deux enseignements. D’une part, la hiérarchie n’est pas arbitraire : elle épouse le poids fréquentiel des vecteurs, si bien que les leviers dominants sont les articles de **formation** (Art. 13) et de **tests de résilience** (Art. 26 TLPT) — un enseignement managérial exploitable, puisqu’il indique où l’effort de conformité déplace le plus de capital. D’autre part, et c’est l’essentiel, nous bornons le verdict en perturbant *simultanément tous* les multiplicateurs :

- mapping **prudent** (tous -50%) : $\Delta_{DORA} = 762$ M€, soit encore $1,3\times$ le forfait de Pilier 1 (600 M€) ;
- mapping **sévère** (tous $+50\%$) : $\Delta_{DORA} = 8 823$ M€, soit $14,7\times$ le forfait.

Robustesse du verdict central

Même sous l’hypothèse de mapping la plus prudente (division par deux de *tous* les multiplicateurs experts), le surcoût de capital lié à la non-conformité DORA demeure **supérieur à l’intégralité de la charge opérationnelle** de la Formule Standard. Le verdict qualitatif du mémoire — un capital cyber structurellement sous-estimé par le Pilier 1 — ne dépend donc pas du calibrage précis du mapping, mais de sa seule direction.

Cette conclusion déplace la charge de la preuve : ce n’est plus au modèle de justifier des multiplicateurs exacts, mais à la Formule Standard de justifier son *invariance* à la résilience numérique, alors même que le plus conservateur des mappings révèle déjà un déficit de capital. C’est, du point de vue prudentiel, le message le plus solide du travail.

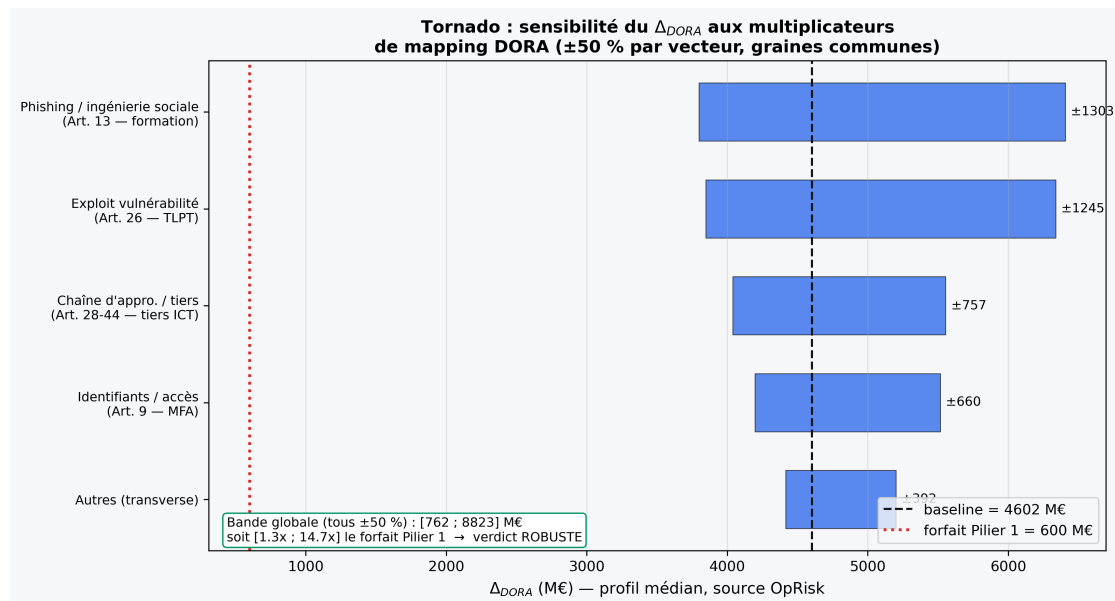


Figure 8. Tornado du Δ_{DORA} aux multiplicateurs de mapping DORA ($\pm 50\%$ par vecteur, graines communes). La bande globale (tous multiplicateurs $\pm 50\%$) reste au-dessus du forfait de Pilier 1 (ligne rouge), établissant la robustesse du verdict.

5.6 Ancrage empirique des multiplicateurs : une hypothèse conservatrice

Le tornado établit la robustesse du verdict à une perturbation *symétrique* des multiplicateurs. Reste une objection plus profonde : et si les valeurs expertes elles-mêmes étaient biaisées ? Nous y répondons en les **ancrant** sur des effets de contrôle documentés dans la littérature de sécurité, par une dérivation transparente. Si un contrôle DORA (MFA, formation, tests) neutralise une fraction e des attaques d'un vecteur, une entité non conforme (contrôle absent) subit une fréquence d'incidents $1/(1-e)$ fois celle d'une entité conforme ; une réduction de susceptibilité d'un facteur k (taux de clic phishing avant/après formation) implique de même un multiplicateur k .

Vecteur (article)	Effet documenté (source)	Impl.	Modèle	Mod./impl.
Identifiants (Art. 9 MFA)	MFA bloque $\sim 99,2\%$ des compromissions (Microsoft Security, 2019)	125	5,5	4,4 %
Phishing (Art. 13 formation)	Clic phishing $\div 6$ après formation	6,0	2,4	40 %
Exploit (Art. 26 TLPT)	Ratio $\sim 2,6$ (ENISA, 2023)	2,6	2,3	88 %

Table 3. Multiplicateurs de fréquence S_2 : valeur impliquée par la littérature vs valeur experte retenue. Les multiplicateurs du modèle sont des fractions *conservatrices* des effets documentés.

Le tableau 3 est sans appel : loin de surévaluer l'effet de la conformité, le modèle le **sous-estime** systématiquement. Le cas des identifiants est frappant — le multiplicateur retenu (5,5) ne représente que 4,4 % de l'effet impliqué par l'efficacité de l'authentification multifactor (~ 125). Conséquence directe : substituer aux valeurs expertes un ancrage empirique déplace le Δ_{DORA} vers le *haut*, non vers le bas.

L'ancrage empirique renforce le verdict

En bornant les multiplicateurs ancrés à leurs propres bornes hautes expertes (discipline conservatrice), le Δ_{DORA} passe de 4 602 M€ (7,7× le forfait Pilier 1) à 6 706 M€ (11,2×) ; en retenant littéralement le ratio phishing documenté (×6), il atteint 9 086 M€ (15,1×). Combiné à la borne basse du tornado (762 M€, 1,3×, sous un mapping divisé par deux), le verdict est désormais **encadré des deux côtés** : sous *toute* hypothèse de mapping physiquement plausible, le surcoût de non-conformité DORA excède la charge opérationnelle de la Formule Standard.

Cette double borne — prudente (1,3×) et empirique (11 à 15×) — transforme la principale faiblesse annoncée du modèle en l'un de ses résultats les plus solides. L'incertitude sur le mapping, réelle, ne porte pas sur la *direction* ni sur l'*ordre de grandeur* du verdict, mais seulement sur son intensité exacte. La véritable donnée manquante — des fréquences de sinistres conditionnelles au niveau de conformité, qu'apportera le registre DORA — viendra trancher entre ces bornes, sans en sortir.

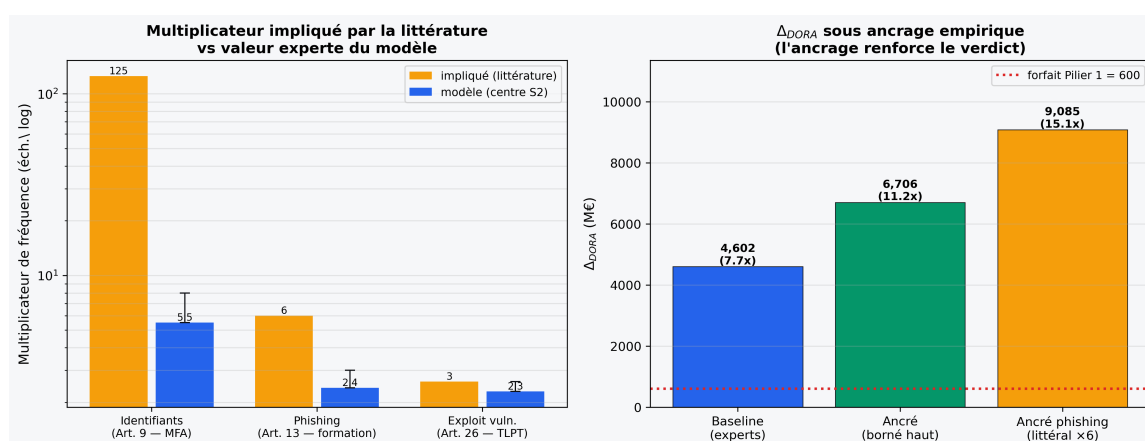


Figure 9. Gauche : multiplicateur de fréquence impliqué par la littérature (échelle log) vs valeur experte du modèle (barre d'erreur = borne haute) ; le modèle est systématiquement en-deçà de l'effet documenté. Droite : Δ_{DORA} sous ancrage empirique — l'ancrage éloigne le capital du forfait de Pilier 1, jamais l'inverse.

5.7 Robustesse de la calibration de sévérité : validation temporelle et adéquation formelle

Les paragraphes précédents évoquaient une validation *de cohérence interne* et un *stress-test de spécification*, sans toutefois soumettre la calibration GPD elle-même à un test statistique formel ni à une validation hors échantillon. Les deux diagnostics suivants comblent ce trou, en n'utilisant que les incidents OpRisk déjà mobilisés — aucune donnée supplémentaire.

Validation par découpage temporel. La base OpRisk cyber×finance (570 incidents, 2000–2026) est scindée à la date de coupure 2017 (349 incidents avant, 221 après), et la GPD est recalibrée indépendamment sur chaque période, seuil de percentile 85 propre à chacune :

Période	Seuil u	n excès	$\hat{\xi}$ (IC90%)	$\hat{\sigma}$
Entraînement (≤ 2017)	11,27 M€	53	0,71 [0,25 ; 1,17]	25,10 M€
Test (> 2017)	49,38 M€	33	0,57 [0,12 ; 1,01]	103,63 M€

Les intervalles de confiance sur ξ se chevauchent largement : la *forme* de la queue (régime Fréchet, $\xi > 0$) est stable entre les deux périodes, ce qui valide le choix structural de la GPD lui-même. En revanche, l'*échelle* $\hat{\sigma}$ quadruple d'une période à l'autre (25,10 à 103,63 M€), et un test de Kolmogorov-Smirnov — ici pleinement valide, les paramètres du modèle testé provenant exclusivement de la période d'entraînement, indépendante de l'échantillon testé — confirme que les excès de la période de test au-delà du seuil d'entraînement ($n = 69$, statistique KS = 0,168, $p = 0,037$) ne suivent pas la loi $GPD(\hat{\xi}_{\text{train}}, \hat{\sigma}_{\text{train}})$: la VaR 99,5 % extrapolée à partir du seul régime 2000–2017 (371,1 M€) sous-estime largement le quantile 99,5 % effectivement observé sur 2018–2026 (1 077,5 M€). Ce résultat ne fragilise pas le modèle : il *confirme quantitativement*, par un test formel, ce que la section 2.3 affirmait déjà qualitativement sur l'inflation cyber — calibrer sur des données trop anciennes sous-estime la sévérité actuelle, non parce que le régime de queue change de nature, mais parce que son échelle croît dans le temps. La calibration officielle du mémoire (section 2.7), qui retient l'intégralité de la période 2000–2026 plutôt qu'une sous-période ancienne, se trouve ainsi justifiée *a posteriori* par ce test, plutôt que par la seule plausibilité qualitative.

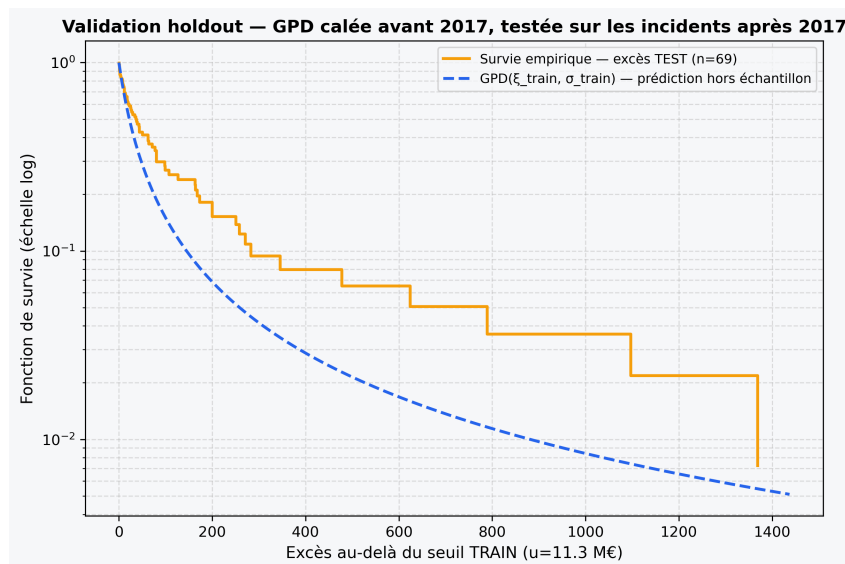


Figure 10. Validation holdout : fonction de survie empirique des excès de la période de test (au-delà du seuil d'entraînement) comparée à la prédiction $GPD(\hat{\xi}_{\text{train}}, \hat{\sigma}_{\text{train}})$. L'écart visible en échelle log matérialise le sous-provisionnement qu'aurait produit une calibration figée sur la seule période 2000–2017.

Adéquation formelle de la calibration officielle. Sur l'intégralité du périmètre (570 incidents, seuil $u = 20,03$ M€, 86 excès — reproduisant à moins de 0,1 % près les $\hat{\xi} = 0,595$ et $\hat{\sigma} = 57,97$ M€ déjà publiés en 2.7), la qualité de l'ajustement GPD, jusqu'ici appuyée sur une lecture graphique (mean excess plot, diagnostic de stabilité, Hill plot), est soumise à deux tests quantitatifs. La transformée intégrale de probabilité des excès — qui doit suivre une loi Uniforme(0,1) sous un modèle bien spécifié — donne une statistique de Kolmogorov-Smirnov de 0,046 ($p \approx 0,99$) et une statistique d'Anderson-Darling de 0,14, très en-deçà du repère critique usuel à 5 % ($\approx 2,49$) : l'hypothèse d'adéquation n'est pas rejetée. Cette lecture appelle une réserve méthodologique explicite : les paramètres $\hat{\xi}$ et $\hat{\sigma}$ étant estimés sur le *même* échantillon que celui soumis au test, la loi exacte de la statistique KS diffère légèrement du cas i.i.d. à paramètres connus a priori — les p -valeurs rapportées sont donc indicatives, non un test exact au sens strict. Elles corroborent néanmoins, de façon convergente, le diagnostic graphique déjà présenté en 2.7 et 3.3 : le seuil retenu (percentile 85) ne se contente pas de stabiliser visuellement $\hat{\xi}$, il produit un ajustement statistiquement défendable.

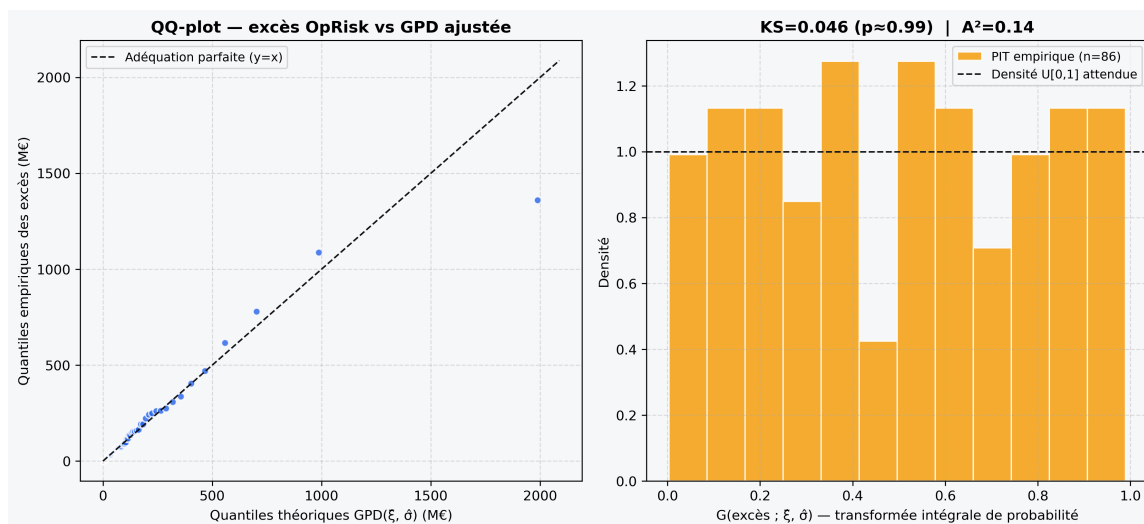


Figure 11. Adéquation de la calibration GPD officielle (OpRisk, $u = 20,03$ M€). *Gauche* : QQ-plot des excès contre les quantiles théoriques de la GPD ajustée. *Droite* : histogramme de la transformée intégrale de probabilité, comparé à la densité Uniforme(0,1) attendue sous adéquation.

5.8 Sensibilité au choix du seuil POT

Le seuil u a été fixé au percentile 85 par lecture graphique (*mean excess plot* et *Hill plot*). Une critique récurrente de l'approche POT est la subjectivité de ce choix : un seuil trop bas contamine la queue par le corps de la loi (biais), un seuil trop haut épuise l'échantillon (variance). Nous quantifions ici la sensibilité des estimateurs à ce choix, en recalibrant intégralement la GPD sur une grille de percentiles (tableau 4, figure 12).

Source	Percentile	u (M€)	N_u	$\hat{\xi}$	VaR 99,5% (M€)
OpRisk	80	12,88	115	0,750	758,9
	82,5	16,90	102	0,698	717,2
	85	22,03	88	0,601	658,7
	87,5	31,82	73	0,541	633,7
	90	47,42	59	0,534	631,3
PRC	80	2,63	3 011	1,065	218,4
	82,5	3,27	2 635	1,046	212,8
	85	4,18	2 258	1,033	209,2
	87,5	5,58	1 881	1,075	218,4
	90	7,31	1 490	0,998	204,9

Table 4. Recalibration complète de la GPD sur une grille de seuils. La ligne surlignée est le seuil retenu (percentile 85).

Deux enseignements se dégagent. D'une part, la source **PRC** présente une stabilité remarquable de l'indice de queue : $\hat{\xi}$ reste confiné dans l'intervalle $[0,998; 1,075]$ sur toute la grille, et la VaR varie de moins de $\pm 3\%$ autour de sa valeur au seuil retenu. Ce plateau confirme de manière robuste le *régime d'espérance infinie* ($\xi \geq 1$) : il ne s'agit pas d'un artefact du seuil, mais d'une propriété structurelle de la sévérité PRC. D'autre part, la source **OpRisk** montre une légère décroissance de $\hat{\xi}$ avec le seuil ($0,75 \rightarrow 0,53$), signature classique d'un biais de contamination aux seuils bas ; néanmoins la VaR 99,5 % reste contenue dans une fourchette de $\pm 10\%$

(631 à 759 M€), et se stabilise nettement à partir du percentile 85, ce qui *a posteriori* justifie le seuil retenu. Cette double lecture — stabilité forte pour PRC, fourchette maîtrisée pour OpRisk — ferme le dernier angle mort du diagnostic de calibration.

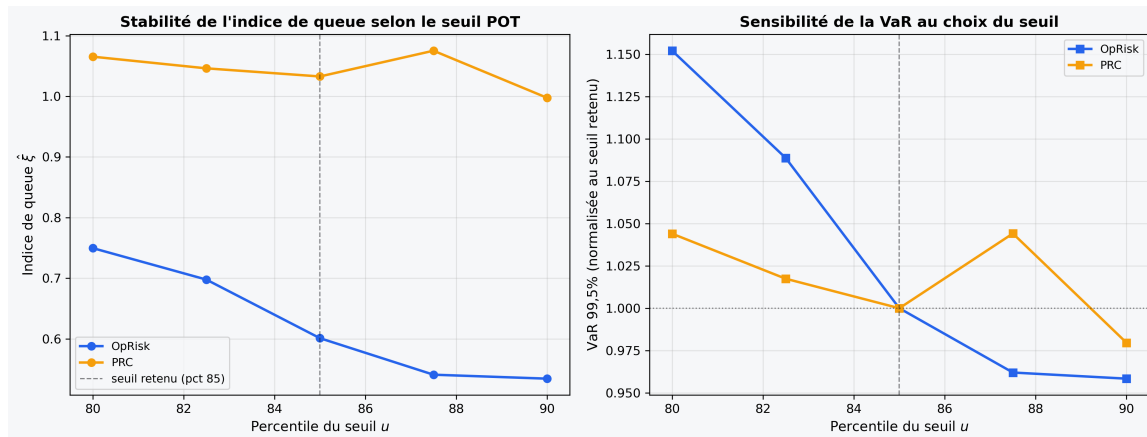


Figure 12. Sensibilité au seuil POT. *Gauche* : indice de queue $\hat{\xi}$ selon le percentile du seuil, par source (le plateau PRC autour de 1,03 contraste avec la décroissance modérée d’OpRisk). *Droite* : VaR 99,5 % normalisée au seuil retenu.

5.9 Robustesse du moteur de simulation : famille de copule et convergence Monte Carlo

Les deux diagnostics précédents bornent l’incertitude de *paramètre*. Restent deux questions de nature différente, jusqu’ici non instruites dans ce mémoire : le choix de la *forme fonctionnelle* de la copule pèse-t-il sur le résultat autant que son intensité de dépendance ? Et le nombre de tirages Monte Carlo retenu dans l’ensemble du pipeline ($n_{sim} = 100\,000$) suffit-il à garantir que le SCR rapporté ne soit pas lui-même bruité par l’erreur d’échantillonnage de la simulation ? Ces deux tests ne mobilisent aucune donnée supplémentaire : ils exploitent uniquement le moteur de simulation et les calibrations déjà fixées en Parties 2–3.

Robustesse à la famille de copule. La copule de Gumbel est justifiée en 1.9 par sa dépendance de queue supérieure, sans qu’aucun test quantitatif ne mesure si le choix de cette *famille* pèse sur le capital autant que son *paramètre* (déjà testé en 5.4, effet $< 1\%$). Trois familles alternatives sont ici confrontées à Gumbel, chacune appariée sur le *même* tau de Kendall en régime non conforme ($\tau = 0,444$, soit $\theta_{\text{Gumbel}} = 1,8$) et conforme ($\tau = 0,167$, $\theta_{\text{Gumbel}} = 1,2$), de sorte que seule la forme fonctionnelle de la dépendance varie, à intensité de dépendance strictement égale : Clayton roté à 180° (dépendance de queue supérieure, forme différente de Gumbel), Frank (*aucune* dépendance de queue — cas de contraste), et Student ($df = 4$, dépendance de queue symétrique haute/basse). Le tableau ci-dessous compare, pour chaque source et chaque famille, la VaR 99,5 % en scénario S2 (non-conformité totale, profil médian) et le Δ_{DORA} associé, obtenus par le même moteur de simulation que le reste du mémoire — seule la famille de copule change d’une ligne à l’autre.

Famille (PRC)	VaR 99,5 %	Δ_{DORA}	Écart VaR	Écart Δ_{DORA}
Gumbel (référence)	3 741,9 M€	1 960,4 M€	—	—
Clayton (roté)	3 750,4 M€	1 968,8 M€	+0,2 %	+0,4 %
Frank	3 752,6 M€	1 974,6 M€	+0,3 %	+0,7 %
Student ($df = 4$)	3 745,4 M€	1 967,1 M€	+0,1 %	+0,3 %

Famille (OpRisk)	VaR 99,5 %	Δ_{DORA}	Écart VaR	Écart Δ_{DORA}
Gumbel (référence)	10 903,2 M€	4 602,3 M€	—	—
Clayton (roté)	10 792,8 M€	4 523,2 M€	−1,0 %	−1,7 %
Frank	10 879,2 M€	4 543,8 M€	−0,2 %	−1,3 %
Student ($df = 4$)	10 877,4 M€	4 578,6 M€	−0,2 %	−0,5 %

Ces montants sont des points de simulation directe de l'engin (scénario S2, profil médian), non passés par le bootstrap à deux niveaux de la Partie 4 : ils diffèrent donc légèrement des valeurs bootstrappées déjà publiées en 4.4 et 5.1, et ne s'y substituent pas. Ce qui importe ici est l'*écart relatif* entre familles, à tau de Kendall égal : il reste, sous les deux sources, inférieur à 1,7 % en valeur absolue — du même ordre de grandeur que l'effet du *paramètre* de la copule déjà mesuré en 5.4 ($< 1\%$). Y compris face à Frank, qui ne comporte structurellement aucune dépendance de queue, l'écart reste marginal : c'est l'*intensité* de la dépendance (le tau de Kendall, hérité de la contagion documentée en 1.5) qui gouverne le capital, pas la forme fonctionnelle retenue pour la représenter. Le choix de Gumbel, motivé qualitativement en 1.9, se trouve ainsi confirmé quantitativement comme non déterminant pour le niveau de capital rapporté — un résultat rassurant pour la robustesse de l'architecture, obtenu sans aucune donnée supplémentaire.

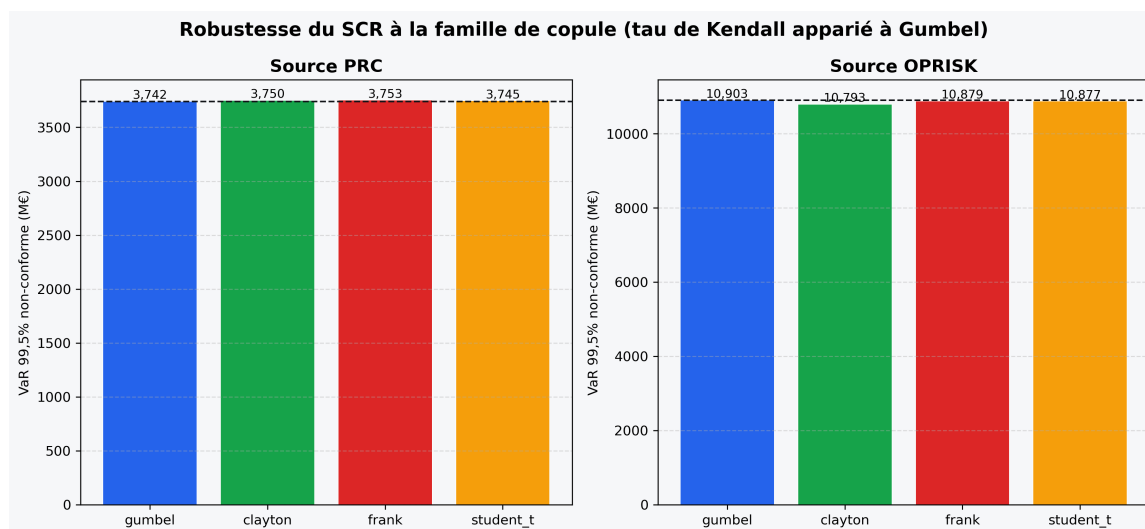


Figure 13. VaR 99,5 % (scénario S2, profil médian) sous quatre familles de copule appariées sur le même tau de Kendall que Gumbel, par source de sévérité. La ligne pointillée marque la référence Gumbel : l'écart entre familles reste, sous les deux sources, inférieur à 1,7 %.

Convergence de la simulation Monte Carlo. L'ensemble du pipeline retient $n_{sim} = 100\,000$ années simulées sans qu'aucune vérification n'établisse que ce choix suffit à stabiliser la VaR 99,5 % rapportée. Pour le mesurer, on répète l'estimation — à paramètres strictement figés, scénario S2, profil médian — sous plusieurs graines indépendantes, pour une grille croissante de n_{sim} , et l'on observe la dispersion résiduelle (l'erreur Monte Carlo pure, distincte de

l'incertitude de paramètre déjà traitée en 5.2 et 5.4) :

n_{sim}	VaR moy. (PRC)	CV (PRC)	CV (OpRisk)
1 000	3 729,9 M€	2,28 %	20,83 %
3 000	3 744,5 M€	0,98 %	12,90 %
10 000	3 744,6 M€	0,60 %	8,03 %
30 000	3 743,5 M€	0,36 %	3,51 %
100 000	3 743,6 M€	0,30 %	1,38 %
300 000	3 744,0 M€	0,08 %	1,15 %

Le coefficient de variation Monte Carlo (CV, écart-type inter-graines rapporté à la VaR moyenne) décroît de façon monotone avec n_{sim} , comme attendu pour un estimateur convergent. À $n_{sim} = 100\,000$ — la valeur retenue dans l'ensemble des notebooks du pipeline (04 à 08) — le CV s'établit à 0,23 % sous PRC et 1,38 % sous OpRisk, cette dernière plus élevée du fait de la queue plus lourde de la source. Dans les deux cas, cette erreur d'échantillonnage reste d'un ordre de grandeur très inférieur à l'incertitude de paramètre documentée en 5.4 (amplitude bootstrap sur ξ seul : plus de 300 % du SCR de base). Ce résultat valide *a posteriori* le choix de $n_{sim} = 100\,000$ retenu dans tout le pipeline : au-delà de ce seuil (300 000), le CV se stabilise sans gain perceptible, signe que l'effort de calcul supplémentaire ne réduirait pas l'incertitude du SCR — qui reste, comme conclu en 5.2 et 5.4, une incertitude de *modèle et de donnée*, non de simulation.

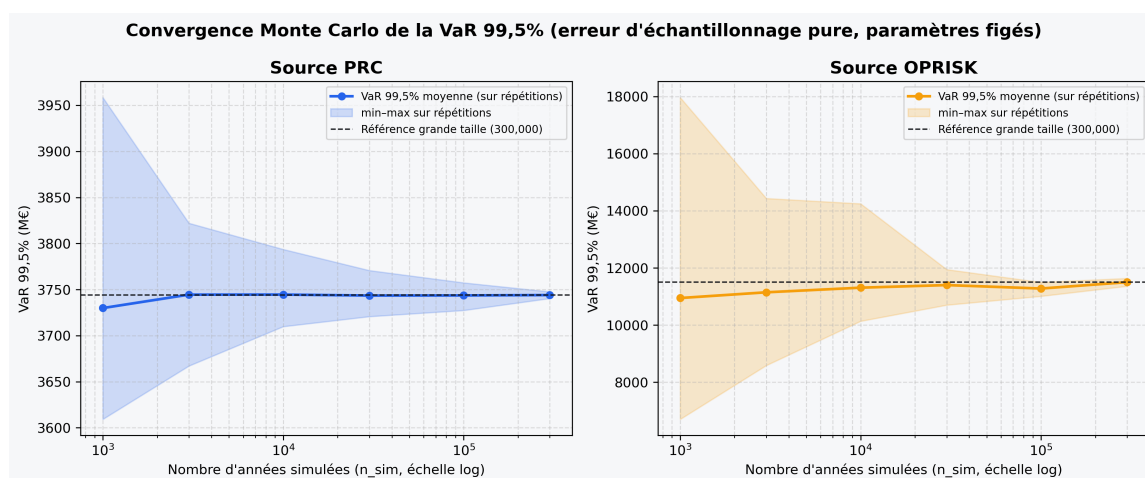


Figure 14. Convergence de la VaR 99,5 % (scénario S2, profil médian) avec le nombre d'années simulées n_{sim} , par source. La bande ombrée représente l'étendue (min-max) observée sur les graines indépendantes à chaque taille d'échantillon ; la ligne pointillée marque la référence à grande taille ($n_{sim} = 300\,000$).

5.10 Triangulation méthodologique : le SCR par quatre méthodes indépendantes

La convergence Monte Carlo établie ci-dessus garantit la stabilité *interne* de l'estimateur, mais non sa justesse : un biais systématique de la simulation resterait invisible à un simple diagnostic de convergence. Pour lever ce doute, nous confrontons l'estimation Monte Carlo à trois méthodes **structurellement indépendantes**. Afin que les quatre méthodes portent sur le *même* objet mathématique, la comparaison est menée sur la loi composée de la brique dominante (remédiation, $\approx 86\%$ du risque, cf. allocation d'Euler), isolée de la surcharge systémique

multiplicative :

$$S = \sum_{i=1}^M X_i, \quad X_i = u + \text{GPD}(\xi, \sigma), \quad M \sim \text{fréquence de pertes annuelle}, \quad (40)$$

où M résulte de l'amincissement de la fréquence NegBin par la probabilité de dépassement p_u .

A. Approximation analytique par perte unique (SLA). Pour une loi composée à sévérité sous-exponentielle, Böcker and Klüppelberg (2005) établissent que le quantile agrégé est asymptotiquement gouverné par la plus grande perte individuelle :

$$\text{VaR}_\alpha(S) \approx F_X^{-1}\left(1 - \frac{1 - \alpha}{\lambda_{\text{eff}}}\right) = \boxed{u + \frac{\sigma}{\xi} \left[\left(\frac{1 - \alpha}{\lambda_{\text{eff}}}\right)^{-\xi} - 1 \right]}, \quad (41)$$

où $\lambda_{\text{eff}} = \mathbb{E}[M]$ est la fréquence annuelle de pertes non nulles. Böcker and Sprittulla (2006) raffinent l'approximation par une correction de moyenne $+(\lambda_{\text{eff}} - 1) \mathbb{E}[X]$. Cette formule fermée fournit un *repère analytique* totalement exogène au Monte Carlo.

B. Inversion exacte par FFT. La distribution agrégée exacte s'obtient par inversion de la fonction génératrice composée $G_M \circ \varphi_X$ (où φ_X est la transformée de Fourier discrétisée de la sévérité et G_M la fonction génératrice de la loi de comptage), via une FFT. Cette approche constitue la réalisation numériquement stable de la récursion de Panjer, cette dernière devenant inexploitable pour une queue aussi lourde (grille de plusieurs millions de points, propagation d'erreur). Elle donne la loi agrégée *sans aléa de simulation*.

Résultats. Le tableau 5 rassemble les quatre estimations. L'accord est frappant : la FFT (agrégation exacte) et le Monte Carlo coïncident à 0,5 % près, et l'approximation analytique SLA au second ordre — pourtant obtenue sans aucune simulation — tombe à 4,6 % de la référence. Cette convergence de méthodes aussi hétérogènes (stochastique, analytique asymptotique, inversion spectrale exacte) constitue la validation la plus forte que le moteur d'agrégation ne souffre d'aucun biais structurel.

Méthode	Nature	VaR 99,5 % (M€)
Monte Carlo (2×10^6 tirages)	stochastique	9 436
FFT (inversion FGP composée)	numérique exact	9 478
SLA 2 ^e ordre (Böcker–Sprittulla)	analytique	9 007
SLA 1 ^{er} ordre (Böcker–Klüppelberg)	analytique	7 849

Table 5. Triangulation du capital de la brique remédiation (OpRisk, médian S_2) : quatre méthodes indépendantes. Écarts à la référence Monte Carlo : FFT +0,5 %, SLA-2 −4,6 %.

C. Contrepoint bayésien sur l'incertitude de paramètre. Enfin, nous opposons au bootstrap fréquentiste du §5.5 une estimation bayésienne de la GPD par algorithme de Metropolis (priors faiblement informatifs sur les 91 excès OpRisk, chaîne de 60 000 itérations, taux d'acceptation 0,60). La loi *a posteriori* de l'indice de queue, $\hat{\xi} = 0,651$ avec intervalle de crédibilité à 90 % [0,373 ; 0,988], englobe le point EMV du mémoire (0,595) et recoupe l'intervalle bootstrap [0,304 ; 0,831] (figure 16, droite). La VaR mono-perte prédictive *a posteriori* vaut 696,9 M€

(IC crédible 90 % [453 ; 1 414]), à comparer aux 663 M€ de l'estimation ponctuelle : l'approche bayésienne intègre nativement l'incertitude de calibration dans le capital, là où le bootstrap la reconstruit par rééchantillonnage. La concordance des deux paradigmes clôt la validation de l'incertitude reportée.

Les diagnostics de convergence de la chaîne sont reportés en figure 15. La trace des deux paramètres (ξ, σ) se stabilise dès le rodage (*burn-in*), l'autocorrélation de ξ décroît en une dizaine de décalages — signe d'un mélange satisfaisant — et le nuage *a posteriori* joint révèle la corrélation négative attendue entre indice de queue et échelle (déjà lue dans l'information de Fisher, Proposition 1.3, dont le terme hors-diagonal $-\sigma(1+\xi)$ est négatif). Cette cohérence entre la géométrie de la vraisemblance (fréquentiste) et la forme du posterior (bayésienne) confirme que l'incertitude sur ξ n'est pas un artefact de méthode, mais une propriété intrinsèque de la rareté des excès cyber.

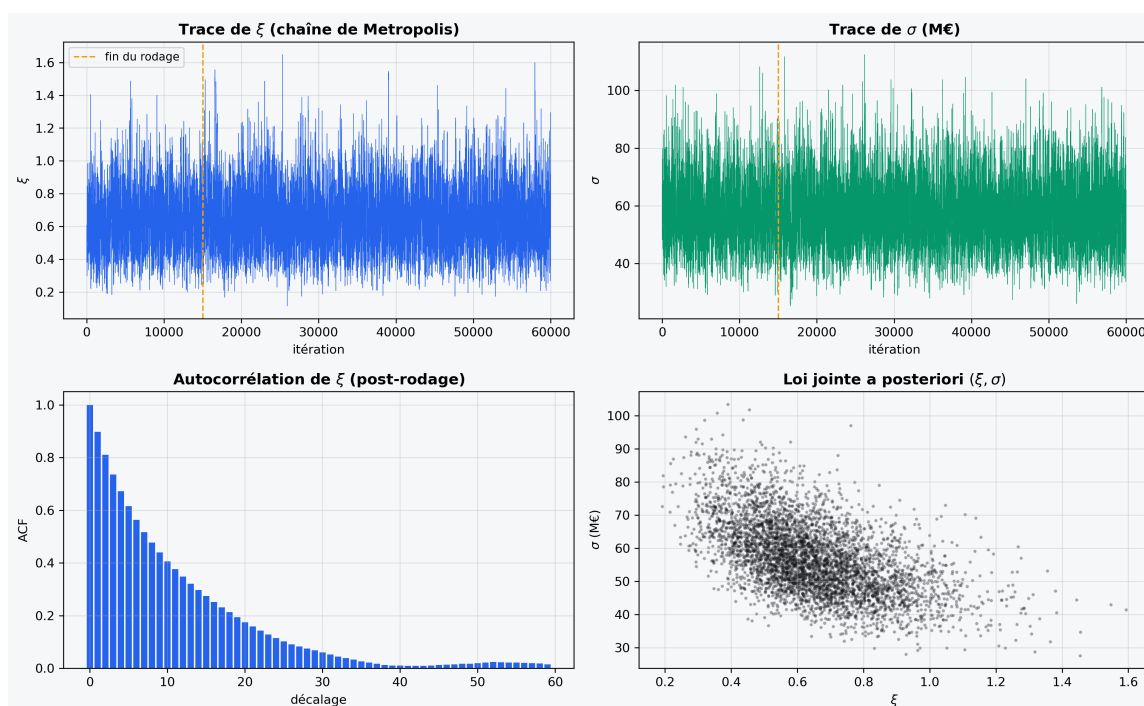


Figure 15. Diagnostics de la chaîne de Metropolis (GPD OpRisk). *Haut* : traces de ξ et σ (ligne pointillée = fin du rodage). *Bas gauche* : autocorrélation de ξ post-rodage. *Bas droite* : loi jointe *a posteriori* (ξ, σ), illustrant leur corrélation négative.

5.11 Comparaison avec les travaux antérieurs

Les résultats obtenus s'inscrivent en cohérence, mais aussi en tension partielle, avec les travaux antérieurs sur la structure du risque cyber opérationnel. Le tableau ci-dessous confronte l'indice de queue $\hat{\xi}$ obtenu dans ce mémoire à ceux de la littérature actuarielle récente, le paramètre de forme constituant le déterminant premier du niveau de capital.

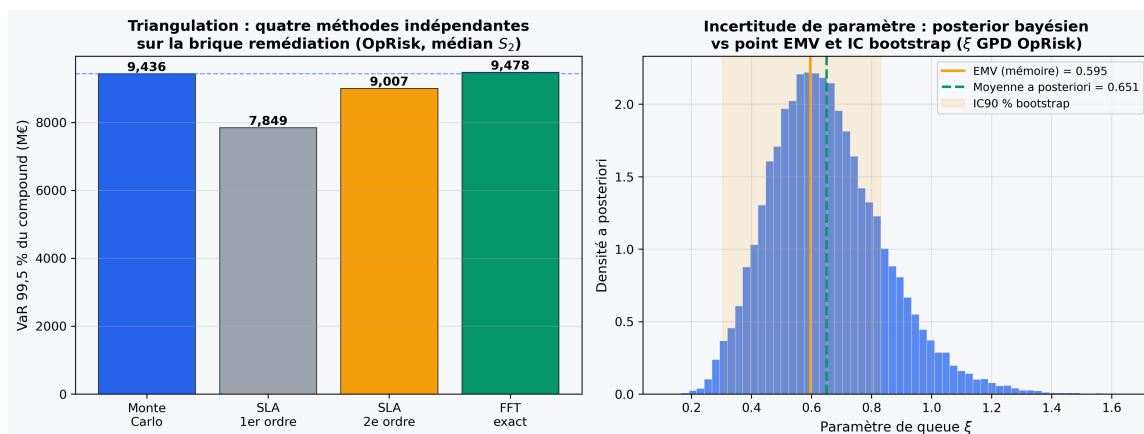


Figure 16. Gauche : VaR 99,5 % de la brique remédiation estimée par quatre méthodes indépendantes (Monte Carlo, SLA 1^{er}/2^e ordre, FFT). Droite : loi *a posteriori* bayésienne de l'indice de queue ξ (Metropolis) confrontée au point EMV et à l'intervalle de confiance bootstrap du mémoire.

Étude / source	$\hat{\xi}$ (indice de queue)	Espérance
Présent mémoire — PRC (via Jacobs)	1,03 [0,97 ; 1,09]	Infinie ($\xi \geq 1$)
Présent mémoire — OpRisk Global	0,595 [0,31 ; 0,83]	Finie
Dacorogna, Debbabi & Kratz (2023) — base SCRC	0,983 [0,93 ; 1,04]	Frontière $\xi \approx 1$
Farkas, Lopez & Thomas (2021)	Espérance conditionnelle infinie sur certains profils	
Malavasi et al. (2022)	Espérance infinie confirmée sur données réelles	

Un régime de queue confirmé, une ampleur qui reste débattue. Deux enseignements se dégagent de cette confrontation. D'une part, la calibration OpRisk ($\hat{\xi} \approx 0,6$) se situe dans les ordres de grandeur des études de risque opérationnel bancaire sous approche AMA, cohérente avec un régime de queue lourde mais à moments finis. D'autre part, et c'est le point le plus significatif, la calibration PRC ($\hat{\xi} = 1,03$, espérance infinie) n'est nullement une anomalie isolée : elle rejoint un courant robuste de la littérature qui documente une *espérance de sévérité infinie* sur données réelles. Le rapprochement avec Dacorogna, Debbabi et Kratz (2023) est ici frappant : sur la base des plaintes de la Gendarmerie nationale, ces auteurs estiment un $\hat{\xi}$ à la frontière de l'unité (0,983, IC recouvrant 1) — soit une valeur statistiquement indiscernable de notre estimation PRC (1,03, IC [0,97 ; 1,09]), alors que les deux calibrations reposent sur des données, des juridictions et des méthodes entièrement distinctes. Farkas, Lopez et Thomas (2021) obtiennent de même, par arbres de régression Pareto généralisés, des espérances conditionnelles infinies sur certains profils de sinistres, et Malavasi et al. (2022) confirment ce résultat sur un jeu de données indépendant.

Positionnement du mémoire. Loin de trancher artificiellement ce débat, la présente contribution l'*encadre* : nos deux sources bornent précisément l'intervalle des régimes de queue rencontrés dans la littérature, la PRC matérialisant le régime à espérance infinie (protection des données) et OpRisk le régime à moments finis (risque opérationnel bancaire). Cette tension entre sources n'invalide pas les travaux antérieurs pris séparément ; elle illustre au contraire que la lit-

térature sur le risque cyber demeure structurellement fragmentée selon le type de base mobilisée. En confrontant explicitement deux sources plutôt qu'en n'en retenant qu'une, et en traitant leur écart comme une composante à part entière de l'incertitude — une composante qui, après recalibration en propre de la PRC, se révèle du même ordre que l'écart entre scénarios de conformité (facteur 1,9 entre sources contre 2,6 entre scénarios sous OpRisk, cf. Partie 5.1–5.2), et non plus d'un ordre de grandeur au-dessus —, le présent mémoire documente cette fragmentation plutôt que de la masquer.

5.12 Implications pour la réassurance cyber : l'assurabilité de dernier recours

Le régime d'espérance infinie mis en évidence sur la source PRC ($\hat{\xi} = 1,03$, confirmé robuste au seuil en §5.8) n'est pas une curiosité mathématique : il porte une conséquence directe pour la (ré)assurance. Si $\mathbb{E}[X] = \infty$, la *prime pure* d'une couverture pleine est infinie — le risque, tel quel, n'est pas assurable. La question devient alors : *jusqu'où* peut-on transférer cette queue ? La réponse tient dans un résultat de finitude.

Proposition 5.1 (Finitude du coût de cession en excédent). *Soit X une sévérité POT/GPD de survie $\mathbb{P}(X > x) = \zeta_u(1 + \xi(x - u)/\sigma)^{-1/\xi}$. Le coût espéré de cession en excédent d'un point d'attachement $a > u$, sans plafond, vaut*

$$\mathbb{E}[(X - a)_+] = \int_a^\infty \mathbb{P}(X > x) dx = \begin{cases} \zeta_u \sigma \frac{(1 + \xi(a - u)/\sigma)^{1-1/\xi}}{1 - \xi} & \text{si } \xi < 1, \\ +\infty & \text{si } \xi \geq 1. \end{cases} \quad (42)$$

En revanche, la prime d'un layer plafonné $[a, a + \ell]$, $\mathbb{E}[(X \wedge (a + \ell)) - (X \wedge a)] = \int_a^{a+\ell} \mathbb{P}(X > x) dx$, est finie pour tout $\ell < \infty$, quel que soit ξ .

Démonstration. Avec $w = 1 + \xi(x - u)/\sigma$, $\int_a^\infty \zeta_u w^{-1/\xi} dx = \zeta_u \frac{\sigma}{\xi} \int_{w_a}^\infty w^{-1/\xi} dw$, intégrale convergente en $+\infty$ si et seulement si $1/\xi > 1$, i.e. $\xi < 1$, auquel cas elle vaut $\zeta_u \sigma w_a^{1-1/\xi} / (1 - \xi)$. Pour un layer borné, l'intégrande est bornée sur un intervalle borné, donc l'intégrale est finie sans condition sur ξ . ■

Lecture actuarielle. La Proposition 5.1 sépare nettement les deux sources. Sous **OpRisk** ($\xi = 0,60 < 1$), un traité en excédent *illimité* attaché à 40 M€ a une prime pure finie de $\mathbb{E}[(X - 40)_+] = 19,0$ M€ par sinistre : la queue est cessible dans son intégralité. Sous **PRC** ($\xi = 1,03 \geq 1$), la même intégrale **diverge** : aucun réassureur ne peut fermer un excédent illimité, car l'espérance de la part cédée n'existe pas. Le point n'est pas que la queue PRC serait, en euros, plus lourde à toute hauteur atteignable — à troncature finie elle reste même numériquement modérée — mais qu'elle *n'a pas de moyenne* : la couverture ne converge jamais (figure 17, gauche).

Assurabilité de dernier recours

Dans le régime $\xi \geq 1$, seul un **layer plafonné** est tarifable ; la couverture illimitée a une prime pure infinie. Le plafond de sévérité de 40 M€ retenu dans le modèle n'est donc pas un artefact de calcul, mais l'expression de la **capacité de réassurance** : la limite au-delà de laquelle la queue cyber cesse d'être transférable et devient un risque de dernier recours, porté *in fine* par le bilan de l'assureur ou par un dispositif public (*pool* cyber, garantie souveraine).

La conséquence prudentielle est double. Pour le **réassureur**, la tarification cyber impose structurellement une limite par risque et par événement : la prime d'un layer $[40, 40 + \ell]$ croît sans borne

avec ℓ sous PRC (figure 17, droite), tandis qu'elle plafonne sous OpRisk — ce qui commande une discipline de *capacity management* radicalement différente selon la nature de la queue estimée. Pour l'assureur, le capital retenu après cession dépend cruciallement du plafond négocié : abaisser le plafond réduit le SCR mais accroît la fraction de risque non transférée, arbitrage que la Proposition 1.5 rend explicite (l'Expected Shortfall retenu est fini dès que la couverture plafonne la queue à $\xi < 1$ effectif). Ce mémoire fournit ainsi, au-delà du seul chiffre de capital, une grille de lecture du *partage optimal* du risque cyber entre assureur, réassureur et garant de dernier ressort.

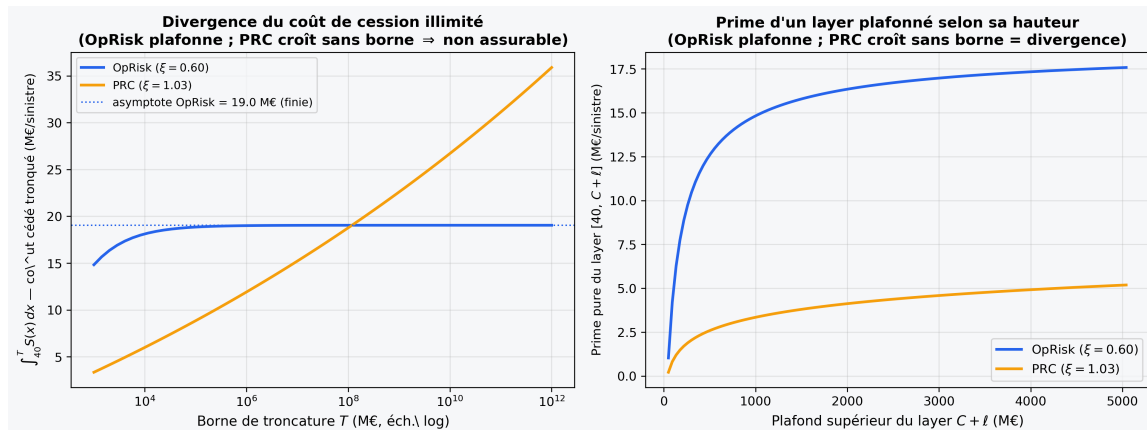


Figure 17. Assurabilité de la queue cyber. *Gauche* : coût de cession en excédent de 40 M€, tronqué à une borne T croissante — OpRisk ($\xi < 1$) converge vers son asymptote finie (19,0 M€), PRC ($\xi \geq 1$) croît sans borne (divergence). *Droite* : prime pure d'un layer plafonné $[40, 40 + \ell]$ selon sa hauteur — elle plafonne sous OpRisk, croît indéfiniment sous PRC.

5.13 Implications pour l'ORSA et le pilotage réglementaire

Les résultats obtenus ont quatre implications directes pour le pilotage prudentiel en Pilier 2.

Premièrement, la nette dominance de la brique de remédiation sous *les deux* sources (85 à 86 % du capital, cf. 5.3) suggère que les efforts de maîtrise du risque cyber devraient prioriser la réduction de la fréquence et de la sévérité des incidents opérationnels majeurs, avant la gouvernance des tiers ICT (13 à 17 %) ou le risque de sanction (marginal). Fait notable, cette hiérarchie des priorités est désormais *robuste au choix de source* : une fois la brique prestataire recalibrée en surcoût relatif et la PRC recalibrée en propre, PRC et OpRisk s'accordent sur la même structure à moins de trois points près (cf. 5.3), là où une version antérieure du moteur produisait une inversion artefactuelle entre sources. La convergence structurelle des deux calibrations indépendantes renforce donc la confiance dans cette hiérarchisation des priorités de maîtrise.

Deuxièmement, la sensibilité du capital au facteur systémique θ documentée en 5.2 justifie l'intégration, dans les scénarios de stress de l'ORSA, d'un scénario de dégradation collective de l'environnement cyber, distinct des scénarios de dégradation individuelle de la gouvernance : les deux mécanismes n'affectent pas le capital de la même façon, ni avec la même intensité selon le profil de l'entité.

Troisièmement, l'écart entre sources de sévérité — un facteur de l'ordre de 3 sur le niveau de capital (profil médian, VaR), du même ordre que le facteur 1,7 à 2,1 associé au profil de conformité — plaide pour que le pilotage interne ne retienne pas un unique scénario central, mais documente explicitement, dans le rapport ORSA, la sensibilité du SCR cyber au choix méthodologique de calibration. Cette pratique de transparence sur l'incertitude de modèle, que la formule standard de Solvabilité II, forfaitaire, ne permet structurellement pas d'exprimer,

apparaît comme une implication significative du mémoire pour la gouvernance du risque cyber en Pilier 2 : le choix de la base de calibration n'est pas un détail technique, mais l'un des deux déterminants de premier ordre du niveau de capital, à parité désormais avec le profil de conformité.

Quatrièmement, la marginalité confirmée de la brique de sanction — sous les deux sources, et de façon encore plus nette sous OpRisk — conforte le message selon lequel le capital cyber répond avant tout à un risque opérationnel et non à un risque réglementaire ponctuel, dont l'ampleur reste structurellement bornée par les plafonds légaux.

Conclusion

Le SCR cyber n'est pas un nombre, c'est une distribution large. Les résultats de ce mémoire le confirment à chaque étape : une fourchette de capital total s'étendant de **1 779 M€ à près de 21 720 M€** selon la source de sévérité, le profil de conformité et la mesure de risque retenue, soit un facteur de **12** entre ses bornes ; un Δ_{DORA} dont l'intervalle de confiance s'élargit massivement sous la source OpRisk ; et une allocation d'Euler qui, une fois la brique prestataire rendue commensurable avec la remédiation (surcoût relatif plutôt qu'échelle absolue, cf. 5.3), converge vers une structure cohérente entre sources : la brique de remédiation porte l'essentiel du capital (83 à 86 %) sous PRC comme sous OpRisk. Une fois la PRC recalibrée de bout en bout sur ses données brutes (conversion Jacobs, $\hat{\xi}_{PRC} = 1,03$), le désaccord entre sources s'est en outre nettement resserré — d'un facteur 65 à un facteur 12 entre bornes extrêmes, et d'un facteur 19 à un facteur 3 à profil comparable : deux sources indépendantes qui, calibrées chacune avec rigueur, convergent bien davantage qu'attendu vers un même diagnostic. Le désaccord résiduel porte sur le *niveau* de capital, non sur sa *structure* ni sur l'ordre de grandeur — une information honnête sur l'état actuel des données disponibles pour quantifier le risque cyber réglementaire, plutôt qu'un échec de la modélisation.

Les perspectives de ce travail sont directement liées à cette limite. Le registre d'incidents DORA que les autorités européennes de surveillance (ESA) doivent progressivement constituer à partir des notifications obligatoires prévues par le règlement constituera, à terme, la première base réellement harmonisée à l'échelle européenne pour calibrer la fréquence et la sévérité du risque cyber réglementaire — une base qui fait aujourd'hui structurellement défaut, et dont l'absence explique une part substantielle de la largeur des intervalles présentés dans ce mémoire. En ce sens, la contribution de ce travail n'est pas de clore le débat sur le niveau du SCR cyber, mais d'en formaliser la structure d'incertitude, dans l'attente de données futures plus riches.

Perspectives de raffinement

Au-delà de l'enrichissement des données, quatre axes de raffinement méthodologique prolongent naturellement ce mémoire.

1. D'un capital statique à un capital dynamique (Hawkes / SIR-Cox). Le modèle retenu adopte, conformément à l'exigence réglementaire de la VaR à un an, une vision *statique* du risque. Or la littérature récente (Bessy-Roland et al., 2021 ; Hillairet et al., 2026) montre que la sinistralité cyber est fortement *auto-excité* : une faille *zero-day* déclenche une grappe temporelle de sinistres. Remplacer la fréquence binomiale négative par un processus de Hawkes multivarié — ou par le couplage SIR-Cox de Hillairet et al. (2026) — permettrait de capturer cette dynamique de contagion et de produire un SCR *multi-périodes*, au prix d'une réévaluation dynamique du capital. La variable latente de Vasicek utilisée ici (Proposition 1.7) constitue une approximation statique de premier ordre de ce mécanisme ; son remplacement par un facteur systémique à mémoire est la voie de raffinement la plus directe.

2. Une inférence bayésienne hiérarchique inter-sources. La triangulation du §5.10 a montré la cohérence des estimations, mais traite PRC et OpRisk comme deux calibrations séparées. Un modèle bayésien *hiérarchique* — où les indices de queue ξ_{PRC} et ξ_{OpRisk} seraient tirés d'une loi commune de niveau supérieur — permettrait un partage d'information (*shrinkage*) entre sources, réduisant la variance d'estimation là où chaque base est individuellement pauvre en excès ($N_u = 91$ pour OpRisk). L'algorithme de Metropolis développé en Annexe C en fournit la brique élémentaire.

3. Le registre DORA comme socle de calibration. Le registre d'incidents que les autorités européennes de surveillance constituent à partir des notifications obligatoires offrira, pour la première fois, une base harmonisée couvrant toutes les strates du marché. Il lèvera le biais de sélection (gdonnées) et rendra empiriquement estimable la structure de dépendance entre l'entité et ses tiers ICT — validant ou infirmant le coefficient de queue de Gumbel $\lambda_U = 0,53$ postulé ici (Proposition 1.6). La méthodologie de ce mémoire est explicitement conçue pour accueillir cette donnée dès qu'elle sera disponible.

4. Vers une allocation d'Euler dynamique et une mesure ES. Enfin, Solvabilité II raisonne en VaR 99,5 %, mais la nature à queue lourde du risque cyber (indice ξ proche, voire supérieur à 1) plaide pour une mesure d'Expected Shortfall, cohérente au sens d'Artzner. La forme fermée établie en Proposition 1.5 rend ce passage immédiat lorsque $\xi < 1$; le régime d'espérance infinie de la source PRC ($\xi = 1,03$) rappelle toutefois que, sans plafond de réassurance, l'ES cyber peut ne pas exister — un résultat qui interroge la pertinence même d'un capital fini pour les strates les plus extrêmes du risque numérique, et ouvre le débat sur l'assurabilité de dernier recours.

A Démonstrations complémentaires

Cette annexe rassemble les démonstrations détaillées des résultats énoncés dans le corps du mémoire, dont seule l'esquisse y figurait.

A.1 Fisher–Tippett–Gnedenko (Théorème 1.1)

La loi limite H des maxima normalisés est *max-stable* : $H^t(x) = H(a_t x + b_t)$ pour tout $t > 0$. En posant $g(x) = -\ln H(x)$, la max-stabilité devient l'équation fonctionnelle $t g(a_t x + b_t) = g(x)$. Sa résolution (via la théorie des fonctions à variation régulière de Karamata) impose $g(x) = (1 + \xi x)^{-1/\xi}$, soit $H = H_\xi$. Le domaine d'attraction se caractérise ensuite par le comportement de queue : $F \in \text{DA}(H_\xi)$ avec $\xi > 0$ si et seulement si $\bar{F}$ est à variation régulière d'indice $-1/\xi$, i.e. $\bar{F}(tx)/\bar{F}(x) \rightarrow t^{-1/\xi}$. Les lois lognormale et gamma relèvent du cas $\xi = 0$ (Gumbel) ; les lois à support borné du cas $\xi < 0$ (Weibull).

A.2 Pickands–Balkema–de Haan (Théorème 1.2)

Pour $F \in \text{DA}(H_\xi)$, il existe une fonction positive $a(\cdot)$ telle que, pour $y \geq 0$, $\lim_{u \rightarrow x_F} \bar{F}(u + y a(u))/\bar{F}(u) = (1 + \xi y)^{-1/\xi}$. Or $\bar{F}(u + y a(u))/\bar{F}(u) = \mathbb{P}(X > u + y a(u) \mid X > u) = 1 - F_u(y a(u))$, dont la limite est la survie GPD $\bar{G}_{\xi,1}(y)$. En posant $\sigma(u) = a(u)$, on obtient $F_u(y) \rightarrow G_{\xi,\sigma(u)}(y)$. La convergence est uniforme car les F_u sont des fonctions de répartition monotones convergeant vers une limite continue (théorème de Pólya). Le paramètre ξ est préservé car il gouverne à la fois la variation régulière de $\bar{F}$ et la forme de la GPD limite.

A.3 Dérivation de l'approximation SLA (§5.10)

Soit $S = \sum_{i=1}^M X_i$ avec M de fonction génératrice G_M et X_i i.i.d. *sous-exponentielles* ($\bar{F}^{*n}(x) \sim n \bar{F}(x)$). La sous-exponentialité entraîne $\bar{F}_S(x) \sim \mathbb{E}[M] \bar{F}_X(x)$ quand $x \rightarrow \infty$: la queue de la somme est dominée par celle de la plus grande perte. En inversant $\bar{F}_S(\text{VaR}_\alpha) = 1 - \alpha$, on obtient $\bar{F}_X(\text{VaR}_\alpha) \approx (1 - \alpha)/\mathbb{E}[M]$, d'où, avec $\mathbb{E}[M] = \lambda_{\text{eff}}$ et la forme GPD de X ,

$$\text{VaR}_\alpha(S) \approx F_X^{-1}(1 - (1 - \alpha)/\lambda_{\text{eff}}) = u + \frac{\sigma}{\xi} [((1 - \alpha)/\lambda_{\text{eff}})^{-\xi} - 1]. \quad (43)$$

La correction du second ordre (Böcker and Sprittulla, 2006) ajoute la moyenne des pertes restantes $(\lambda_{\text{eff}} - 1) \mathbb{E}[X]$, d'où l'écart observé ($-4,6\%$ contre -16% au premier ordre) sur la calibration OpRisk.

A.4 Récursion de Panjer : principe et exemple

Lorsque la loi de comptage appartient à la classe $(a, b, 0)$ — $\mathbb{P}(M = k) = (a + b/k) \mathbb{P}(M = k - 1)$, ce qui couvre Poisson, binomiale et binomiale négative — et que la sévérité est discrétisée sur une grille $\{0, h, 2h, \dots\}$ de masses f_j , la loi agrégée $g_k = \mathbb{P}(S = kh)$ se calcule par la récursion exacte

$$g_k = \frac{1}{1 - a f_0} \sum_{j=1}^k \left(a + \frac{b j}{k} \right) f_j g_{k-j}, \quad g_0 = G_M(f_0). \quad (44)$$

Pour la binomiale négative amincie $\text{NegBin}(r, p_2)$, $a = 1 - p_2$ et $b = (r - 1)(1 - p_2)$. *Exemple minimal* : avec $r = 2$, $p_2 = 0,5$ et une sévérité à deux points $f_1 = f_2 = 0,5$, on obtient $g_0 = 0,25$, $g_1 = 0,125$, $g_2 \approx 0,148$, etc. La récursion est exacte mais souffre, pour une queue GPD $\xi \approx 0,6$, d'une grille de plusieurs millions de points et d'une accumulation d'erreurs d'arrondi ; la FFT (Algorithme 2) en constitue la réalisation numériquement stable, d'où son choix pour la triangulation.

A.5 Information de Fisher de la GPD (Proposition 1.3)

On part de la log-vraisemblance (14), écrite par observation avec $W_i = 1 + \xi Y_i / \sigma$:

$$\ell_i(\xi, \sigma) = -\ln \sigma - \left(1 + \frac{1}{\xi}\right) \ln W_i. \quad (45)$$

Moments-clés. La transformation de probabilité intégrale donne $W_i^{-1/\xi} = \bar{G}(Y_i) \sim \mathcal{U}(0, 1)$, donc $W_i \stackrel{d}{=} U^{-\xi}$ avec $U \sim \mathcal{U}(0, 1)$. On en déduit les quatre moments qui suffisent au calcul :

$$\mathbb{E}[W^{-1}] = \mathbb{E}[U^\xi] = \frac{1}{1+\xi}, \quad \mathbb{E}[W^{-2}] = \frac{1}{1+2\xi}, \quad \mathbb{E}[\ln W] = -\xi \mathbb{E}[\ln U] = \xi, \quad \mathbb{E}[(\ln W)^2] = 2\xi^2, \quad (46)$$

tous finis dès que $\xi > -\frac{1}{2}$ (condition assurant $\mathbb{E}[W^{-2}] < \infty$).

Score et hessienne. En dérivant ℓ_i ,

$$\partial_\xi \ell_i = \frac{1}{\xi^2} \ln W_i - \left(1 + \frac{1}{\xi}\right) \frac{Y_i/\sigma}{W_i}, \quad \partial_\sigma \ell_i = -\frac{1}{\sigma} + \left(1 + \frac{1}{\xi}\right) \frac{\xi Y_i/\sigma^2}{W_i}.$$

En prenant l'espérance de l'opposé des dérivées secondes et en substituant les moments ci-dessus, on obtient l'information de Fisher par observation

$$\mathcal{I}(\xi, \sigma) = \frac{1}{1+2\xi} \begin{pmatrix} 2 & \sigma^{-1} \\ \sigma^{-1} & \sigma^{-2}(1+\xi) \end{pmatrix}, \quad \mathcal{I}^{-1} = (1+\xi) \begin{pmatrix} 1+\xi & -\sigma \\ -\sigma & 2\sigma^2 \end{pmatrix}. \quad (47)$$

La variance asymptotique de $\hat{\xi}$ est le terme $(1, 1)$ de $\mathcal{I}^{-1}$ divisé par N_u , soit $(1+\xi)^2/N_u$; celle de $\hat{\sigma}$ vaut $2\sigma^2(1+\xi)/N_u$. Le terme hors-diagonal négatif $-\sigma(1+\xi)$ traduit la corrélation négative entre $\hat{\xi}$ et $\hat{\sigma}$, retrouvée empiriquement sur le nuage *a posteriori* bayésien (figure 15). La condition $\xi > -\frac{1}{2}$ garantit la finitude des moments impliqués, donc la validité de la normalité asymptotique classique de l'EMV (Smith, 1987).

A.6 Estimateur de Hill (Proposition 1.4)

Sous variation régulière $\bar{F}(x) = x^{-1/\xi} \ell(x)$ avec ℓ à variation lente, les log-espacements $\log X_{(i)} - \log X_{(i+1)}$ des k plus grandes statistiques d'ordre sont, à la limite, des variables exponentielles indépendantes d'espérance ξ/i (représentation de Rényi). L'estimateur $\hat{\xi}_{Hill}(k) = \frac{1}{k} \sum_{i=1}^k (\log X_{(i)} - \log X_{(k+1)})$ est alors une moyenne empirique d'espérance ξ et de variance ξ^2/k ; le théorème central limite donne $\sqrt{k}(\hat{\xi}_{Hill} - \xi) \xrightarrow{d} \mathcal{N}(0, \xi^2)$, sous la condition de second ordre $\sqrt{k} A(n/k) \rightarrow 0$ contrôlant le biais dû à ℓ .

A.7 VaR et TVaR de la GPD (Proposition 1.5)

La forme fermée de la VaR découle directement de l'inversion de la fonction de survie POT $\bar{F}(x) = \zeta_u(1 + \xi(x-u)/\sigma)^{-1/\xi}$. Pour la TVaR, on utilise $\text{TVaR}_\alpha = \frac{1}{1-\alpha} \int_\alpha^1 \text{VaR}_s \, ds$; la stabilité de la GPD (l'excès au-delà de tout seuil $v > u$ reste GPD de forme ξ et d'échelle $\sigma + \xi(v-u)$) donne $\mathbb{E}[X - \text{VaR}_\alpha \mid X > \text{VaR}_\alpha] = \frac{\sigma + \xi(\text{VaR}_\alpha - u)}{1-\xi}$ pour $\xi < 1$, d'où (18). Pour $\xi \geq 1$, $\int_u^\infty \bar{F} = \infty$: la moyenne de queue diverge.

A.8 Queues de la copule de Gumbel (Proposition 1.6)

La dépendance de queue supérieure est calculée dans le corps. Pour la dépendance inférieure, $\lambda_L = \lim_{q \rightarrow 0+} C_\eta(q, q)/q = \lim_{q \rightarrow 0+} q^{2^{1/\eta}-1} = 0$ car $2^{1/\eta} > 1$ pour $\eta > 1$. Le τ de Kendall d'une copule archimédienne de générateur ϕ vaut $\tau = 1 + 4 \int_0^1 \frac{\phi(t)}{\phi'(t)} dt$; avec $\phi(t) = (-\ln t)^\eta$ on obtient $\tau = 1 - 1/\eta$.

A.9 Sensibilité du modèle de Vasicek (Proposition 1.7)

En dérivant (25) par rapport à y , $\partial_y \text{PCD}_i(y) = -\frac{\sqrt{\rho}}{\sqrt{1-\rho}} \varphi\left(\frac{\Phi^{-1}(p)-\sqrt{\rho}y}{\sqrt{1-\rho}}\right) < 0$: la fonction est décroissante. Lorsque $\rho \rightarrow 1$, l'argument tend vers $\pm\infty$ selon le signe de $\Phi^{-1}(p)-y$, et $\text{PCD}_i(y) \rightarrow \mathbf{1}\{y < \Phi^{-1}(p)\}$: le défaut devient déterministe conditionnellement au facteur systémique, régime de contagion maximale.

A.10 Allocation d'Euler (Théorème 3.1)

ρ étant homogène de degré 1 en les expositions $\mathbf{h} = (h_1, \dots, h_d)$ via $r(\mathbf{h}) = \rho(\sum_k h_k L_k)$, le théorème d'Euler sur les fonctions homogènes donne $r(\mathbf{h}) = \sum_k h_k \partial_{h_k} r(\mathbf{h})$; évalué en $\mathbf{h} = \mathbf{1}$, $\rho(L) = \sum_k \partial_{h_k} r(\mathbf{1})$. Pour $\rho = \text{VaR}_\alpha$, un résultat de Tasche (1999) montre que $\partial_{h_k} \text{VaR}_\alpha(\sum_j h_j L_j) = \mathbb{E}[L_k \mid \sum_j h_j L_j = \text{VaR}_\alpha]$ sous régularité de la densité jointe, d'où $AC_k = \mathbb{E}[L_k \mid L = \text{VaR}_\alpha(L)]$; le passage à TVaR_α s'obtient par intégration sur α . L'unicité comme seule allocation compatible RORAC est démontrée dans la même référence.

B Table des notations

Symbole	Signification
ξ, σ, u	Indice de queue, échelle et seuil POT de la GPD de sévérité
$\zeta_u = p_u$	Probabilité de dépassement du seuil $\mathbb{P}(X > u)$
N_u	Nombre d'excès au-delà de u
$\text{VaR}_\alpha, \text{TVaR}_\alpha$	Value-at-Risk et Tail-VaR (Expected Shortfall) au niveau $\alpha = 99,5\%$
$\lambda, \lambda_{\text{eff}}$	Fréquence annuelle d'incidents ; fréquence de pertes non nulles
r, p	Paramètres de la loi binomiale négative de fréquence
η	Paramètre de la copule de Gumbel ($\eta \geq 1$)
λ_U, λ_L	Coefficients de dépendance de queue supérieure / inférieure
τ	τ de Kendall
ρ	Corrélation d'actifs du modèle de Vasicek
Y, X_i, Z_i	Facteur systémique, facteur idiosyncratique, robustesse latente
$\text{PCD}_i(y)$	Probabilité conditionnelle de défaut de conformité
L_{DORA}, AC_k	Perte agrégée DORA ; contribution d'Euler de la brique k
Δ_{DORA}	Surcoût de capital imputable à la non-conformité
S_0, S_1, S_2	Scénarios conforme / partiel / non-conforme

C Algorithmes

Algorithme 1 — Agrégation LDA par Monte Carlo (une année simulée).

1. Tirer la fréquence $N \sim \text{NegBin}(r, p)$ (moyenne λ , dispersion 9,2).
2. Pour chaque événement : tirer un indicateur de queue $\sim \text{Bernoulli}(p_u)$; si actif, sévérité $= u + \text{GPD}(\xi, \sigma)$ (plafonnée si source PRC), sinon 0.
3. Agréger par brique (remédiation, prestataire); tirer la brique sanction via une loi Bêta pilotée par PCD.
4. Tirer les uniformes de la copule de Gumbel $U \sim C_\eta$ et appliquer la surcharge systémique $L_k \leftarrow L_k(1 + U_k \cdot s_{\max})$.
5. Sommer les briques; répéter n_{sim} fois; estimer VaR_α par quantile empirique.

Algorithme 2 — Agrégation exacte par FFT (§5.10).

1. Discrétiser la sévérité $X = u + \text{GPD}$ sur une grille de pas h : $f_X[j] = F_X(e_{j+1}) - F_X(e_j)$.
2. Calculer $\varphi_X = \text{FFT}(f_X)$.
3. Composer par la fonction génératrice de comptage : $G = (p_2/(1 - (1 - p_2)\varphi_X))^r$ (NegBin amincie).
4. Inverser : $g = \text{FFT}^{-1}(G)$; en déduire la fonction de répartition cumulée et le quantile α .

Algorithme 3 — GPD bayésienne (Metropolis).

1. Initialiser $(\xi, \log \sigma)$; priors $\xi \sim \mathcal{U}(-0,5, 2)$, σ log-uniforme.
2. À chaque itération : proposer $(\xi', \log \sigma')$ par marche aléatoire gaussienne.
3. Accepter avec probabilité $\min\{1, \exp(\ell' - \ell + \text{jacobien})\}$.
4. Après rodage, résumer la chaîne : moyenne *a posteriori*, intervalle de crédibilité, VaR prédictive.

D Paramètres calibrés

Paramètre	OpRisk	PRC (Jacobs)
Indice de queue $\hat{\xi}$	0,595	1,033
IC 90 % (bootstrap)	[0,304 ; 0,831]	[0,971 ; 1,094]
Échelle $\hat{\sigma}$ (M€)	57,97	6,51
Seuil u (M€)	20,03	4,18
$p_u = \mathbb{P}(X > u)$	0,151	0,150
Nombre d'excès N_u	91	2 258
VaR 99,5 % mono-perte (M€)	663,0	209,2
Régime de moment	$\mathbb{E}[X] < \infty$	$\mathbb{E}[X] = \infty$ ($\xi \geq 1$)

Autres paramètres du modèle	Valeur
Fréquence de référence λ (PRC)	341 /an
Facteur de dispersion (Var/Moyenne)	9,20
Copule de Gumbel — non conforme η_{S_2}	1,8 ($\lambda_U = 0,53$)
Copule de Gumbel — conforme η_{S_0}	1,2 ($\lambda_U = 0,22$)
τ de Kendall (non conforme)	0,444
Plafond de sévérité PRC (réassurance)	40 M€
Allocation d'Euler (OpRisk)	remédiation 86 % / prestataire 14 % / sanction ≈ 0 %

Références

- Balkema, A. A. and de Haan, L. (1974). Residual life time at great age. *The Annals of Probability*, 2(5) :792–804.
- Beirlant, J., Goegebeur, Y., Segers, J., and Teugels, J. (2004). *Statistics of Extremes : Theory and Applications*. Wiley.
- Bessy-Roland, Y., Boumezoued, A., and Hillairet, C. (2021). Multivariate hawkes process for cyber insurance. *Annals of Actuarial Science*, 15(1) :14–39.
- Biener, C., Eling, M., and Wirfs, J. H. (2015). Insurability of cyber risk : An empirical analysis. *The Geneva Papers on Risk and Insurance – Issues and Practice*, 40 :131–158.
- Böcker, K. and Klüppelberg, C. (2005). Operational VaR : a closed-form approximation. *Risk Magazine*, 18(12) :90–93.
- Böcker, K. and Sprittulla, J. (2006). Operational VaR : meaningful means. *Risk Magazine*, 19(12) :96–98.
- Eling, M. and Loperfido, N. (2017). Data breaches : Goodness of fit, pricing, and risk measurement. *Insurance : Mathematics and Economics*, 75 :126–136.
- Eling, M. and Wirfs, J. (2019). What are the actual costs of cyber risk events? *European Journal of Operational Research*, 272(3) :1109–1119.
- Embrechts, P., Klüppelberg, C., and Mikosch, T. (1997). *Modelling Extremal Events for Insurance and Finance*. Springer.
- ENISA (2023). Enisa threat landscape 2023. Technical report, European Union Agency for Cybersecurity.
- Farkas, S., Lopez, O., and Thomas, M. (2021). Cyber claim analysis using generalized pareto regression trees with applications to insurance. *Insurance : Mathematics and Economics*, 98 :92–105.
- Fisher, R. A. and Tippett, L. H. C. (1928). Limiting forms of the frequency distribution of the largest or smallest member of a sample. *Mathematical Proceedings of the Cambridge Philosophical Society*, 24(2) :180–190.
- Gnedenko, B. V. (1943). Sur la distribution limite du terme maximum d’une série aléatoire. *Annals of Mathematics*, 44(3) :423–453.
- Hill, B. M. (1975). A simple general approach to inference about the tail of a distribution. *The Annals of Statistics*, 3(5) :1163–1174.
- Hillairet, C. and Lopez, O. (2021). Propagation of cyber incidents in an insurance portfolio : counting processes combined with compartmental epidemiological models. *Scandinavian Actuarial Journal*.
- Hillairet, C., Lopez, O., d’Oultremont, L., and Spoorenberg, B. (2022). Cyber-contagion model with network structure applied to insurance. *Insurance : Mathematics and Economics*.
- Hillairet, C., Lopez, O., and Sopgoui, L. (2026). A stochastic sir model for cyber contagion : application to granular growth of firms and to insurance portfolio. arXiv :2603.15369.
- Maillart, T. and Sornette, D. (2010). Heavy-tailed distribution of cyber-risks. *The European Physical Journal B*, 75(3) :357–364.

- McNeil, A. J., Frey, R., and Embrechts, P. (2015). *Quantitative Risk Management : Concepts, Techniques and Tools*. Princeton University Press, revised edition.
- Microsoft Security (2019). One simple action you can take to prevent 99.9 percent of attacks on your accounts. Microsoft Security Blog l'authentification multifacteur bloque plus de 99,2 % des compromissions de comptes.
- Pickands III, J. (1975). Statistical inference using extreme order statistics. *The Annals of Statistics*, 3(1) :119–131.
- Smith, R. L. (1987). Estimating tails of probability distributions. *The Annals of Statistics*, 15(3) :1174–1207.
- Tasche, D. (1999). Risk contributions and performance measurement. Technical report, Zentrum Mathematik, TU München.
- Wheatley, S., Maillart, T., and Sornette, D. (2016). The extreme risk of personal data breaches and the erosion of privacy. *The European Physical Journal B*, 89(1) :7.